

Final Report

Ayaan Hirsi 17317721

Table of Contents

Table of Figures	Error! Bookmark not defined.
Executive Summary	4
Deployment Topology	4
CIS Top 18 Controls Implementation	5
Control 1 — Inventory of Enterprise Assets	5
Control 2 — Inventory of Software Assets	11
Control 3 — Data Protection	16
Control 4 — Secure Configuration of Enterprise Assets and Software	24
Control 5 — Account Management	34
Control 6 — Access Control Management	40
Control 7 — Continuous Vulnerability Management	45
Control 8 — Audit Log Management	49
Control 9 — Email and Web Browser Protections	52
Control 10 — Malware Defenses	56
Control 11 Data Recovery	59
Control 12 Network Infrastructure Management	61
Control 13 Network Monitoring and Defense	63
Control 14 — Security Awareness and Skills Training	71
Control 15 Service Provider Management	72
Control 16 Application Software Security	74
Control 17 Incident Response Management	76
Control 18 — Penetration Testing	79
Security Automation and Response	81
Workflow 1 — EternalBlue Active Response	81
Workflow 2 — SSH Brute Force SOAR Response	84
Challenges and Resolutions	86

Conclusion	87
References.....	88

Executive Summary

Phase 3 extends the Group 5 monitoring infrastructure deployed in Phases 1 and 2 by implementing all eighteen CIS Top 18 Controls across the segmented lab environment, configuring automated active response workflows, and integrating a SOAR platform for orchestrated incident response. The Wazuh Manager at 172.16.23.34 serves as the central SIEM, with seven enrolled agents spanning Windows Server, Ubuntu Linux, and container hosts. Two fully operational automation workflows are demonstrated: an EternalBlue active response that automatically blocks attacker IPs via iptables when rule 100004 fires, and a SOAR pipeline in which Wazuh forwards SSH brute force alerts to n8n, which extracts the attacker IP and executes a remote iptables block on the VPN server. All eighteen CIS controls are addressed with technical implementation evidence; where lab constraints prevent full implementation, gaps are explicitly documented.

Deployment Topology

The G5 environment is built on a single hypervisor host running VMware, segmented across five primary zones by a CoreRouter (172.16.23.33) running Ubuntu 24.04.2 LTS. The Management zone (172.16.23.32/28) hosts the Wazuh Manager, n8n SOAR, and Security Onion. The AD zone (172.16.33.0/26) hosts GS-AD running Windows Server 2019 with Active Directory, Sysmon64, and DHCP. The DMZ (172.16.48.x/29 series) hosts jumpbox-ssh, jumpbox-rdp, OpenVPN, a reverse proxy, WAF, and the container host running CorpWeb, IntWeb, FileSharing, and E-Site as Docker containers across VLANs 30 through 34. The Internal zone (172.16.23.0/28) hosts internal user and admin workstations.

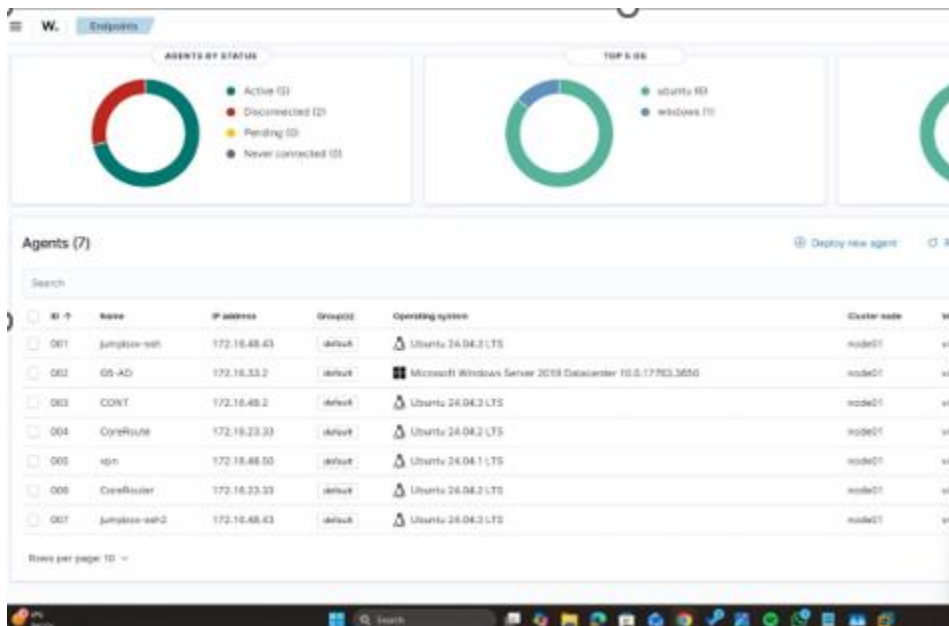
Seven Wazuh agents are enrolled: GS-AD (002), mgmt (003/004), vpn (005), CoreRouter (006), jumpbox-ssh2 (007), and CONT (009). The Wazuh dashboard and OpenSearch are accessible at 172.16.23.34, and the n8n SOAR instance is deployed at 172.16.23.35.

CIS Top 18 Controls Implementation

Control 1 — Inventory of Enterprise Assets

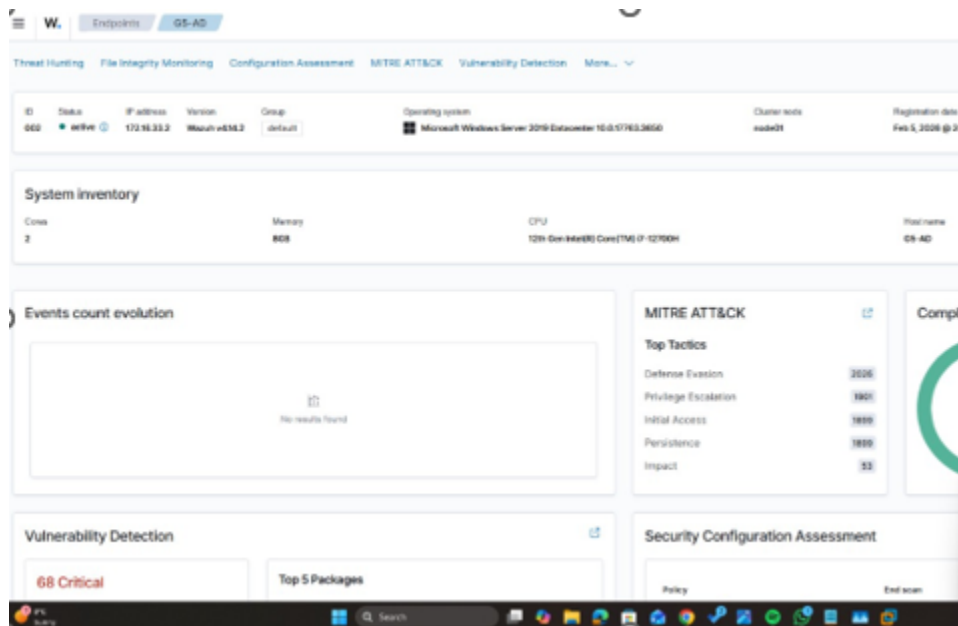
Active and continuous asset discovery is implemented through three complementary mechanisms. Wazuh's syscollector module provides real-time visibility into all monitored hosts, collecting hardware, network interface, and OS data from all seven enrolled agents automatically every 24 hours. An active nmap-based discovery script runs on the core router daily at 06:00 via cron, scanning all nine subnets and comparing discovered hosts against an approved baseline, with unknown IPs triggering a syslog alert forwarded to Wazuh. A passive tcpdump-based listener also runs on the core router as a systemd service, capturing traffic on all interfaces for five minutes every hour without transmitting any discovery packets. DHCP audit logging is enabled on GS-AD with logs stored at C:\Windows\System32\dhcp\, recording all IP lease events including hostname, MAC address, and timestamp.

Wazuh Endpoints dashboard displaying all seven enrolled enterprise assets with agent ID, hostname, IP address, operating system, version, and active status, satisfying CIS Control 1.1 asset inventory requirements.



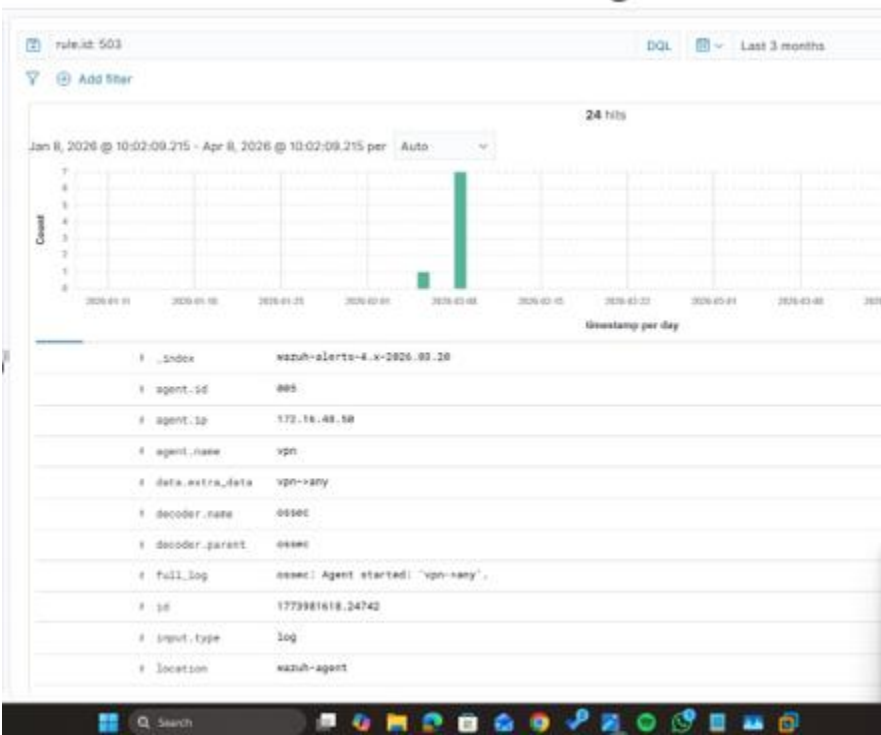
1.1a - Wazuh Agents Summary Dashboard

G5-AD agent detail page showing system inventory including CPU model, memory (8GB), hostname, and compliance mapping, confirming hardware-level asset data collection by Wazuh syscollector.



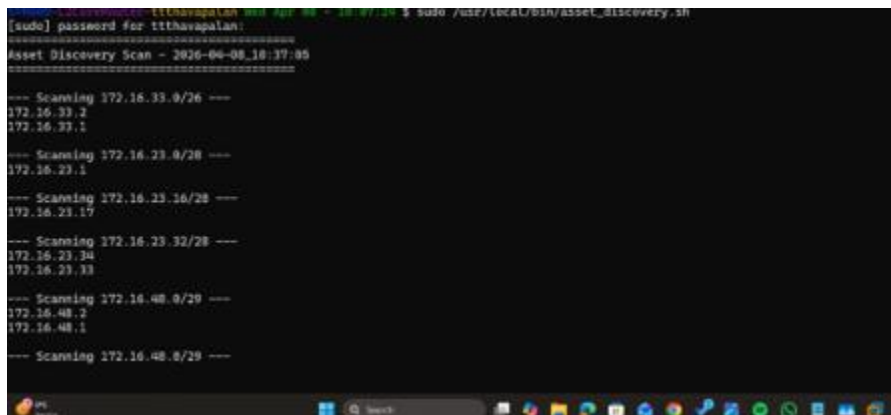
1.1b - Wazuh Agent Info with System Inventory

Wazuh Security Events filtered by rule.id 503 showing agent enrollment events, with the most recent event from the VPN agent (172.16.48.50), demonstrating automated detection of new assets connecting to the network.



1.2 - Wazuh Agent Enrollment Alert

Active asset discovery script executing on the core router, scanning all nine network subnets sequentially and displaying live discovered hosts per subnet.



```
[sude] password for tithavapalan:
=====
Asset Discovery Scan - 2026-06-08_18:37:55
=====

--- Scanning 172.16.33.0/26 ---
172.16.33.2
172.16.33.1

--- Scanning 172.16.23.0/28 ---
172.16.23.1

--- Scanning 172.16.23.16/28 ---
172.16.23.17

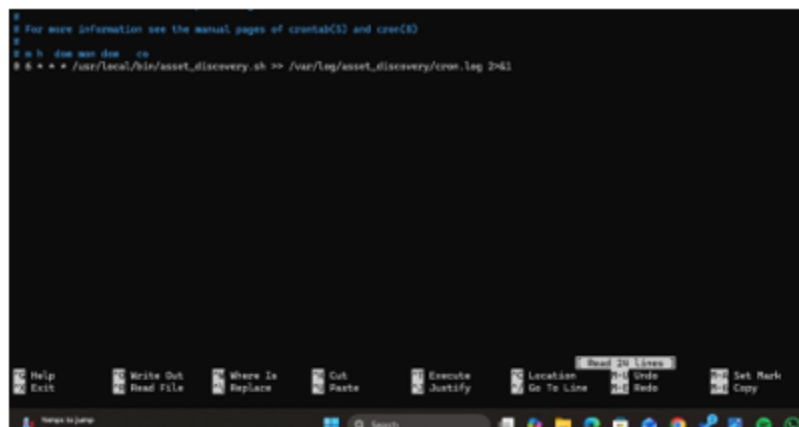
--- Scanning 172.16.23.32/28 ---
172.16.23.34
172.16.23.33

--- Scanning 172.16.48.0/29 ---
172.16.48.2
172.16.48.1

--- Scanning 172.16.48.0/29 ---
```

1.3a - Asset Discovery Script nmap Output

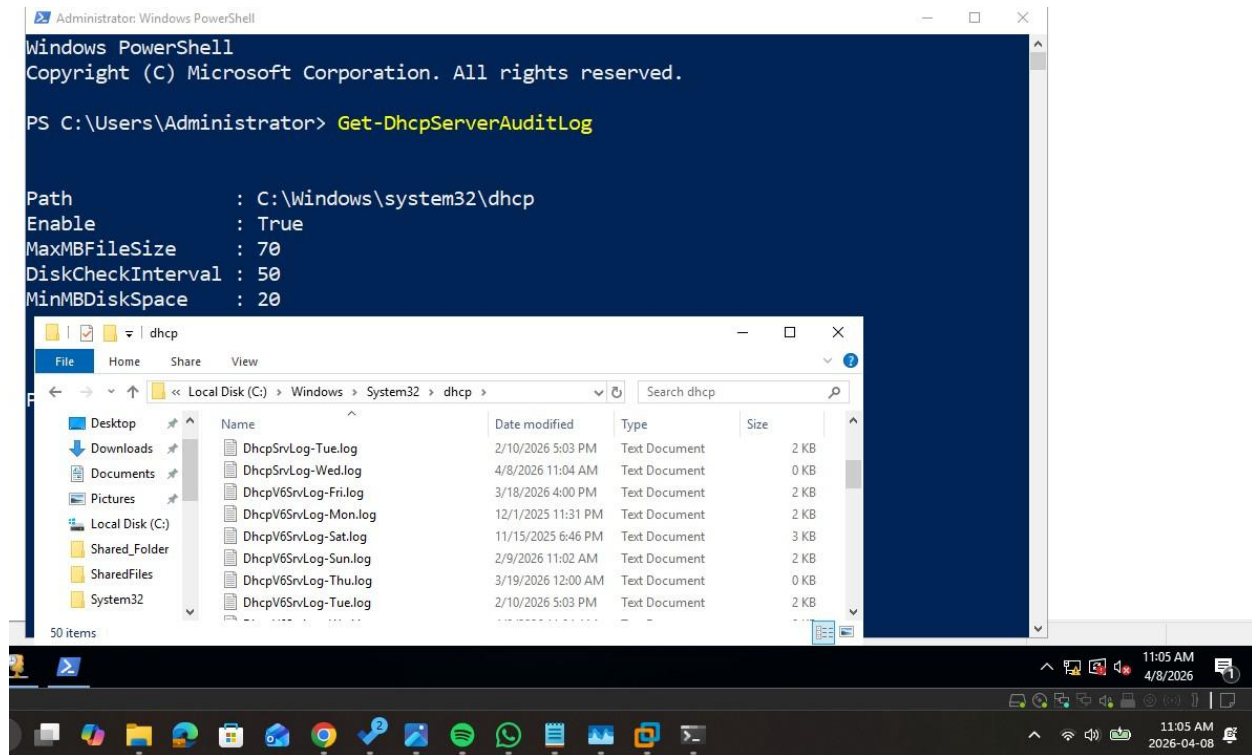
Root crontab entry on the core router scheduling the asset discovery script to execute daily at 06:00, satisfying the CIS Control 1.3 requirement for daily active discovery execution.



```
# For more information see the manual pages of crontab(5) and cron(8)
#
# m h dom mon dow   day
# * * * * * /usr/local/bin/asset_discovery.sh >> /var/log/asset_discovery/cron.log 2>&1
```

1.3b - Cron Job for Asset Discovery

Windows PowerShell output of Get-DhcpServerAuditLog on GS-AD confirming DHCP audit logging is enabled with log path C:\Windows\System32\dhcp



1.4a - DHCP Server Audit Log Enabled

Contents of the DHCP server audit log file showing IP lease renewal events for jumpbox-ssh with MAC addresses and timestamps, demonstrating DHCP-based asset inventory updates.

```

DhcpSrvLog-Thu.log - Notepad
File Edit Format View Help
24,03/19/26,15:07:56,Database Cleanup Begin,,,,,0,6,,,,,,0
30,03/19/26,15:07:56,DNS Update Request,172.16.23.3,user-g5.G5.LOCAL,,,0,6,,,,,,0
25,03/19/26,15:07:56,0 leases expired and 0 leases deleted,,,,,0,6,,,,,,0
25,03/19/26,15:07:56,0 leases expired and 0 leases deleted,,,,,0,6,,,,,,0
31,03/19/26,15:08:06,DNS Update Failed,172.16.23.3,user-g5.G5.LOCAL,,,0,6,,,,,,9002
30,03/19/26,15:40:50,DNS Update Request,172.16.48.43,jumpbox-ssh.G5.LOCAL,,,0,6,,,,,,0
11,03/19/26,15:40:50,Renew,172.16.48.43,jumpbox-ssh.G5.LOCAL,2B9434C100020000AB11B55589BCE74D20EC,,4219687
31,03/19/26,15:41:00,DNS Update Failed,172.16.48.43,jumpbox-ssh.G5.LOCAL,,,0,6,,,,,,9005
24,03/19/26,16:07:56,Database Cleanup Begin,,,,,0,6,,,,,,0
30,03/19/26,16:07:56,DNS Update Request,172.16.23.3,user-g5.G5.LOCAL,,,0,6,,,,,,0
25,03/19/26,16:07:56,0 leases expired and 0 leases deleted,,,,,0,6,,,,,,0
25,03/19/26,16:07:56,0 leases expired and 0 leases deleted,,,,,0,6,,,,,,0
31,03/19/26,16:08:07,DNS Update Failed,172.16.23.3,user-g5.G5.LOCAL,,,0,6,,,,,,9002
30,03/19/26,16:18:44,DNS Update Request,172.16.48.43,jumpbox-ssh.G5.LOCAL,,,0,6,,,,,,0
12,03/19/26,16:18:44,Release,172.16.48.43,jumpbox-ssh.G5.LOCAL,2B9434C100020000AB11B55589BCE74D20EC,,4219687
12,03/19/26,16:18:44,Release,172.16.48.43,jumpbox-ssh.G5.LOCAL,2B9434C100020000AB11B55589BCE74D20EC,,4219687
12,03/19/26,16:18:44,Release,172.16.48.43,jumpbox-ssh.G5.LOCAL,2B9434C100020000AB11B55589BCE74D20EC,,4219687
30,03/19/26,16:18:54,DNS Update Request,172.16.48.43,jumpbox-ssh.G5.LOCAL,,,0,6,,,,,,0

```

1.4b - DHCP Log IP Lease Entries

Systemd service status of passive-discovery.service on the core router showing the service active and running, with journal logs confirming passive tcpdump capture without transmitting any discovery packets.

```

CoreRouter-11thavapalan Wed Apr 08 - 10:51:36 $ sudo systemctl status passive-discovery.service
passive-discovery.service - CIS Control 1.5 - Passive Asset Discovery
Loaded: loaded (/etc/systemd/system/passive-discovery.service; enabled; preset: enabled)
Active: active (running) since Wed 2026-04-08 11:40:46 EDT; 2s ago
Docs: https://www.cisecurity.org/controls/v8
Main PID: 5213 (passive_discover)
Tasks: 2 (limit: 9379)
Memory: 1.0M (peak: 2.1M)
CPU: 87ms
CGroup: /system.slice/passive-discovery.service
└─5213 /bin/bash /usr/local/bin/passive_discovery.sh
└─5213 tcpdump -i any -w /tmp/passive_11Vs.pcap -C 300 -W 1

Apr 08 11:40:46 CoreRouter systemd[1]: Started passive-discovery.service - CIS Control 1.5 - Passive Asset Discovery.
Apr 08 11:40:46 CoreRouter passive-discovery[5213]: [2026-04-08 11:40:46] Passive discovery service started.
Apr 08 11:40:46 CoreRouter passive-discovery[5213]: [2026-04-08 11:40:46] Starting passive capture for 300s on interface any...
CoreRouter-11thavapalan Wed Apr 08 - 10:51:36 $ sudo journalctl -u passive-discovery.service --no-pager | tail -40
Apr 08 11:40:46 CoreRouter systemd[1]: Started passive-discovery.service - CIS Control 1.5 - Passive Asset Discovery.
Apr 08 11:40:46 CoreRouter passive-discovery[5213]: [2026-04-08 11:40:46] Passive discovery service started.
Apr 08 11:40:46 CoreRouter passive-discovery[5213]: [2026-04-08 11:40:46] Starting passive capture for 300s on interface any...
CoreRouter-11thavapalan Wed Apr 08 - 10:51:36 $

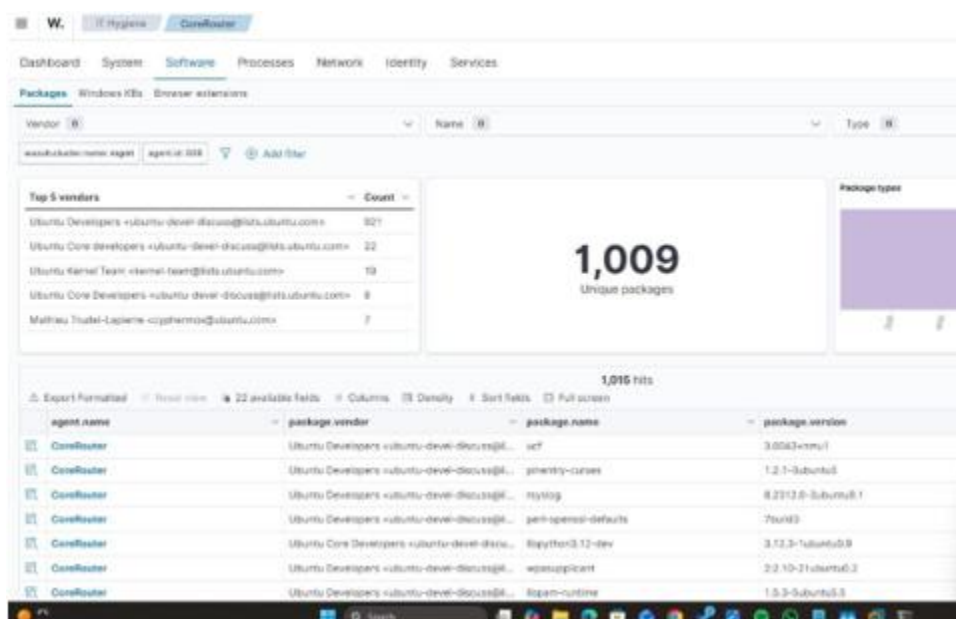
```

1.5 - Passive Discovery Service Running

Control 2 — Inventory of Software Assets

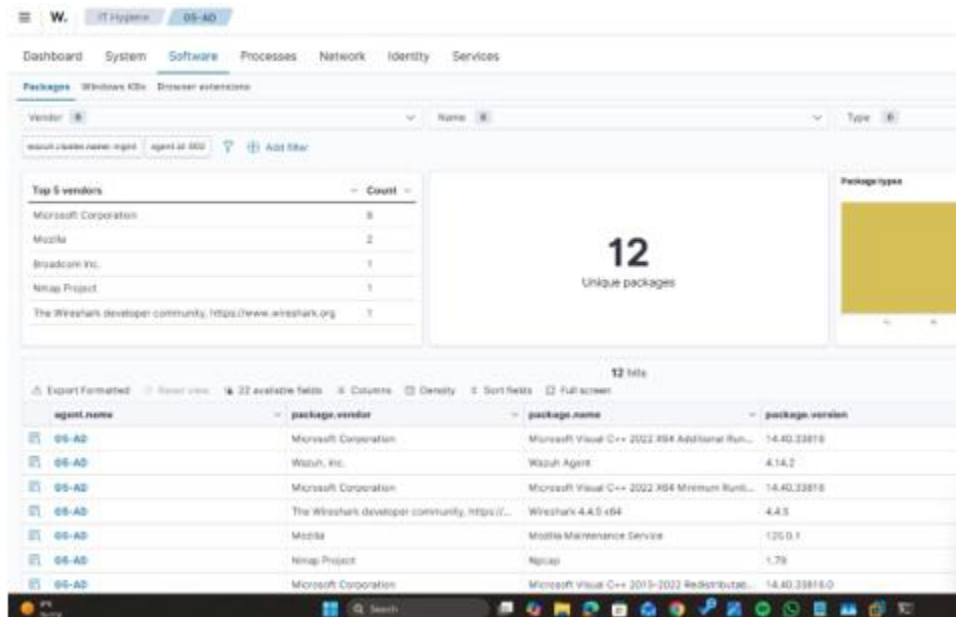
Software asset inventory is maintained through Wazuh's syscollector module, which automatically collects installed package data from all enrolled agents. For Linux agents, dpkg package data is collected; for Windows agents, installed programs from the registry are enumerated. Unauthorized software detection is handled by a custom baseline comparison script deployed as a systemd timer service running hourly on the Wazuh Manager and jumpbox-ssh. Application allowlisting is enforced on jumpbox-ssh through AppArmor with 30 profiles in enforce mode.

Wazuh IT Hygiene software inventory for CoreRouter showing 1,009 unique packages with package name, vendor, version, and type columns, demonstrating comprehensive Linux software inventory collection.



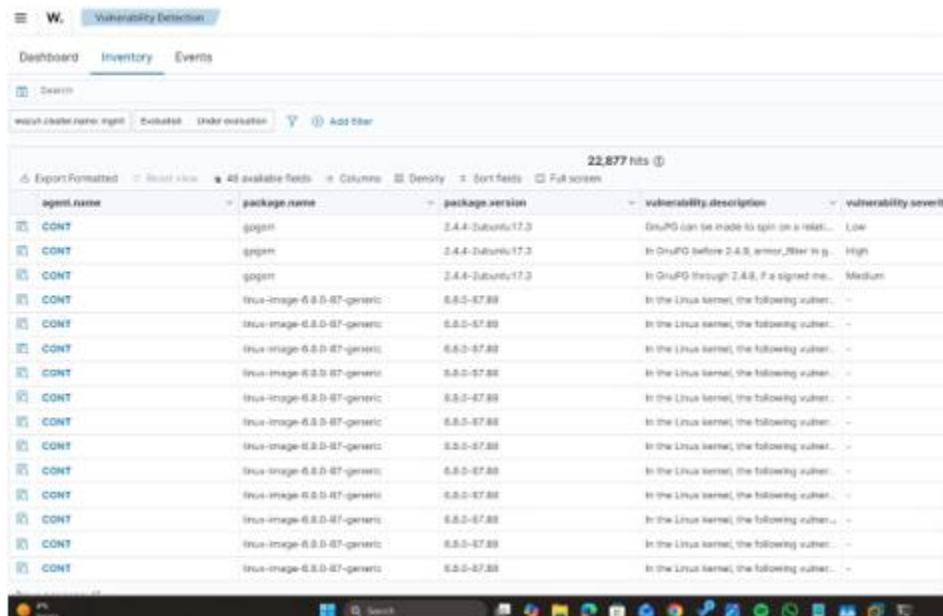
2.1a - Linux Software Inventory CoreRouter

Wazuh IT Hygiene software inventory for G5-AD showing 12 Windows packages including Wazuh Agent, Wireshark, and Nmap, confirming Windows software inventory collection via syscollector.



2.1b - Windows AD Software Inventory

Wazuh Vulnerability Detection inventory showing 22,877 evaluated vulnerability hits across all agents, with CVE IDs, affected package names, versions, and severity ratings.



The screenshot shows the Wazuh Vulnerability Detection inventory interface. At the top, there's a search bar and a filter button. Below the search bar, it says "22,877 hits". The table has the following columns: agent.name, package.name, package.version, vulnerability.description, and vulnerability.severity. The table lists several entries for the agent "CONT", including packages like "gpgm" and "linux-image-6.8.0-87-generic". The vulnerability descriptions are truncated, and the severity ratings are "Low", "High", and "Medium".

agent.name	package.name	package.version	vulnerability.description	vulnerability.severity
CONT	gpgm	2.4.4-2ubuntu17.3	GnuPG can be made to sign on a relat...	Low
CONT	gpgm	2.4.4-2ubuntu17.3	In GnuPG before 2.4.8, error_after is g...	High
CONT	gpgm	2.4.4-2ubuntu17.3	In GnuPG through 2.4.8, if a signed me...	Medium
CONT	linux-image-6.8.0-87-generic	6.8.0-87.88	In the Linux kernel, the following vulne...	-
CONT	linux-image-6.8.0-87-generic	6.8.0-87.88	In the Linux kernel, the following vulne...	-
CONT	linux-image-6.8.0-87-generic	6.8.0-87.88	In the Linux kernel, the following vulne...	-
CONT	linux-image-6.8.0-87-generic	6.8.0-87.88	In the Linux kernel, the following vulne...	-
CONT	linux-image-6.8.0-87-generic	6.8.0-87.88	In the Linux kernel, the following vulne...	-
CONT	linux-image-6.8.0-87-generic	6.8.0-87.88	In the Linux kernel, the following vulne...	-
CONT	linux-image-6.8.0-87-generic	6.8.0-87.88	In the Linux kernel, the following vulne...	-
CONT	linux-image-6.8.0-87-generic	6.8.0-87.88	In the Linux kernel, the following vulne...	-
CONT	linux-image-6.8.0-87-generic	6.8.0-87.88	In the Linux kernel, the following vulne...	-
CONT	linux-image-6.8.0-87-generic	6.8.0-87.88	In the Linux kernel, the following vulne...	-
CONT	linux-image-6.8.0-87-generic	6.8.0-87.88	In the Linux kernel, the following vulne...	-
CONT	linux-image-6.8.0-87-generic	6.8.0-87.88	In the Linux kernel, the following vulne...	-
CONT	linux-image-6.8.0-87-generic	6.8.0-87.88	In the Linux kernel, the following vulne...	-
CONT	linux-image-6.8.0-87-generic	6.8.0-87.88	In the Linux kernel, the following vulne...	-

2.2 - Vulnerability Detection Inventory

Systemd timer status of software-audit.timer on jumpbox-ssh showing the timer active and waiting, confirming hourly automated software audit execution.

```

• software-audit.timer - CIS Control 2.3 - Run Software Audit Hourly
  Loaded: loaded (/etc/systemd/system/software-audit.timer; enabled; preset: enabled)
  Active: active (waiting) since Wed 2026-04-08 11:54:19 EDT; 21s ago
  Trigger: Wed 2026-04-08 12:54:19 EDT; 59min left
  Triggers: • software-audit.service

```

2.3a - Software Audit Timer on Jumpbox

Wazuh Manager journal output showing the software audit service detecting cowsay and libtextcharwidth-perl as unauthorized packages with an [ALERT] flag, confirming the unauthorized software detection mechanism functions correctly.

```

v software-audit.service - CIS Control 2.3 - Unauthorized Software Detection
Loaded: loaded (/etc/systemd/system/software-audit.service; disabled; preset: enabled)
Active: inactive (dead) since Wed 2026-04-08 11:49:58 EDT; 3s ago
Duration: 70ms
TriggeredBy: ● software-audit.timer
Process: 5282 ExecStart=/usr/local/bin/software_baseline_check.sh (code=exited, status=8/SUCCESS)
Main PID: 5282 (code=exited, status=8/SUCCESS)
CPU: 88ms

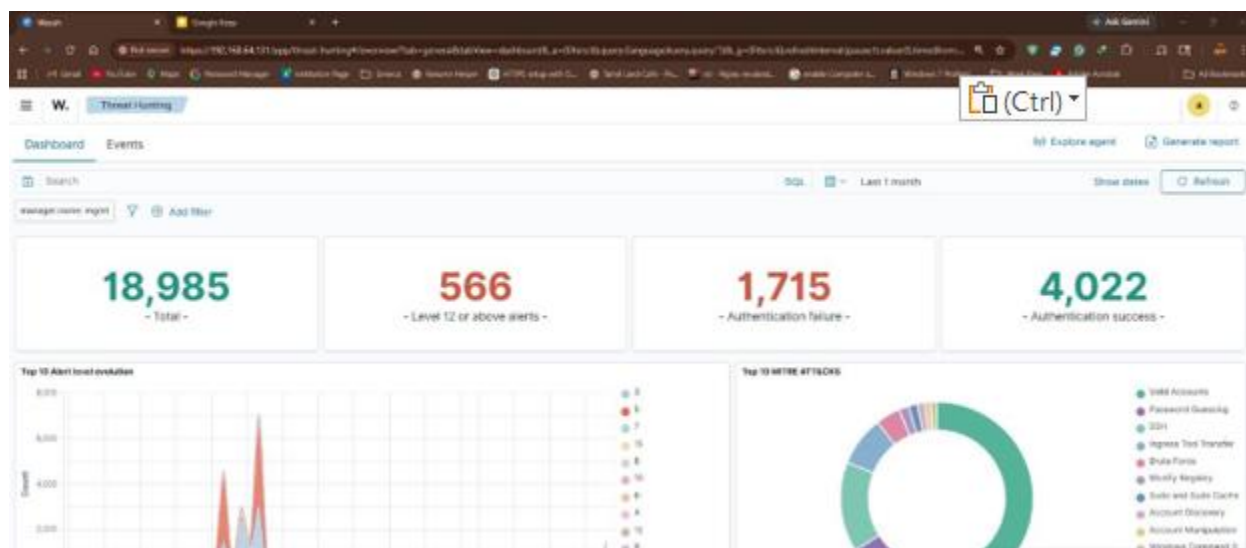
Apr 08 11:49:58 sgmt software-audit[5286]: =====
Apr 08 11:49:58 sgmt software-audit[5288]: Software Audit - 2026-04-08 11:49:58
Apr 08 11:49:58 sgmt software-audit[5290]: =====
Apr 08 11:49:58 sgmt software-audit[5295]: --- Unauthorized Software Check ---
Apr 08 11:49:58 sgmt software-audit[5305]: [ALERT] New unauthorized packages detected:
Apr 08 11:49:58 sgmt software-audit[5305]: cowsay
Apr 08 11:49:58 sgmt software-audit[5305]: libtext-charwidth-perl
Apr 08 11:49:58 sgmt software-audit[5306]: =====
Apr 08 11:49:58 sgmt software-audit[5310]: Audit complete. Log: /var/log/software_audit/software_check_2026-04-08_11:49:58.log
Apr 08 11:49:58 sgmt systemd[1]: software-audit.service: Deactivated successfully.

wazuh-ttthavapalan Wed Apr 08 - 11:38:54 $ cat /var/log/software_audit/cat /var/log/software_audit/software_check_$(ls -t /va
cat: '/var/log/software_audit/software_check_2026-04-08_11:49:58.log': No such file or directory
wazuh-ttthavapalan Wed Apr 08 - 11:38:54 $

```

2.3b - Unauthorized Package Detected

Wazuh Threat Hunting dashboard showing 18,985 total events and top MITRE ATT&CK techniques across all agents managed by the Wazuh Manager.



2.4 - Threat Hunting Dashboard

AppArmor status on jumpbox-ssh showing the module loaded with 126 profiles, 30 in enforce mode including tcpdump, rsyslogd, named, and sssd, implementing application allowlisting per CIS Control 2.5 through 2.7.

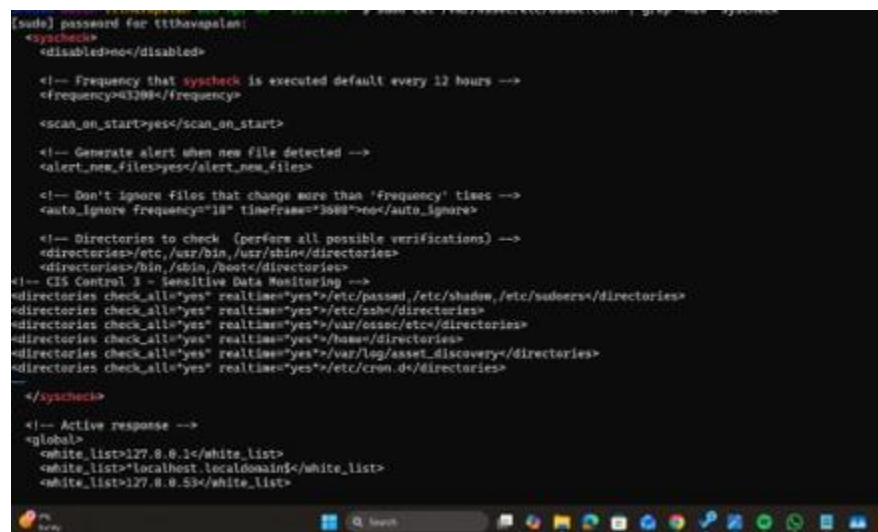
```
apparmor module is loaded.
126 profiles are loaded.
38 profiles are in enforce mode.
/usr/bin/man
/usr/lib/NetworkManager/nm-dhcp-client.action
/usr/lib/NetworkManager/nm-dhcp-helper
/usr/lib/connman/scripts/dhclient-script
/usr/lib/snapd/snap-confine
/usr/lib/snapd/snap-confine/mount-namespace-capture-helper
/(usr/sbin/dhclient
lsb_release
man_filter
man_groff
named
nvidia_modprobe
nvidia_modprobe//kmod
passt
plasmashell
plasmashell//QtWebEngineProcess
rsyslogd
tcpdump
ubuntu_pro_apt_news
ubuntu_pro_esa_cache
ubuntu_pro_esa_cache//apt_methods
ubuntu_pro_esa_cache//apt_methods_gpgv
ubuntu_pro_esa_cache//cloud_id
ubuntu_pro_esa_cache//dpkg
ubuntu_pro_esa_cache//ps
ubuntu_pro_esa_cache//ubuntu_distro_info
ubuntu_pro_esa_cache_systemctl
ubuntu_pro_esa_cache_systemd_detect_virt
unix_chkpwd
unprivileged_users
5 profiles are in complain mode.
/usr/sbin/sss
;
```

2.5 - AppArmor Enforced Profiles

Control 3 — Data Protection

Data protection is implemented through Wazuh File Integrity Monitoring, network segmentation by data sensitivity, encryption of data in transit, and strict file permission controls. FIM is configured with real-time monitoring on sensitive paths including credential files, SSH configuration, Wazuh security configuration, home directories, and cron paths. All inter-agent communications use TLS on port 1514, and remote access is encrypted using OpenVPN with AES-256-GCM.

Wazuh Manager ossec.conf syscheck configuration showing FIM enabled with 12-hour scan frequency, scan_on_start, alert_new_files, and six sensitive path entries with check_all="yes" and realtime="yes" attributes, confirming the data management process.



```
[sudo] password for tithavapalan:
<syscheck>
  <disabled>no</disabled>

  <!-- Frequency that syscheck is executed default every 12 hours -->
  <frequency>43200</frequency>

  <scan_on_start>yes</scan_on_start>

  <!-- Generate alert when new file detected -->
  <alert_new_files>yes</alert_new_files>

  <!-- Don't ignore files that change more than 'frequency' times -->
  <auto_ignore frequency="18" timeframe="3600">no</auto_ignore>

  <!-- Directories to check (perform all possible verifications) -->
  <directories>/bin,/sbin,/boot</directories>

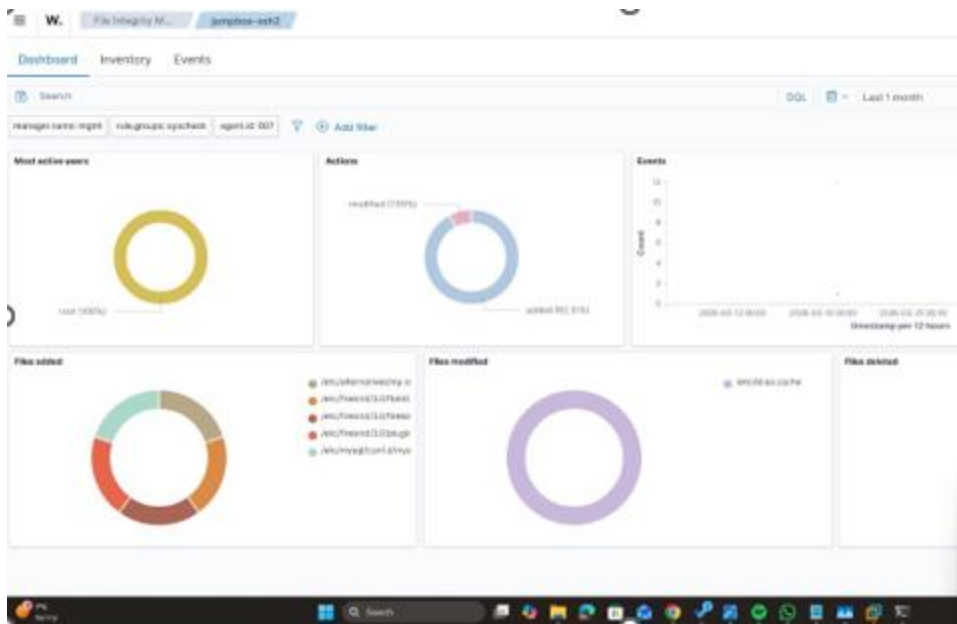
  <!-- CIS Control 3 - Sensitive Data Monitoring -->
  <directories check_all="yes" realtime="yes">/etc/passwd,/etc/shadow,/etc/sudoers</directories>
  <directories check_all="yes" realtime="yes">/etc/ssh</directories>
  <directories check_all="yes" realtime="yes">/var/ossec/etc</directories>
  <directories check_all="yes" realtime="yes">/home</directories>
  <directories check_all="yes" realtime="yes">/var/log/asset_discovery</directories>
  <directories check_all="yes" realtime="yes">/etc/cron.d</directories>

</syscheck>

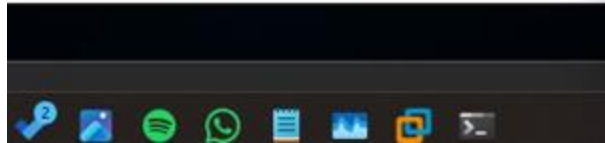
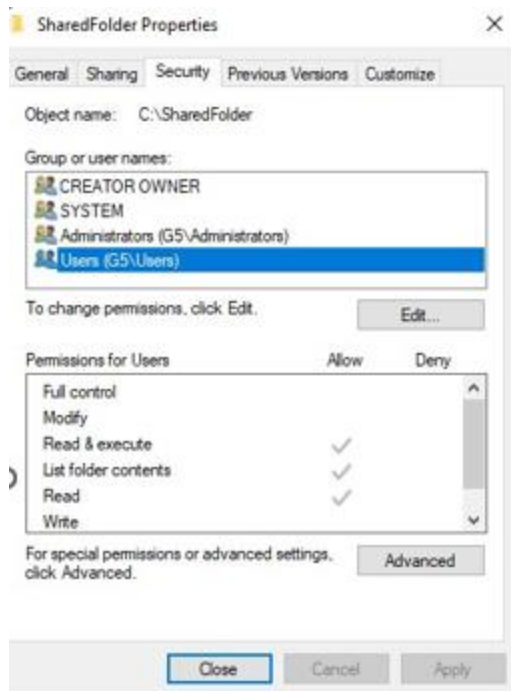
<!-- Active response -->
<global>
  <white_list>127.0.0.1</white_list>
  <white_list>localhost.localdomain</white_list>
  <white_list>127.0.0.53</white_list>
```

3.1 - FIM Configuration in ossec.conf

Wazuh File Integrity Monitoring dashboard for jumpbox-ssh2 showing files added and modified breakdown, confirming active FIM data inventory collection.



3.2a - FIM Dashboard



3.3b - AD Shared Folder ACL

Wazuh Manager /var/ossec/logs/alerts/ directory listing showing alerts.log (1.9MB) and alerts.json (3.0MB) with log rotation configured via logrotate.

```

root@mgmt:~# grep -A5 'logall\|max_output_size\|logs' /var/ossec/etc/ossec.conf
<logall>no</logall>
<logall_json>no</logall_json>
<email_notification>no</email_notification>
<smtp_server>smtp.example.wazuh.com</smtp_server>
<email_from>wazuh@example.wazuh.com</email_from>
<email_to>recipient@example.wazuh.com</email_to>
<email_maxperhour>12</email_maxperhour>

<!-- Choose between "plain", "json", or "plain,json" for the format of internal logs -->
<logging>
  <log_format>plain</log_format>
</logging>

<remote>

  <ignore>/etc/httpd/logs</ignore>
  <ignore>/etc/utmpx</ignore>
  <ignore>/etc/atd/atd.log</ignore>
  <ignore>/etc/cups/certs</ignore>
  <ignore>/etc/dmcc/dmcc.log</ignore>
  <ignore>/etc/svc/volatile</ignore>

  <location>/var/ossec/logs/active-responses.log</location>
</localfile>

<localfile>
  <log_format>syslog</log_format>
  <location>/var/log/dmcc.log</location>
root@mgmt:~# cat /etc/logrotate.d/wazuh 2>/dev/null || ls /var/ossec/logs/
active-responses.log alerts api api.log archives cluster cluster.log firewall integrations.log ossec.log
root@mgmt:~# ls -lh /var/ossec/logs/alerts/
total 6.0M
drwxr-x--- 5 wazuh wazuh 4.8K Apr  8 18:23 2026
-rw-r----- 2 wazuh wazuh 3.0M Apr  8 15:57 alerts.json
-rw-r----- 2 wazuh wazuh 1.9M Apr  8 15:57 alerts.log
root@mgmt:~#

```

3.4 - Data Retention Logs

OpenVPN server configuration showing cipher AES-256-GCM, auth SHA256, tls-auth ta.key 0, and tls-verify script, implementing strong encryption for all data in transit over the remote access channel.

```

#auth-user-pass
tls-auth ta.key 0
cipher AES-256-GCM
auth SHA256
tls-verify /etc/openvpn/server/check_intermediate.sh

```

3.10a - OpenVPN Encryption Config

Wazuh Manager ossec.conf showing agent communication configured on TCP port 1514, confirming all Wazuh agent-to-manager telemetry is transmitted over encrypted TCP channels.

```

root@mgmt:~# grep -E 'protocol|port' /var/ossec/etc/ossec.conf
  <port>1514</port>
  <protocol>tcp</protocol>
  <check_ports>yes</check_ports>
  <ports all="yes">yes</ports>
  <alias>netstat listening ports</alias>
  <port>1515</port>
  <port>1516</port>

```

3.10b - Wazuh TLS Port Config

ls -la /var/ossec/etc/ output showing Wazuh security files with strict permissions: client.keys (rwr----- root:wazuh), sslmanager.cert and sslmanager.key (rw-r----- root:root), protecting key material at rest.

```

root@mgmt:~# ls -la /var/ossec/etc/
total 76
drwxrwx--- 7 wazuh wazuh 4096 Apr  8 12:00 .
drwxr-x--- 20 root  wazuh 4096 Feb  5 15:30 ..
-rw-r----- 1 root  wazuh  572 Apr  8 12:00 client.keys
drwxrwx--- 2 root  wazuh 4096 Feb  5 15:30 decoders
-rw-r----- 1 root  wazuh 14961 Jan  8 14:06 internal_options.conf
drwxrwx--- 4 root  wazuh 4096 Feb  5 15:31 lists
-rw-r----- 1 root  wazuh  320 Jan  8 14:06 local_internal_options.conf
-rw-r----- 1 root  wazuh 3494 Apr 22  2025 localtime
-rw-rw---- 1 root  wazuh 9889 Apr  8 12:00 ossec.conf
drwxrwx--- 2 root  wazuh 4096 Feb  5 15:30 rootcheck
drwxrwx--- 2 root  wazuh 4096 Mar 19 20:19 rules
drwxrwx--- 4 root  wazuh 4096 Mar 20 00:41 shared
-rw-r----- 1 root  root  1164 Feb  5 15:30 sslmanager.cert
-rw-r----- 1 root  root  1704 Feb  5 15:30 sslmanager.key
root@mgmt:~# stat /var/ossec/etc/client.keys
  File: /var/ossec/etc/client.keys
  Size: 572          Blocks: 8          IO Block: 4096   regular file
Device: 252,0    Inode: 667582    Links: 1
Access: (0640/-rw-r-----)  Uid: (   0/   root)   Gid: ( 107/   wazuh)
Access: 2026-04-08 12:00:54.790281215 -0400
Modify: 2026-04-08 12:00:31.940946019 -0400
Change: 2026-04-08 12:00:31.940946019 -0400
 Birth: 2026-04-08 12:00:31.939946005 -0400
root@mgmt:~#

```

3.11 - Wazuh Config File Permissions

Core router ip -br a output showing all network interfaces UP with distinct subnet assignments across seven VLANs, demonstrating data segmentation by sensitivity.

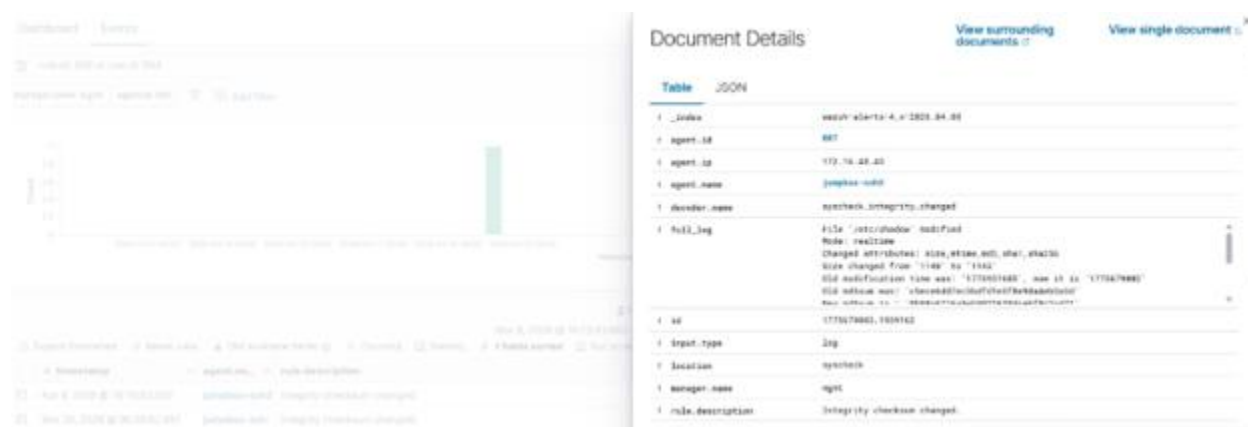
```

lo UNKNOWN 127.0.0.1/8 ::1/128
ens33 UP 172.16.33.1/26 fe80::20c:29ff:fe64:
ens37 DOWN
ens38 UP 172.16.23.1/28 fe80::20c:29ff:fe64:
ens39 UP 172.16.48.49/29 fe80::20c:29ff:fe64:
ens40 UP fe80::20c:29ff:fe64:3613/64
ens41 UP 172.16.48.41/29 fe80::20c:29ff:fe64:
ens42 UP 172.16.23.17/28 fe80::20c:29ff:fe64:
ens43 UP 172.16.23.33/28 fe80::20c:29ff:fe64:
ens44 UP 192.168.64.136/24 metric 100 fe80::
ens40.33@ens40 UP 172.16.48.25/29 fe80::20c:29ff:fe64:
ens40.31@ens40 UP 172.16.48.9/29 fe80::20c:29ff:fe64:
ens40.32@ens40 UP 172.16.48.17/29 fe80::20c:29ff:fe64:
ens40.30@ens40 UP 172.16.48.1/29 fe80::20c:29ff:fe64:
ens40.34@ens40 UP 172.16.48.33/29 fe80::20c:29ff:fe64:

```

3.12 - Router VLAN Segmentation

Wazuh FIM Events filtered by rule.id: 550 or rule.id: 553 for jumpbox-ssh2 showing integrity checksum change events, confirming FIM functions as a real-time data loss prevention mechanism.



3.13 - FIM DLP Alert Rules 550 553

Wazuh alert document detail for jumpbox-ssh2 showing /etc/shadow modified in realtime mode with changed size, mtime, md5, sha1, and sha256 attributes, with GDPR and HIPAA compliance tags confirming sensitive data access logging.

Document Details documents

Table JSON

_index	wazuh-alerts-4.x-2026.04.08
agent.id	007
agent.ip	172.16.48.43
agent.name	jumpbox-ssh2
decoder.name	syscheck_integrity_changed
full_log	File '/etc/shadow' modified Mode: realtime Changed attributes: size, mtime, md5, sha1, sha256 Size changed from '1140' to '1143' Old modification time was: '1773951685', now it is '1775679002' Old md5sum was: 'c5ececdd7ec5bdfdie5f8e9da4eb3a3d' New md5sum is: '0b08e6716a5ah5837638dcabf8e7c471'
id	1775679003.1939162
input.type	log
location	syscheck
manager.name	mgmt
rule.description	Integrity checksum changed.
rule.firedtimes	1

3.14a - FIM Shadow File Alert

Extended FIM alert detail showing complete before/after cryptographic hash comparison for the modified credential file, confirming precise integrity verification.

t rule.tsc	PI1.4, PI1.5, CC6.1, CC6.8, CC7.2, CC7.3
t syscheck.changed_attributes	size, mtime, md5, sha1, sha256
t syscheck.event	modified
t syscheck.gid_after	42
t syscheck.gname_after	shadow
t syscheck.inode_after	395106
t syscheck.md5_after	9b98c6216a5eb5032638dcebf8c2cd71
t syscheck.md5_before	c5ece6dd7ec5bdfd1e5f8e9da4eb3a3d
t syscheck.mode	realtime
syscheck.mtime_after	Apr 8, 2026 @ 12:10:02.000
syscheck.mtime_before	Mar 19, 2026 @ 12:21:25.000
t syscheck.path	/etc/shadow
t syscheck.perm_after	rw-r-----
t syscheck.sha1_after	abe818373ca8f39108ee68f8d3a92dc32d7c4ee5
t syscheck.sha1_before	9a46a99092dd7e742d06ceff228611bfc61aca75
t syscheck.sha256_after	8eb57c0c0ca97e0367bff670f394d95921e97fd4c242fa5b9c302e8b22c4fa3f
t syscheck.sha256_before	0d521c245a85953a054c4e903f1f0f002ae97e8aed32c0634d3a45e6828b6d22

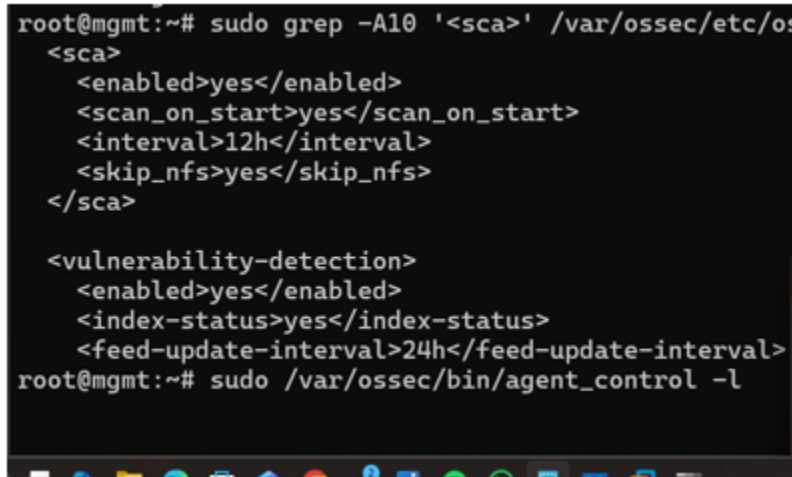
3.14b - FIM Hash Comparison Detail

Control 4 — Secure Configuration of Enterprise Assets and Software

Secure configuration is enforced through Wazuh's Security Configuration Assessment module, which continuously evaluates all agents against CIS benchmarks. The CIS Microsoft Windows Server 2019 Benchmark v2.0.0 is applied to G5-AD (score: 24%, 84 passed, 263 failed) and the CIS Ubuntu Linux 24.04 LTS Benchmark v1.0.0 is applied to Linux agents (CoreRouter: 47%,

116 passed, 128 failed). Host-level firewalls are deployed as systemd services on both the Wazuh Manager and jumpbox-ssh with default DROP policies. SSH hardening and default account controls are applied across all Linux hosts.

Wazuh Manager ossec.conf SCA configuration showing <enabled>yes</enabled>, <scan_on_start>yes</scan_on_start>, and <interval>12h</interval>, confirming automated CIS benchmark scanning is enabled across all agents.

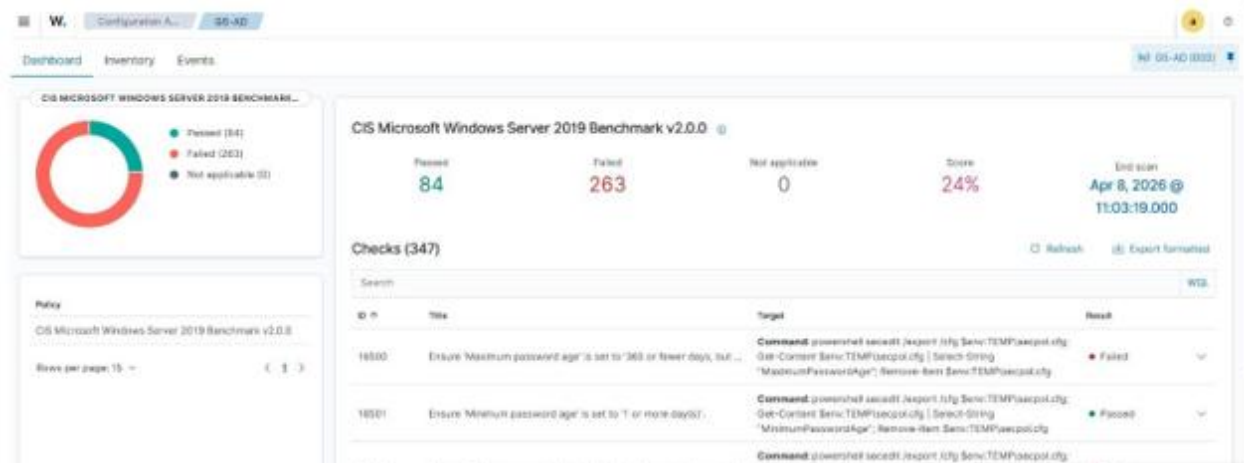
A terminal window showing the command 'sudo grep -A10 '<sca>' /var/ossec/etc/ossec.conf' and its output. The output displays the SCA configuration section, which includes settings for enabling SCA, setting the scan interval to 12 hours, and enabling vulnerability detection. Below the SCA section, the vulnerability detection section is also shown, with settings for enabling it and setting the feed update interval to 24 hours. The terminal prompt is 'root@mgmt:~#'.

```
root@mgmt:~# sudo grep -A10 '<sca>' /var/ossec/etc/ossec.conf
<sca>
  <enabled>yes</enabled>
  <scan_on_start>yes</scan_on_start>
  <interval>12h</interval>
  <skip_nfs>yes</skip_nfs>
</sca>

<vulnerability-detection>
  <enabled>yes</enabled>
  <index-status>yes</index-status>
  <feed-update-interval>24h</feed-update-interval>
root@mgmt:~# sudo /var/ossec/bin/agent_control -l
```

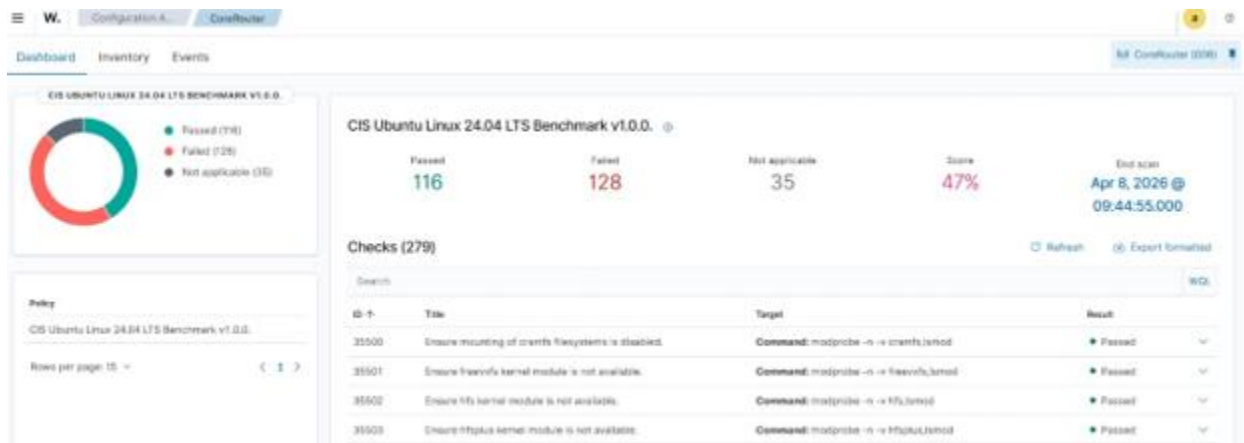
4.1a - SCA Config Enabled

Wazuh Configuration Assessment dashboard for G5-AD showing CIS Windows Server 2019 Benchmark v2.0.0 with 84 passed, 263 failed, score 24%, with individual check results and remediation guidance visible.



4.1b - CIS SCA Dashboard AD

Wazuh Configuration Assessment dashboard for CoreRouter showing CIS Ubuntu Linux 24.04 LTS Benchmark v1.0.0 with 116 passed, 128 failed, score 47%.



4.1c - CIS SCA Dashboard CoreRouter

Core router iptables FORWARD and OUTPUT chain rules showing VLAN-specific subnet access controls, DNS forwarding rules restricted to 172.16.33.0/26, and HTTP/HTTPS access controls for container subnets.

```

0 0 ACCEPT 6 -- * * 172.16.48.0/29 172.16.48.16/29 tcp dpt:80 ctstate NEW,ESTA
BLISHED
0 0 ACCEPT 6 -- * * 172.16.48.0/29 172.16.48.32/29 tcp dpt:80 ctstate NEW,ESTA
BLISHED
0 0 ACCEPT 6 -- * * 0.0.0.0/0 172.16.48.24/29 match-set INTERNAL_SUBNETS
src tcp dpt:445 ctstate NEW,ESTABLISHED
0 0 ACCEPT 17 -- * * ens37 172.16.33.0/26 0.0.0.0/0 udp dpt:53 ctstate NEW,ESTA
BLISHED
0 0 ACCEPT 17 -- * * 172.16.2.0/27 172.16.33.0/26 udp dpt:53 STRING match "I
0267350865787465726e616c001" ALGO name bm
0 0 ACCEPT 6 -- * * 172.16.2.0/27 172.16.33.0/26 tcp dpt:53 STRING match "I
0267350865787465726e616c001" ALGO name bm
0 0 ACCEPT 6 -- * * ens37 0.0.0.0/0 0.0.0.0/0 match-set INTERNET_ALLOWED_
SUBNETS src multiport dports 80,443 ctstate NEW,ESTABLISHED
0 0 ACCEPT 17 -- * * ens37 0.0.0.0/0 0.0.0.0/0 match-set INTERNET_ALLOWED_
SUBNETS src udp dpt:53 ctstate NEW,ESTABLISHED
0 0 ACCEPT 17 -- * * 172.16.2.0/27 172.16.48.48/29 udp dpt:1194 ctstate NEW,ES
TABLISHED
25 1780 LOG 0 -- * * 0.0.0.0/0 0.0.0.0/0 LOG flags 0 level 4 prefix
"FORWARD-DROP: "

Chain OUTPUT (policy DROP 587 packets, 816K bytes)
pkts bytes target prot opt in out source destination ctstate
2 690 ACCEPT 0 -- * * 0.0.0.0/0 0.0.0.0/0 0.0.0.0/0 ctstate RELATED,ESTABLISHED
6 450 ACCEPT 0 -- * * lo 0.0.0.0/0 0.0.0.0/0
0 0 ACCEPT 6 -- * * 0.0.0.0/0 172.16.48.0/29 tcp dpt:443
0 0 ACCEPT 6 -- * * 0.0.0.0/0 172.16.48.0/29 tcp dpt:80
0 0 ACCEPT 6 -- * * 172.16.48.0/29 0.0.0.0/0 tcp spt:443 flags:0x12/0x12
0 0 ACCEPT 6 -- * * 172.16.48.0/29 0.0.0.0/0 tcp spt:80 flags:0x12/0x12
0 0 ACCEPT 80 -- * * ens37 0.0.0.0/0 0.0.0.0/0

```

4.2a - Core Router IPTables Rules

jumpbox-ssh sshd_config output showing PermitRootLogin prohibit-password, confirming SSH hardening prevents direct root login via password.

```

#PermitRootLogin prohibit-password
#MaxAuthTries 6
PasswordAuthentication yes
## PasswordAuthentication. Depending on your PAM configuration,
# the setting of "PermitRootLogin prohibit-password".
# PAM authentication, then enable this but set PasswordAuthentication

```

4.2b - SSH Server Hardening

Wazuh Manager iptables -L -n -v --line-numbers output showing INPUT chain with DROP default policy, rules permitting only required ports (22, 1514, 1515, 1516, 55000, 443), with LOG rule for dropped packets prefixed [CIS-4.4-DROP].

```

root@mgmt:~# sudo iptables -L -n -v --line-numbers
Chain INPUT (policy DROP 5 packets, 308 bytes)
num  pkts bytes target    prot opt in     out     source               destination
1      282 27645 ACCEPT    0     --  lo     *       0.0.0.0/0            0.0.0.0/0
2      216 16740 ACCEPT    0     --  *      *       0.0.0.0/0            0.0.0.0/0          ctstate RELATED,
ESTABLISHED
3          0      0 ACCEPT    6     --  *      *       0.0.0.0/0            0.0.0.0/0          tcp dpt:22
4          0      0 ACCEPT    6     --  *      *       0.0.0.0/0            0.0.0.0/0          tcp dpt:1514
5          0      0 ACCEPT    17    --  *      *       0.0.0.0/0            0.0.0.0/0          udp dpt:1514
6          0      0 ACCEPT    6     --  *      *       0.0.0.0/0            0.0.0.0/0          tcp dpt:1515
7          0      0 ACCEPT    6     --  *      *       0.0.0.0/0            0.0.0.0/0          tcp dpt:1516
8          0      0 ACCEPT    6     --  *      *       0.0.0.0/0            0.0.0.0/0          tcp dpt:55000
9          0      0 ACCEPT    6     --  *      *       0.0.0.0/0            0.0.0.0/0          tcp dpt:443
10         0      0 ACCEPT    1     --  *      *       0.0.0.0/0            0.0.0.0/0          icmp type 8
11         0      0 LOG       0     --  *      *       0.0.0.0/0            0.0.0.0/0          LOG flags 0 leve
l 4 prefix "[CIS-4.4-DROP] "

Chain FORWARD (policy DROP 0 packets, 0 bytes)
num  pkts bytes target    prot opt in     out     source               destination

```

4.4a - Wazuh Manager Firewall Rules

jumpbox-ssh jumpbox-firewall.service systemd status showing active, alongside iptables output confirming INPUT DROP default policy with rules permitting only SSH, Wazuh agent port, and ICMP.

```

• jumpbox-firewall.service - CIS Control 4.4 - Jumpbox-ssh Host Firewall
   Loaded: loaded (/etc/systemd/system/jumpbox-firewall.service; enabled; preset: enabled)
   Active: active (exited) since Wed 2025-04-08 16:36:58 EDT; 18s ago
   Process: 30657 ExecStart=/usr/local/bin/jumpbox_firewall.sh (code=exited, status=0/SUCCESS)
   Main PID: 30657 (code=exited, status=0/SUCCESS)
   CPU: 62ms

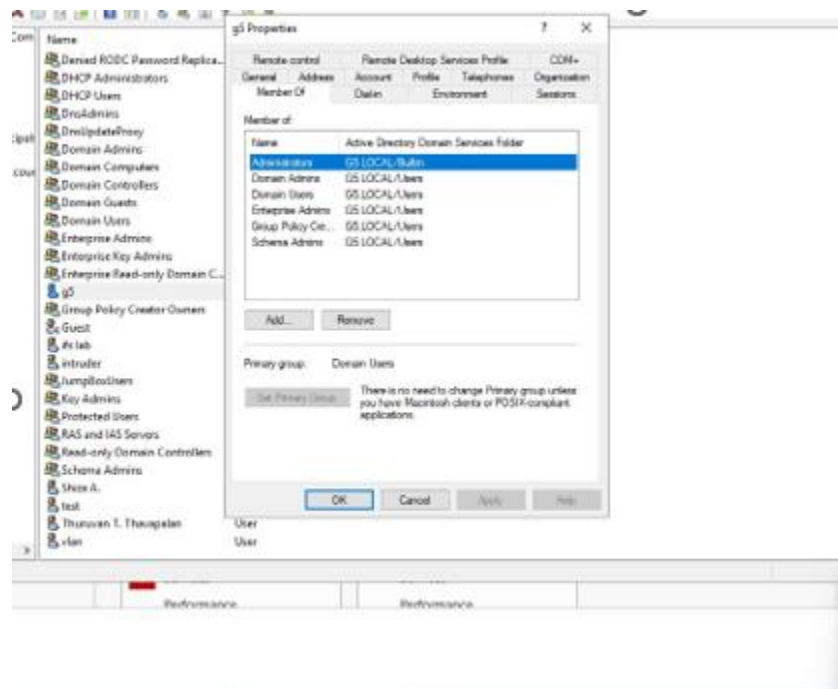
Apr 08 16:36:58 jumpbox-ssh2 jumpbox-firewall[30672]: 3      0      0 ACCEPT    5      -- *      *      0.0.0.0/0
Apr 08 16:36:58 jumpbox-ssh2 jumpbox-firewall[30672]: 4      0      0 ACCEPT    6      -- *      *      0.0.0.0/0
Apr 08 16:36:58 jumpbox-ssh2 jumpbox-firewall[30672]: 5      0      0 ACCEPT   17      -- *      *      0.0.0.0/0
Apr 08 16:36:58 jumpbox-ssh2 jumpbox-firewall[30672]: 6      0      0 ACCEPT    1      -- *      *      0.0.0.0/0
Apr 08 16:36:58 jumpbox-ssh2 jumpbox-firewall[30672]: 7      0      0 LOG        0      -- *      *      0.0.0.0/0
Apr 08 16:36:58 jumpbox-ssh2 jumpbox-firewall[30672]: Chain FORWARD (policy DROP 0 packets, 0 bytes)
Apr 08 16:36:58 jumpbox-ssh2 jumpbox-firewall[30672]: num  pkts bytes target    prot opt in     out     source
Apr 08 16:36:58 jumpbox-ssh2 jumpbox-firewall[30672]: Chain OUTPUT (policy ACCEPT 1 packets, 226 bytes)
Apr 08 16:36:58 jumpbox-ssh2 jumpbox-firewall[30672]: num  pkts bytes target    prot opt in     out     source
Apr 08 16:36:58 jumpbox-ssh2 systemd[1]: Finished jumpbox-firewall.service - CIS Control 4.4 - jumpbox-ssh Host Firewall

ttthavapalan@jumpbox-ssh2:~$ sudo iptables -L -n -v --line-numbers
Chain INPUT (policy DROP 2 packets, 124 bytes)
num  pkts bytes target    prot opt in     out     source            destination
1      36 3426 ACCEPT    0      --  lo      *          0.0.0.0/0         0.0.0.0/0
2     118 20674 ACCEPT    0      -- *        *          0.0.0.0/0         0.0.0.0/0          ctstate RELATED,ESTABLISHED
3        0      0 ACCEPT    6      -- *        *          0.0.0.0/0         0.0.0.0/0          tcp dpt:22
4        0      0 ACCEPT    6      -- *        *          0.0.0.0/0         0.0.0.0/0          tcp dpt:1514
5        0      0 ACCEPT   17      -- *        *          0.0.0.0/0         0.0.0.0/0          udp dpt:1514
6        0      0 ACCEPT    1      -- *        *          0.0.0.0/0         0.0.0.0/0          icmp type 8
7         1    72 LOG        0      -- *        *          0.0.0.0/0         0.0.0.0/0          LOG flags 0 level 4 priority 0
efix "[CIS-4.4-DROP]"

```

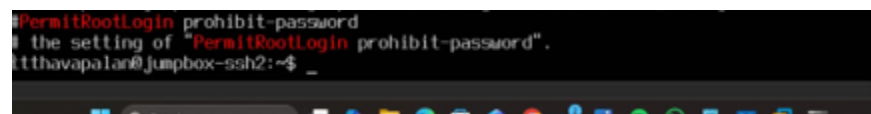
4.4b - Jumpbox Firewall Service and Rules

Active Directory Users and Computers showing disabled Guest and intruder accounts, confirming default account management per CIS Control 4.7.



4.7a - AD Admin Account Configuration

Jumpbox-ssh grep PermitRootLogin /etc/ssh/sshd_config showing PermitRootLogin prohibitpassword, preventing root login via password authentication.



4.7b - SSH No Root Login

jumpbox-ssh system account listing showing all service accounts (UIDs 0 through 111) with /usr/sbin/nologin or /bin/false shells, confirming no unexpected interactive system accounts exist.

```

root 0 /bin/bash
daemon 1 /usr/sbin/nologin
bin 2 /usr/sbin/nologin
sys 3 /usr/sbin/nologin
sync 4 /bin/sync
games 5 /usr/sbin/nologin
man 6 /usr/sbin/nologin
lp 7 /usr/sbin/nologin
mail 8 /usr/sbin/nologin
news 9 /usr/sbin/nologin
uucp 10 /usr/sbin/nologin
proxy 13 /usr/sbin/nologin
www-data 33 /usr/sbin/nologin
backup 34 /usr/sbin/nologin
list 38 /usr/sbin/nologin
irc 39 /usr/sbin/nologin
_apt 42 /usr/sbin/nologin
systemd-network 998 /usr/sbin/nologin
systemd-timesync 997 /usr/sbin/nologin
dhcpd 100 /bin/false
messagebus 101 /usr/sbin/nologin
systemd-resolve 992 /usr/sbin/nologin
pollinate 102 /bin/false
polkitd 991 /usr/sbin/nologin
syslog 103 /usr/sbin/nologin
uidd 104 /usr/sbin/nologin
tcpdump 105 /usr/sbin/nologin
tss 106 /bin/false
landscape 107 /usr/sbin/nologin
fuupd-refresh 989 /usr/sbin/nologin
usbmux 108 /usr/sbin/nologin
bind 109 /usr/sbin/nologin
sshd 110 /usr/sbin/nologin
dnsmasq 999 /usr/sbin/nologin
cockpit-ws 111 /usr/sbin/nologin
:

```

4.7c - System Accounts nologin

jumpbox-ssh ss -tlnp output showing only port 22 (sshd) and port 9090 (systemd internal), confirming no unnecessary network services are exposed.

```

tthavapalan@jumpbox-ssh2:~$ ss -tlnp
State Recv-Q Send-Q Local Address:Port Peer Address:Port Process
LISTEN 0      4096      0.0.0.0:22      0.0.0.0:*      users:(("sshd",pid=1292,fd=
LISTEN 0      4096    127.0.0.54:53      0.0.0.0:*      users:(("systemd-resolve",p
LISTEN 0      4096    127.0.0.53%lo:53      0.0.0.0:*      users:(("systemd-resolve",p
LISTEN 0      4096      *:9090          *:9090          users:(("systemd",pid=1,fd=
LISTEN 0      4096      [::]:22        [::]:22        users:(("sshd",pid=1292,fd=
tthavapalan@jumpbox-ssh2:~$

```

4.8a - Only Expected Ports Listening

jumpbox-ssh systemctl list-units --type=service --state=running showing only essential services: sssd, wazuh-agent, ssh, suricata, rsyslog, with no unnecessary services present.

```
UNIT                                LOAD    ACTIVE SUB    DESCRIPTION
cron.service                       loaded active running Regular background program proce
dbus.service                       loaded active running D-Bus System Message Bus
fwupd.service                      loaded active running Firmware update daemon
getty@tty1.service                 loaded active running Getty on tty1
ModemManager.service              loaded active running Modem Manager
multipathd.service                loaded active running Device-Mapper Multipath Device
networkd-dispatcher.service        loaded active running Dispatcher daemon for systemd-n
NetworkManager.service            loaded active running Network Manager
oddjobd.service                   loaded active running privileged operations for unpri
open-vm-tools.service              loaded active running Service for virtual machines ho
openvpn-server@server.service      loaded active running OpenVPN service for server
polkit.service                    loaded active running Authorization Manager
rsyslog.service                   loaded active running System Logging Service
ssh.service                       loaded active running OpenBSD Secure Shell server
sssd.service                      loaded active running System Security Services Daemon
suricata.service                  loaded active running Suricata IDS/IDP daemon
systemd-journald.service           loaded active running Journal Service
systemd-logind.service             loaded active running User Login Management
systemd-networkd.service           loaded active running Network Configuration
systemd-resolved.service           loaded active running Network Name Resolution
systemd-timesyncd.service          loaded active running Network Time Synchronization
systemd-udevd.service              loaded active running Rule-based Manager for Device E
udisks2.service                   loaded active running Disk Manager
unattended-upgrades.service         loaded active running Unattended Upgrades Shutdown
upower.service                    loaded active running Daemon for power management
user@1000.service                 loaded active running User Manager for UID 1000
user@1219001110.service            loaded active running User Manager for UID 1219001110
vgauth.service                    loaded active running Authentication service for virt
wazuh-agent.service               loaded active running Wazuh agent
wpa_supplicant.service             loaded active running WPA supplicant

Legend: LOAD → Reflects whether the unit definition was properly loaded.
          ACTIVE → The high-level unit activation state, i.e. generalization of SUB.
          SUB → The low-level unit activation state, values depend on unit type.
lines 1-35
```

4.8b - Minimal Services Running

jumpbox-ssh resolved.conf showing DNS=172.16.33.2 (internal AD DNS) as primary with FallbackDNS=1.1.1.1 8.8.8.8, and search domain g5.local, confirming trusted internal DNS configuration.

```
## This is /run/systemd/resolve/stub-resolv.conf managed by man:systemd-resolved(8).
## Do not edit.
##
## This file might be symlinked as /etc/resolv.conf. If you're looking at
## /etc/resolv.conf and seeing this text, you have followed the symlink.
##
## This is a dynamic resolv.conf file for connecting local clients to the
## internal DNS stub resolver of systemd-resolved. This file lists all
## configured search domains.
##
## Run "resolvectl status" to see details about the uplink DNS servers
## currently in use.
##
## Third party programs should typically not access this file directly, but only
## through the symlink at /etc/resolv.conf. To manage man:resolv.conf(5) in a
## different way, replace this symlink by a static file or a different symlink.
##
## See man:systemd-resolved.service(8) for details about the supported modes of
## operation for /etc/resolv.conf.

nameserver 127.0.0.53
options edns0 trust-ad
search g5.local localdomain
ttthavapalan@jumpbox-ssh2:~$ cat /etc/systemd/resolved.conf | grep DNS
# Some examples of DNS servers which may be used for DNS= and FallbackDNS=:
DNS= 172.16.33.2
FallbackDNS=1.1.1.1 8.8.8.8
#DNSSEC=no
#DNSOverTLS=no
#MulticastDNS=no
#DNSStubListener=yes
#DNSStubListenerExtra=
```

4.9 - Trusted DNS Configuration

Control 5 — Account Management

Account management is centralized through Active Directory on GS-AD. All domain-joined machines authenticate against G5.LOCAL via Kerberos and SSSD. A custom Wazuh detection rule fires on unauthorized local account creation events (EventID 4720). AD password policy enforces complexity, history, and age requirements. Administrative privilege is strictly limited to the g5 domain account, with the Linux sudo group containing only ttthavapalan on jumpbox-ssh.

Wazuh IT Hygiene user inventory for G5-AD showing all 15 accounts including krbtgt, Administrator, Guest, and domain users with group memberships, confirming comprehensive account inventory.

agent name	user name	user groups	user shell
G5-AD	LOCAL SERVICE	-	C:\Windows\system32\cmd.exe
G5-AD	NETWORK SERVICE	-	C:\Windows\system32\cmd.exe
G5-AD	SYSTEM	-	C:\Windows\system32\cmd.exe
G5-AD	krbtgt	Domain RODC Password Replication Group, M...	C:\Windows\system32\cmd.exe
G5-AD	Administrator	Users	C:\Windows\system32\cmd.exe
G5-AD	Guest	Guests	C:\Windows\system32\cmd.exe
G5-AD	kysan	Users	C:\Windows\system32\cmd.exe
G5-AD	flake	Users	C:\Windows\system32\cmd.exe
G5-AD	intruder	Administrators, Users	C:\Windows\system32\cmd.exe
G5-AD	test	Users	C:\Windows\system32\cmd.exe
G5-AD	thuytran	Users	C:\Windows\system32\cmd.exe
G5-AD	vlah	Users	C:\Windows\system32\cmd.exe
G5-AD	ofinaco	Users	C:\Windows\system32\cmd.exe
G5-AD	spita	Users	C:\Windows\system32\cmd.exe
G5-AD	g5	Domain RODC Password Replication Group, AD...	C:\Windows\system32\cmd.exe

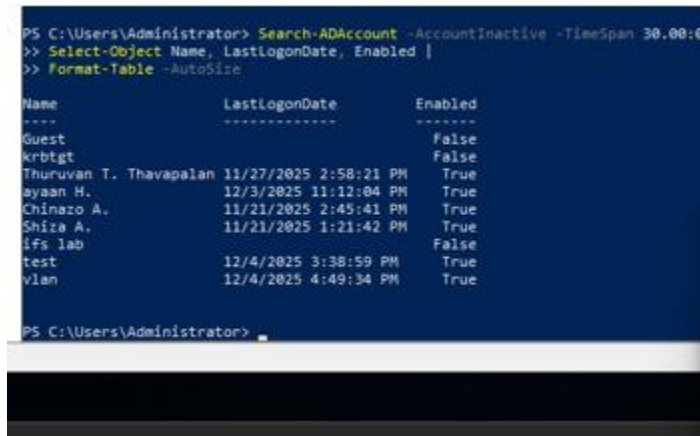
5.1 - User Account Inventory AD

Active Directory Default Domain Password Policy showing 24 password history, 42-day maximum age, 1-day minimum age, 7-character minimum length, complexity enabled, reversible encryption disabled.

Policy	Policy Setting
Enforce password history	24 passwords remembered
Maximum password age	42 days
Minimum password age	1 days
Minimum password length	7 characters
Minimum password length audit	Not Defined
Password must meet complexity requirements	Enabled
Store passwords using reversible encryption	Disabled

5.2 - AD Password Policy

PowerShell Search-ADAccount -AccountInactive -TimeSpan 30 output showing Guest and krbtgt properly disabled, confirming dormant account controls are in place.



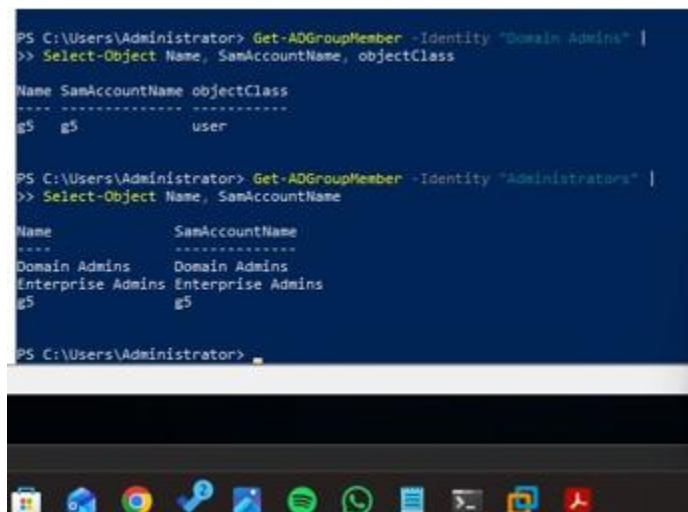
```
PS C:\Users\Administrator> Search-ADAccount -AccountInactive -TimeSpan 30.00:00:00
>> Select-Object Name, LastLogonDate, Enabled |
>> Format-Table -AutoSize
```

Name	LastLogonDate	Enabled
Guest		False
krbtgt		False
Thuruvan T. Thavapalan	11/27/2025 2:58:21 PM	True
ayaan H.	12/3/2025 11:12:04 PM	True
Chinazo A.	11/21/2025 2:45:41 PM	True
Shiza A.	11/21/2025 1:21:42 PM	True
ifs lab		False
test	12/4/2025 3:38:59 PM	True
vlan	12/4/2025 4:49:34 PM	True

```
PS C:\Users\Administrator>
```

5.3 - Dormant Account Check

PowerShell Get-ADGroupMember "Domain Admins" output showing only g5 as a member, confirming minimal and controlled administrative group membership.



```
PS C:\Users\Administrator> Get-ADGroupMember -Identity "Domain Admins" |
>> Select-Object Name, SamAccountName, objectClass
```

Name	SamAccountName	objectClass
g5	g5	user

```
PS C:\Users\Administrator> Get-ADGroupMember -Identity "Administrators" |
>> Select-Object Name, SamAccountName
```

Name	SamAccountName
Domain Admins	Domain Admins
Enterprise Admins	Enterprise Admins
g5	g5

```
PS C:\Users\Administrator>
```

5.4a - Domain Admins Membership

jumpbox-ssh getent group sudo output showing sudo:x:27:ttthavapalan, confirming only one authorized user has sudo privileges on the Linux jumpbox.

```
etc/sudoers.d/README:## The default /etc/sudoers file created on installation of the
etc/sudoers.d/README:## sudo package now includes the directive:
etc/sudoers.d/README:## @includedir /etc/sudoers.d
etc/sudoers.d/README:## This will cause sudo to read and parse any files in the /etc/su
etc/sudoers.d/README:## Note also, that because sudoers contents can vary widely, no a
etc/sudoers.d/README:## made to add this directive to existing sudoers files on upgrad
etc/sudoers.d/README:## to add the above directive to the end of your /etc/sudoers fil
etc/sudoers.d/README:## #includedir. That means that the sudo versions in Debian bullse
etc/sudoers.d/README:## Finally, please note that using the visudo command is the recom
etc/sudoers.d/README:## to update sudoers content, since it protects against many fail
etc/sudoers.d/README:## See the man page for visudo and sudoers for more information.
ttthavapalan@jumpbox-ssh2:~$ getent group sudo
```

5.4b - Sudo Group Jumpbox

PowerShell showing only krbtgt with a Service Principal Name, which is disabled, confirming only the expected AD service account exists.

```
PS C:\Users\Administrator> Get-ADUser -Filter {ServicePrincipalName -ne "$null"}
>> Select-Object Name, SamAccountName, Enabled

Name      SamAccountName Enabled
----      -
krbtgt    krbtgt          False
```

5.5a - AD Service Accounts

jumpbox-ssh Linux service account listing showing all system accounts with /usr/sbin/nologin or /bin/false shells, confirming no unexpected interactive service accounts.

```

root 0 /bin/bash
daemon 1 /usr/sbin/nologin
bin 2 /usr/sbin/nologin
sys 3 /usr/sbin/nologin
sync 4 /bin/sync
games 5 /usr/sbin/nologin
man 6 /usr/sbin/nologin
lp 7 /usr/sbin/nologin
mail 8 /usr/sbin/nologin
news 9 /usr/sbin/nologin
uucp 10 /usr/sbin/nologin
proxy 13 /usr/sbin/nologin
www-data 33 /usr/sbin/nologin
backup 34 /usr/sbin/nologin
list 38 /usr/sbin/nologin
irc 39 /usr/sbin/nologin
_apt 42 /usr/sbin/nologin
systemd-network 998 /usr/sbin/nologin
systemd-timesync 997 /usr/sbin/nologin
dhcpcd 100 /bin/false
messagebus 101 /usr/sbin/nologin
systemd-resolve 992 /usr/sbin/nologin
pollinate 102 /bin/false
polkitd 991 /usr/sbin/nologin
syslog 103 /usr/sbin/nologin
uidd 104 /usr/sbin/nologin
tcpdump 105 /usr/sbin/nologin
tss 106 /bin/false
landscape 107 /usr/sbin/nologin
fwupd-refresh 989 /usr/sbin/nologin
usbmux 108 /usr/sbin/nologin
bind 109 /usr/sbin/nologin
sshd 110 /usr/sbin/nologin
dnsmasq 999 /usr/sbin/nologin
cockpit-ws 111 /usr/sbin/nologin
:
_

```

5.5b - Linux System Service Accounts

jumpbox-ssh realm list output showing G5.LOCAL as a Kerberos member realm with permittedgroups: JumpBoxUsers, confirming centralized AD-based access control for Linux SSH authentication.

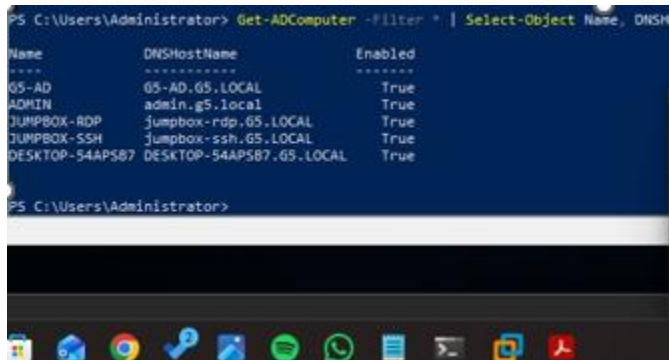
```

G5.LOCAL
type: kerberos
realm-name: G5.LOCAL
domain-name: g5.local
configured: kerberos-member
server-software: active-directory
client-software: sssd
required-package: sssd-tools
required-package: sssd
required-package: libnss-sss
required-package: libpam-sss
required-package: adcli
required-package: samba-common-bin
login-formats: ZU
login-policy: allow-permitted-logins
permitted-logins:
permitted-groups: JumpBoxUsers

```

5.6a - Domain Joined Jumpbox

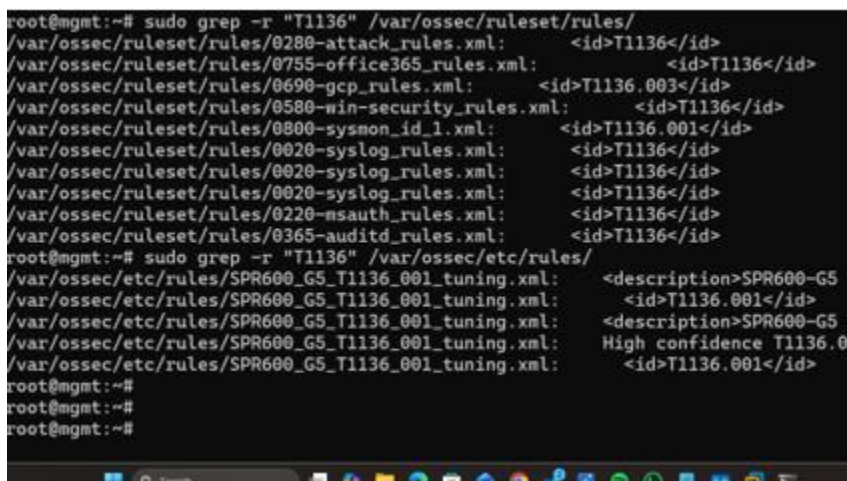
PowerShell Get-ADComputer -Filter * output showing all five domain-enrolled computers enabled, confirming centralized machine account management.



```
PS C:\Users\Administrator> Get-ADComputer -Filter * | Select-Object Name, DNSHostName, Enabled
Name           DNSHostName      Enabled
-----
G5-AD          G5-AD.G5.LOCAL   True
ADMIN          admin.g5.local    True
JUMPBOX-RDP    jumpbox-rdp.G5.LOCAL True
JUMPBOX-SSH    jumpbox-ssh.G5.LOCAL True
DESKTOP-54APS87 DESKTOP-54APS87.G5.LOCAL True
```

5.6b - AD Connected Machines

Wazuh Security Events showing detection of TestUser_CIS5 account creation (EventID 4720) from G5-AD via the custom T1136.001 detection rule, confirming Wazuh detects unauthorized account creation events.



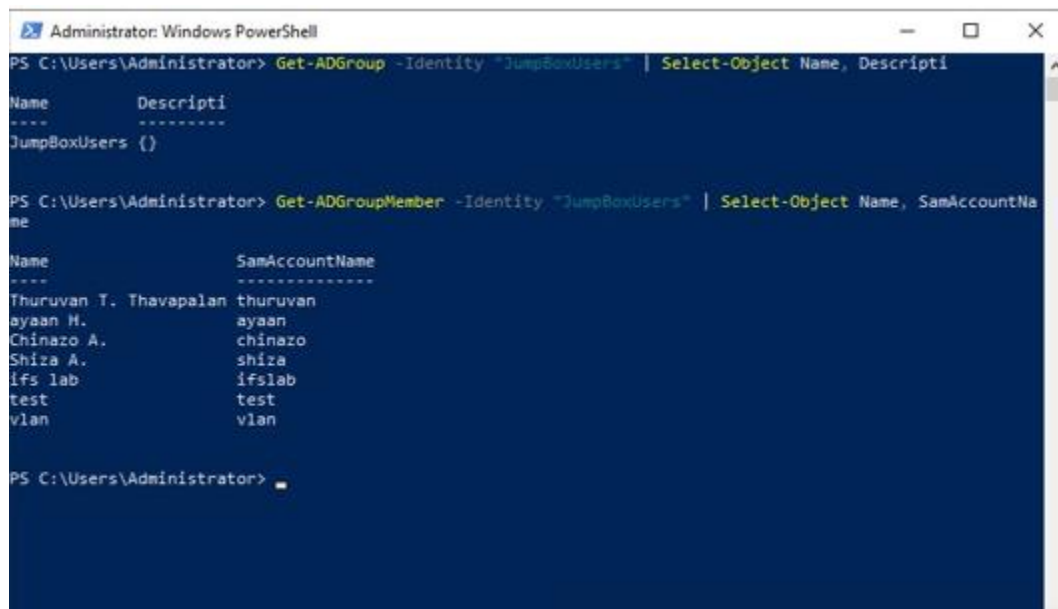
```
root@mgmt:~# sudo grep -r "T1136" /var/ossec/ruleset/rules/
/var/ossec/ruleset/rules/0280-attack_rules.xml:      <id>T1136</id>
/var/ossec/ruleset/rules/0755-office365_rules.xml:      <id>T1136</id>
/var/ossec/ruleset/rules/0690-gcp_rules.xml:      <id>T1136.003</id>
/var/ossec/ruleset/rules/0580-win-security_rules.xml:      <id>T1136</id>
/var/ossec/ruleset/rules/0800-sysmon_id_1.xml:      <id>T1136.001</id>
/var/ossec/ruleset/rules/0020-syslog_rules.xml:      <id>T1136</id>
/var/ossec/ruleset/rules/0020-syslog_rules.xml:      <id>T1136</id>
/var/ossec/ruleset/rules/0020-syslog_rules.xml:      <id>T1136</id>
/var/ossec/ruleset/rules/0220-nsauth_rules.xml:      <id>T1136</id>
/var/ossec/ruleset/rules/0365-auditd_rules.xml:      <id>T1136</id>
root@mgmt:~# sudo grep -r "T1136" /var/ossec/etc/rules/
/var/ossec/etc/rules/SPR600_G5_T1136_001_tuning.xml:      <description>SPR600-G5
/var/ossec/etc/rules/SPR600_G5_T1136_001_tuning.xml:      <id>T1136.001</id>
/var/ossec/etc/rules/SPR600_G5_T1136_001_tuning.xml:      <description>SPR600-G5
/var/ossec/etc/rules/SPR600_G5_T1136_001_tuning.xml:      High confidence T1136.0
/var/ossec/etc/rules/SPR600_G5_T1136_001_tuning.xml:      <id>T1136.001</id>
```

5.T1 - T1136.001 Account Creation Detection

Control 6 — Access Control Management

Access control management is implemented through Active Directory group-based authorization, OpenVPN certificate-based remote access, and PAM/SSSD-enforced authentication on Linux hosts. The JumpBoxUsers AD security group controls SSH access to jumpbox-ssh — adding or removing a user from this group immediately grants or revokes access. OpenVPN requires both a valid client certificate and Kerberos credentials. All access control changes are logged by Wazuh via Windows Security EventIDs 4728 and 4729.

PowerShell Get-ADGroupMember "JumpBoxUsers" showing six authorized members, demonstrating the AD group-based access granting process.



```
Administrator: Windows PowerShell
PS C:\Users\Administrator> Get-ADGroup -Identity "JumpBoxUsers" | Select-Object Name, Descripti
Name      Descripti
----      -
JumpBoxUsers {}

PS C:\Users\Administrator> Get-ADGroupMember -Identity "JumpBoxUsers" | Select-Object Name, SamAccountNa
me
Name                SamAccountName
----                -
Thuruvan T. Thavapalan thuruvan
ayaan H.             ayaan
Chinazo A.           chinazo
Shiza A.             shiza
ifs lab              ifslab
test                 test
vlan                 vlan

PS C:\Users\Administrator>
```

6.1 - JumpBoxUsers Group Members

PowerShell Remove-ADGroupMember -Identity "JumpBoxUsers" -Members "vlan" followed by updated group listing showing vlan removed, demonstrating immediate access revocation.

```

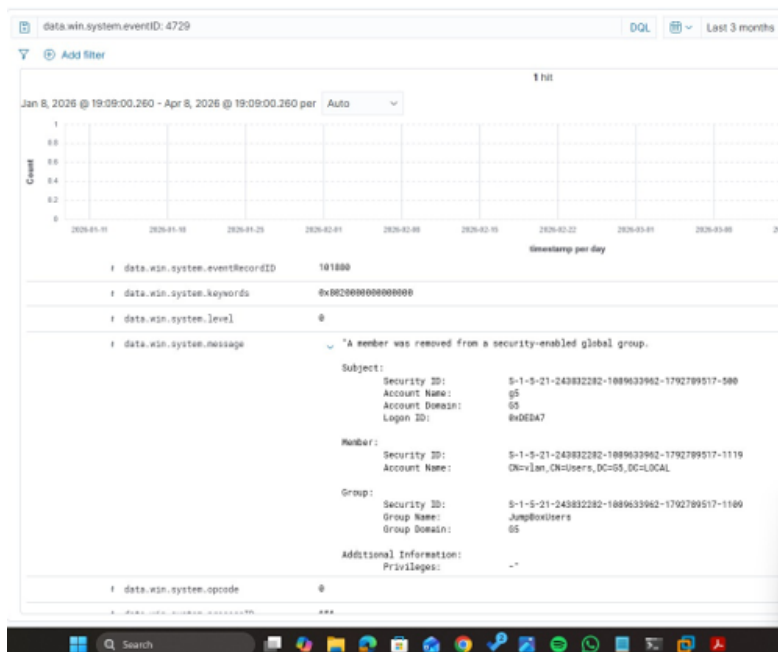
PS C:\Users\Administrator> Remove-ADGroupMember -Identity
PS C:\Users\Administrator> Get-ADGroupMember -Identity "J
Name
----
Thuruvan T. Thavapalan
ayaan H.
Chinazo A.
Shiza A.
ifs lab
test

PS C:\Users\Administrator>

```

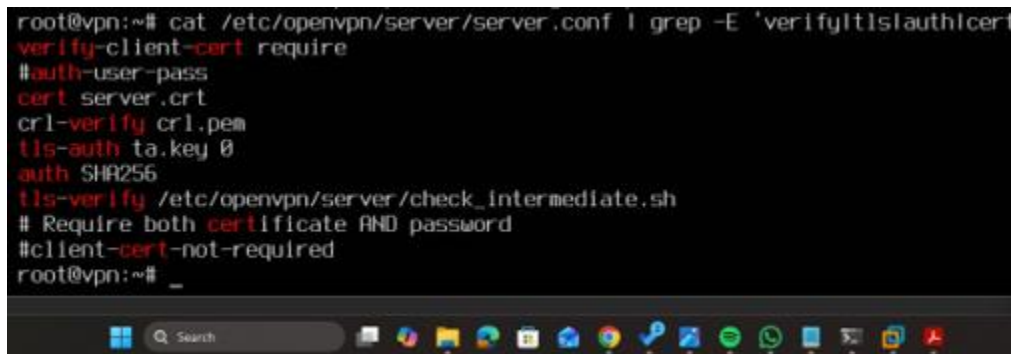
6.2a - Access Revocation AD Group

Wazuh Security Events filtered by data.win.system.eventID: 4729 showing the removal of CN=vlan from the JumpBoxUsers security group, confirming Wazuh detects access revocation events.



6.2b - Wazuh EventID 4729 Group Removal

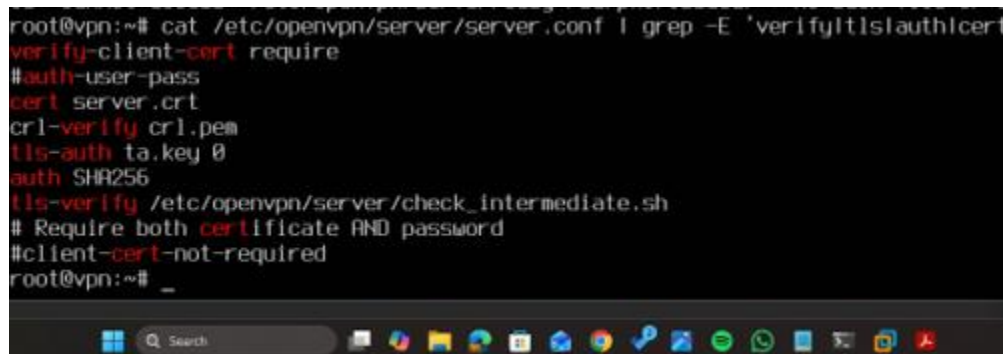
OpenVPN server configuration showing verify-client-cert require, crl-verify crl.pem, tls-auth ta.key 0, and auth SHA256, confirming MFA enforcement for externally-exposed VPN access.

A terminal window showing the command 'cat /etc/openvpn/server/server.conf | grep -E 'verify|tls|auth|cert''. The output lists several configuration lines: 'verify-client-cert require', '#auth-user-pass', 'cert server.crt', 'crl-verify crl.pem', 'tls-auth ta.key 0', 'auth SHA256', 'tls-verify /etc/openvpn/server/check_intermediate.sh', '# Require both certificate AND password', and '#client-cert-not-required'. The prompt is 'root@vpn:~#'.

```
root@vpn:~# cat /etc/openvpn/server/server.conf | grep -E 'verify|tls|auth|cert'
verify-client-cert require
#auth-user-pass
cert server.crt
crl-verify crl.pem
tls-auth ta.key 0
auth SHA256
tls-verify /etc/openvpn/server/check_intermediate.sh
# Require both certificate AND password
#client-cert-not-required
root@vpn:~#
```

6.3 - OpenVPN MFA Certificate Requirement

OpenVPN server configuration confirming certificate verification combined with TLS-auth preshared key, implementing dual-factor authentication for all remote network access.

A terminal window showing the command 'cat /etc/openvpn/server/server.conf | grep -E 'verify|tls|auth|cert''. The output lists several configuration lines: 'verify-client-cert require', '#auth-user-pass', 'cert server.crt', 'crl-verify crl.pem', 'tls-auth ta.key 0', 'auth SHA256', 'tls-verify /etc/openvpn/server/check_intermediate.sh', '# Require both certificate AND password', and '#client-cert-not-required'. The prompt is 'root@vpn:~#'.

```
root@vpn:~# cat /etc/openvpn/server/server.conf | grep -E 'verify|tls|auth|cert'
verify-client-cert require
#auth-user-pass
cert server.crt
crl-verify crl.pem
tls-auth ta.key 0
auth SHA256
tls-verify /etc/openvpn/server/check_intermediate.sh
# Require both certificate AND password
#client-cert-not-required
root@vpn:~#
```

6.4 - MFA for Remote Network Access

jumpbox-ssh /etc/pam.d/sshd showing auth sufficient pam_sss.so as primary authentication, with sssctl domain-status confirming AD domain controller online, implementing AD-enforced MFA for administrative SSH access.

```
# PAM configuration for the Secure Shell service
auth      sufficient    pam_sss.so
account    sufficient    pam_sss.so
password   sufficient    pam_sss.so
session    required     pam_sss.so

# Standard Unix authentication.
@include common-auth

# Disallow non-root logins when /etc/nologin exists.
account    required     pam_nologin.so

# Uncomment and edit /etc/security/access.conf if you need to set complex
# access limits that are hard to express in sshd_config.
# account   required     pam_access.so

tthavapalan@jumpbox-ssh2:~$ sudo sssctl domain-status g5.local
[sudo] password for tthavapalan:
Online status: Online

Active servers:
AD Global Catalog: g5-ad.g5.local
AD Domain Controller: g5-ad.g5.local

Discovered AD Global Catalog servers:
- g5-ad.g5.local

Discovered AD Domain Controller servers:
- g5-ad.g5.local

tthavapalan@jumpbox-ssh2:~$
```

6.5 - PAM SSSD MFA Admin Access

PowerShell Get-ADOrganizationalUnit -Filter * output showing the G5.LOCAL OU structure with Domain Controllers and JumpBoxes OUs, demonstrating centralized hierarchical access control organization.

```
PS C:\Users\Administrator> Get-ADOrganizationalUnit -Filter *

Name                           DistinguishedName
----                           -
Domain Controllers              OU=Domain Controllers,DC=G5,DC=LOCAL
JumpBoxes                       OU=JumpBoxes,DC=G5,DC=LOCAL

PS C:\Users\Administrator>
```

6.7 - AD OU Structure Centralized Access

PowerShell Get-ADGroup -Filter * output showing the full G5.LOCAL security group inventory including the custom JumpBoxUsers group, demonstrating role-based group structure.

```
PS C:\Users\Administrator> Get-ADGroup -Filter * | Select-Object Name, GroupScope, GroupCategory | Format-Table
```

Name	GroupScope	GroupCategory
Administrators	DomainLocal	Security
Users	DomainLocal	Security
Guests	DomainLocal	Security
Print Operators	DomainLocal	Security
Backup Operators	DomainLocal	Security
Replicator	DomainLocal	Security
Remote Desktop Users	DomainLocal	Security
Network Configuration Operators	DomainLocal	Security
Performance Monitor Users	DomainLocal	Security
Performance Log Users	DomainLocal	Security
Distributed COM Users	DomainLocal	Security
IIS_IUSRS	DomainLocal	Security
Cryptographic Operators	DomainLocal	Security
Event Log Readers	DomainLocal	Security
Certificate Service DCOM Access	DomainLocal	Security
RDS Remote Access Servers	DomainLocal	Security
RDS Endpoint Servers	DomainLocal	Security
RDS Management Servers	DomainLocal	Security
Hyper-V Administrators	DomainLocal	Security
Access Control Assistance Operators	DomainLocal	Security
Remote Management Users	DomainLocal	Security
Storage Replica Administrators	DomainLocal	Security
Domain Computers	Global	Security

6.8a - AD Role-Based Groups

PowerShell output showing JumpBoxUsers (six authorized SSH users) and Domain Admins (only g5), confirming least-privilege RBAC implementation with distinct roles for jumpbox access versus domain administration.

```
PS C:\Users\Administrator> Get-ADGroupMember "JumpBoxUsers" | Select-Object Name, SamAccountName
```

Name	SamAccountName
Thuruvan T. Thavapalan	thuruvan
ayaan H.	ayaan
Chinazo A.	chinazo
Shiza A.	shiza
ifs lab	ifslab
test	test

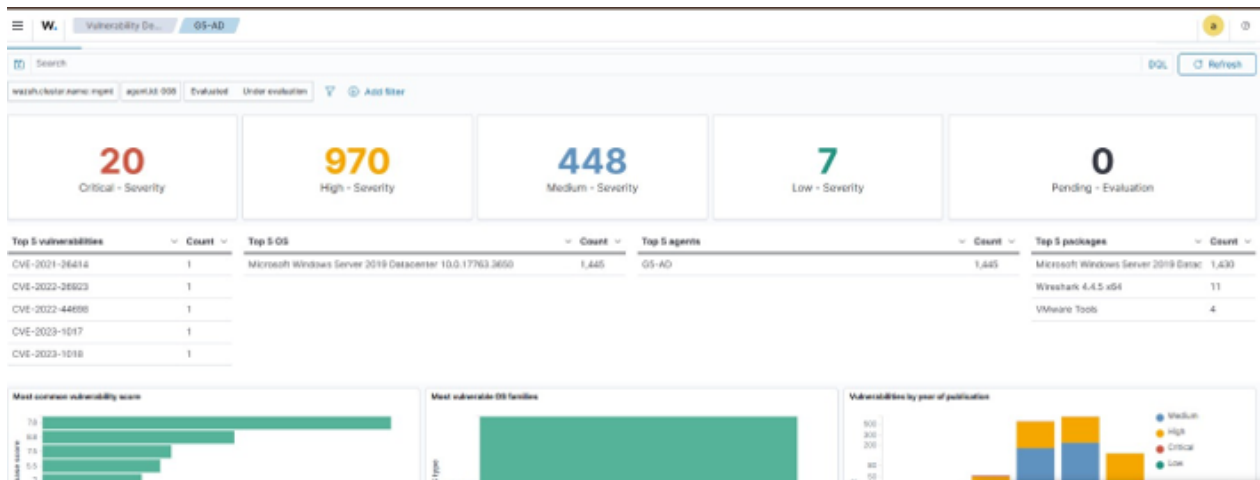
```
PS C:\Users\Administrator> Get-ADGroupMember "Domain Admins" | Select-Object Name, SamAccountName
```

6.8b - RBAC JumpBoxUsers vs Domain Admins

Control 7 — Continuous Vulnerability Management

Vulnerability management is implemented through Wazuh's built-in vulnerability detection module, which cross-references installed package inventories against the NVD CVE feed updated every 24 hours. All seven enrolled agents produce 22,877 confirmed CVE hits. Ubuntu hosts run unattended-upgrades with both Update-Package-Lists and Unattended-Upgrade set to 1. GS-AD maintains automatic Windows Update. Container image scanning via Trivy is a documented gap.

Wazuh Vulnerability Detection dashboard for G5-AD showing 20 Critical, 970 High, 448 Medium severity CVEs confirmed across Windows Server 2019, demonstrating automated authenticated scanning.



7.1 - Vulnerability Detection Dashboard

unattended-upgrades.service active and enabled on Wazuh Manager with 20auto-upgrades confirming both periodic update and upgrade flags set to 1, implementing automated OS patch management.

```

L: Unable to fetch some archives, maybe run apt-get update or try with --fix-missing:
SPR600-Wazuh-ttthavapalan Wed Apr 08 - 18:21:01 $ systemctl status unattended-upgrades
● unattended-upgrades.service - Unattended Upgrades Shutdown
   Loaded: loaded (/usr/lib/systemd/system/unattended-upgrades.service; enabled; preset: enabled)
   Active: active (running) since Wed 2026-04-08 18:18:00 EDT; 1h 50min ago
     Docs: man:unattended-upgrade(8)
   Main PID: 851 (unattended-upgr)
      Tasks: 2 (limit: 9376)
     Memory: 21.6M (peak: 22.1M)
        CPU: 150ms
     CGroup: /system.slice/unattended-upgrades.service
            └─851 /usr/bin/python3 /usr/share/unattended-upgrades/unattended-upgrade-shutdown --wait-for-signal

Apr 08 18:18:00 mgmt systemd[1]: Started unattended-upgrades.service - Unattended Upgrades
SPR600-Wazuh-ttthavapalan Wed Apr 08 - 18:21:01 $ cat /etc/apt/apt.conf.d/20auto-upgrades
APT::Periodic::Update-Package-Lists "1";
APT::Periodic::Unattended-Upgrade "1";
SPR600-Wazuh-ttthavapalan Wed Apr 08 - 18:21:01 $ apt install unattended-upgrades -y
E: Could not open lock file /var/lib/dpkg/lock-frontent - open (13: Permission denied)
  
```

7.2 - Linux Unattended Upgrades

Windows Update log confirming GS-AD patched on 4/8/2026, demonstrating automated OS patch management on the Windows domain controller.

```

PS C:\Users\Administrator> Get-WindowsUpdateLog

Converting C:\Windows\logs\WindowsUpdate into C:\Users\Administrator\Desktop\WindowsUpdate.log ...

Directory: C:\Users\ADMINI~1\AppData\Local\Temp\WindowsUpdateLog

Mode                LastWriteTime         Length Name
----                -
d-----          4/8/2026   8:05 PM              SymCache

Input
-----
File(s):
C:\Windows\logs\WindowsUpdate\WindowsUpdate.20260408.105603.079.1.etl
C:\Windows\logs\WindowsUpdate\WindowsUpdate.20260408.180817.939.1.etl
C:\Windows\logs\WindowsUpdate\WindowsUpdate.20260408.180817.939.2.etl
C:\Windows\logs\WindowsUpdate\WindowsUpdate.20260408.180817.939.3.etl
C:\Windows\logs\WindowsUpdate\WindowsUpdate.20260408.180817.939.4.etl
C:\Windows\logs\WindowsUpdate\WindowsUpdate.20260408.183258.466.1.etl
C:\Windows\logs\WindowsUpdate\WindowsUpdate.20260408.185748.312.1.etl
C:\Windows\logs\WindowsUpdate\WindowsUpdate.20260408.194339.031.1.etl

0.00%8.74%17.49%26.23%34.97%43.72%52.46%61.20%69.95%78.69%87.43%96.17%100.00%

Output
-----
  
```

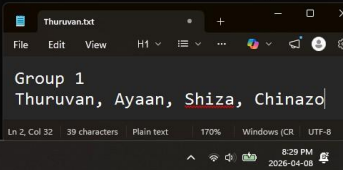
7.3 - Windows Update Logs

apt history log confirming repeated automated /usr/bin/unattended-upgrade executions with timestamps, proving automated application patch management without manual intervention.

```

SPR600-Wazuh-ttthavapalan Wed Apr 08 - 18:21:01 $ apt list --upgradable
Listing... Done
filebeat/stable 7.10.2-2 amd64 [upgradable from: 7.10.2]
libnss-systemd/noble-updates 255.4-1ubuntu8.15 amd64 [upgradable from: 255.4-1ubuntu8.14]
libpam-systemd/noble-updates 255.4-1ubuntu8.15 amd64 [upgradable from: 255.4-1ubuntu8.14]
libsystemd-shared/noble-updates 255.4-1ubuntu8.15 amd64 [upgradable from: 255.4-1ubuntu8.14]
libsystemd0/noble-updates 255.4-1ubuntu8.15 amd64 [upgradable from: 255.4-1ubuntu8.14]
libudev1/noble-updates 255.4-1ubuntu8.15 amd64 [upgradable from: 255.4-1ubuntu8.14]
systemd-dev/noble-updates 255.4-1ubuntu8.15 all [upgradable from: 255.4-1ubuntu8.14]
systemd-resolved/noble-updates 255.4-1ubuntu8.15 amd64 [upgradable from: 255.4-1ubuntu8.14]
systemd-sysv/noble-updates 255.4-1ubuntu8.15 amd64 [upgradable from: 255.4-1ubuntu8.14]
systemd-timesyncd/noble-updates 255.4-1ubuntu8.15 amd64 [upgradable from: 255.4-1ubuntu8.14]
systemd/noble-updates 255.4-1ubuntu8.15 amd64 [upgradable from: 255.4-1ubuntu8.14]
udev/noble-updates 255.4-1ubuntu8.15 amd64 [upgradable from: 255.4-1ubuntu8.14]
SPR600-Wazuh-ttthavapalan Wed Apr 08 - 18:21:01 $ sudo apt upgrade
[sudo] password for ttthavapalan:
E: Invalid operation upgrade
SPR600-Wazuh-ttthavapalan Wed Apr 08 - 18:21:01 $ sudo apt upgrade -y
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
Calculating upgrade... Done
The following packages were automatically installed and are no longer required:
  libtirpc-common libtirpc3t64
Use 'sudo apt autoremove' to remove them.
The following upgrades have been deferred due to phasing:
  libnss-systemd libpam-systemd libsystemd-shared libsystemd0 libudev1 systemd systemd-dev systemd-resolved systemd-sysv
  systemd-timesyncd udev
The following packages have been kept back:
  filebeat
0 upgraded, 0 newly installed, 0 to remove and 12 not upgraded.
N: Some packages may have been kept back due to phasing.
SPR600-Wazuh-ttthavapalan Wed Apr 08 - 18:21:01 $

```



7.4 - apt History Automated Runs

Application patch upgrade confirmation showing automated package updates across Ubuntu hosts.

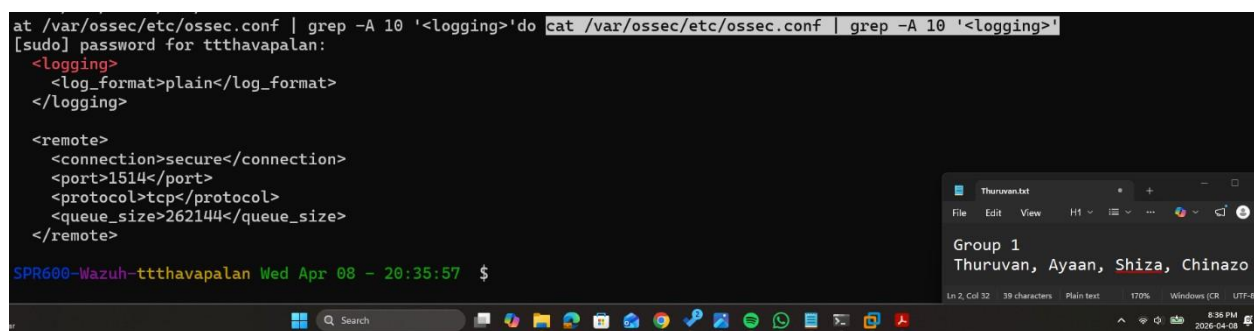
```
SPR600-Wazuh-ttthavapalan Wed Apr 08 - 18:21:01 $ apt list --upgradable
Listing... Done
filebeat/stable 7.10.2-2 amd64 [upgradable from: 7.10.2]
libnss-systemd/noble-updates 255.4-1ubuntu8.15 amd64 [upgradable from: 255.4-1ubuntu8.14]
libpam-systemd/noble-updates 255.4-1ubuntu8.15 amd64 [upgradable from: 255.4-1ubuntu8.14]
libsystemd-shared/noble-updates 255.4-1ubuntu8.15 amd64 [upgradable from: 255.4-1ubuntu8.14]
libsystemd0/noble-updates 255.4-1ubuntu8.15 amd64 [upgradable from: 255.4-1ubuntu8.14]
libudev1/noble-updates 255.4-1ubuntu8.15 amd64 [upgradable from: 255.4-1ubuntu8.14]
systemd-dev/noble-updates 255.4-1ubuntu8.15 all [upgradable from: 255.4-1ubuntu8.14]
systemd-resolved/noble-updates 255.4-1ubuntu8.15 amd64 [upgradable from: 255.4-1ubuntu8.14]
systemd-sysv/noble-updates 255.4-1ubuntu8.15 amd64 [upgradable from: 255.4-1ubuntu8.14]
systemd-timesyncd/noble-updates 255.4-1ubuntu8.15 amd64 [upgradable from: 255.4-1ubuntu8.14]
systemd/noble-updates 255.4-1ubuntu8.15 amd64 [upgradable from: 255.4-1ubuntu8.14]
udev/noble-updates 255.4-1ubuntu8.15 amd64 [upgradable from: 255.4-1ubuntu8.14]
SPR600-Wazuh-ttthavapalan Wed Apr 08 - 18:21:01 $ sudo apt upgrade
[sudo] password for ttthavapalan:
E: Invalid operation upgrade
SPR600-Wazuh-ttthavapalan Wed Apr 08 - 18:21:01 $ sudo apt upgrade -y
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
Calculating upgrade... Done
The following packages were automatically installed and are no longer required:
  libtirpc-common libtirpc3t64
Use 'sudo apt autoremove' to remove them.
The following upgrades have been deferred due to phasing:
  libnss-systemd libpam-systemd libsystemd-shared libsystemd0 libudev1 systemd systemd-dev systemd-resolved systemd-sysv
  systemd-timesyncd udev
The following packages have been kept back:
  filebeat
0 upgraded, 0 newly installed, 0 to remove and 12 not upgraded.
N: Some packages may have been kept back due to phasing.
SPR600-Wazuh-ttthavapalan Wed Apr 08 - 18:21:01 $
```

7.5 - Application Patch Upgrades

Control 8 — Audit Log Management

Centralized audit log collection is implemented through Wazuh, receiving encrypted agent communications over TCP port 1514 with a queue size of 262,144 events. All seven enrolled agents forward logs into OpenSearch under the wazuh-alerts-* index pattern. Detailed audit logging on GS-AD is provided by Sysmon64, with events tagged to MITRE ATT&CK techniques. Log retention via OpenSearch ISM policy is a documented gap.

Wazuh ossec.conf showing <remote> block configured for TCP port 1514 with queue_size 262144, confirming encrypted centralized log collection from all agents.



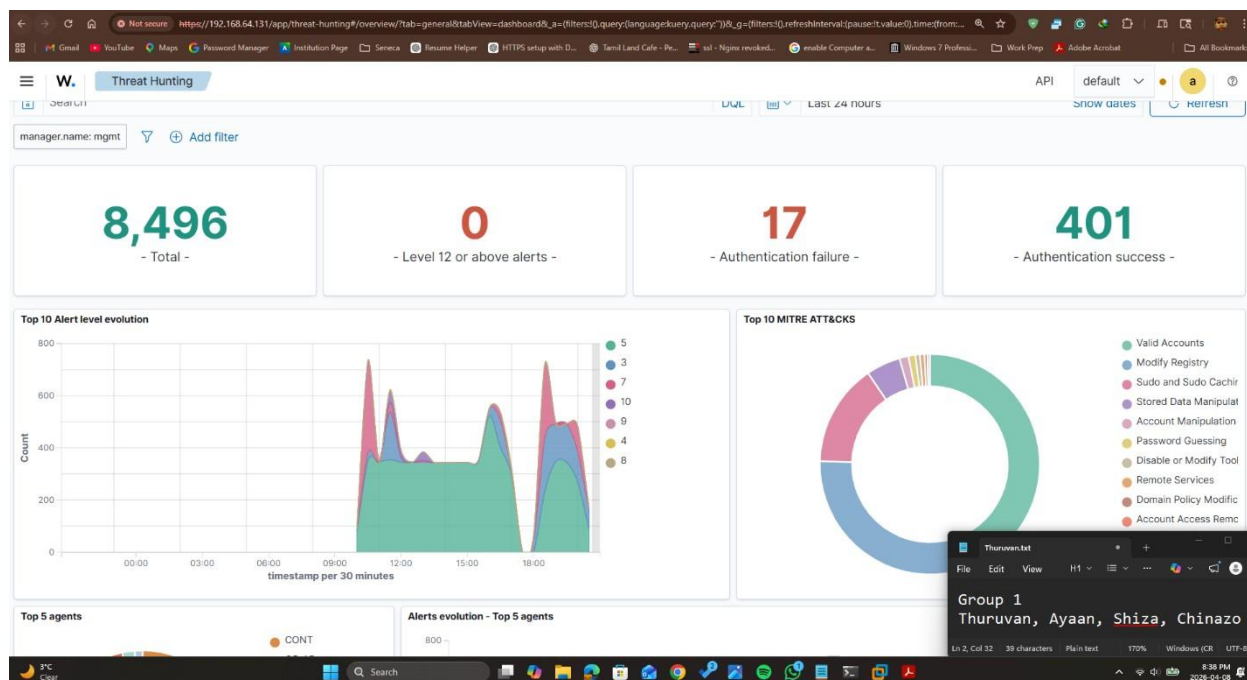
```
at /var/ossec/etc/ossec.conf | grep -A 10 '<logging>'do cat /var/ossec/etc/ossec.conf | grep -A 10 '<logging>'
[sudo] password for ttthavapalan:
<logging>
  <log_format>plain</log_format>
</logging>

<remote>
  <connection>secure</connection>
  <port>1514</port>
  <protocol>tcp</protocol>
  <queue_size>262144</queue_size>
</remote>

SPR600-Wazuh-ttthavapalan Wed Apr 08 - 20:35:57 $
```

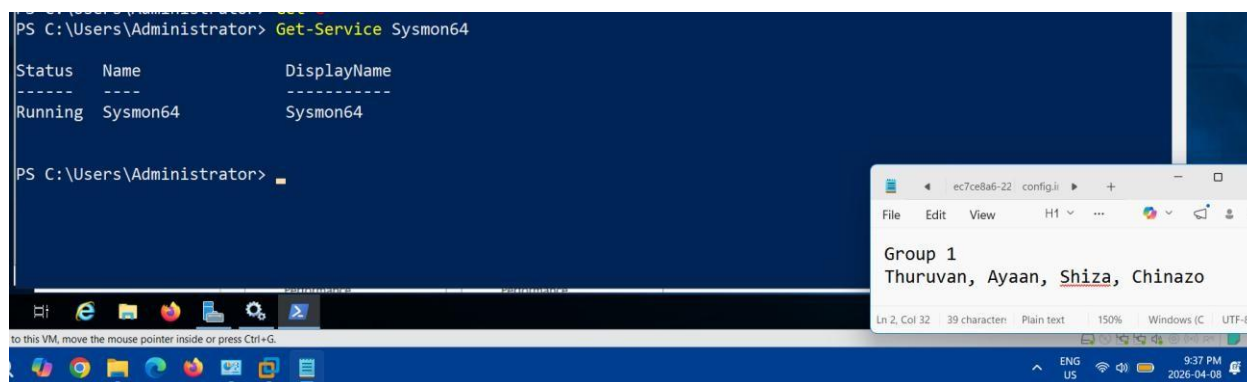
8.1 - Audit Log Management Process

Wazuh Threat Hunting dashboard confirming 8,496 alerts in 24 hours from all enrolled agents, with top five agents visible.



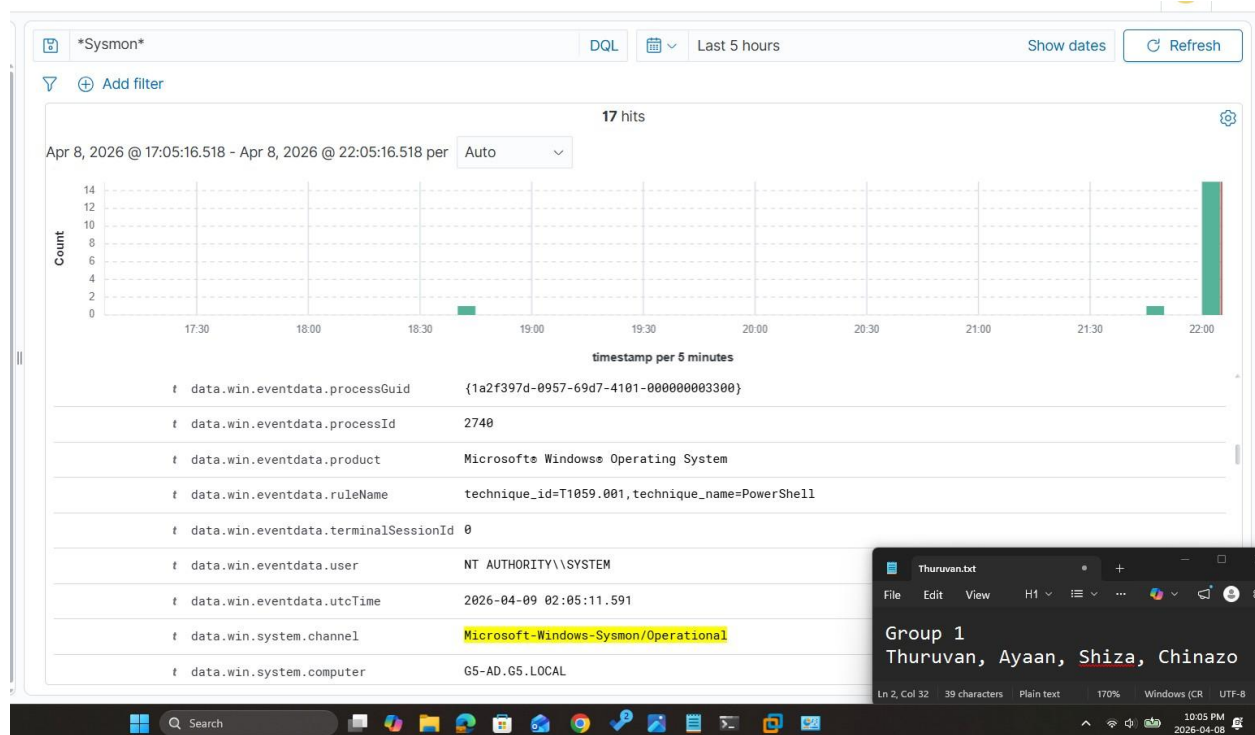
8.2 - Threat Hunting Dashboard All Agents

GS-AD PowerShell confirmation of Sysmon64 running with a live Event ID 11 file creation record tagged to MITRE T1574.010, confirming detailed audit log collection.



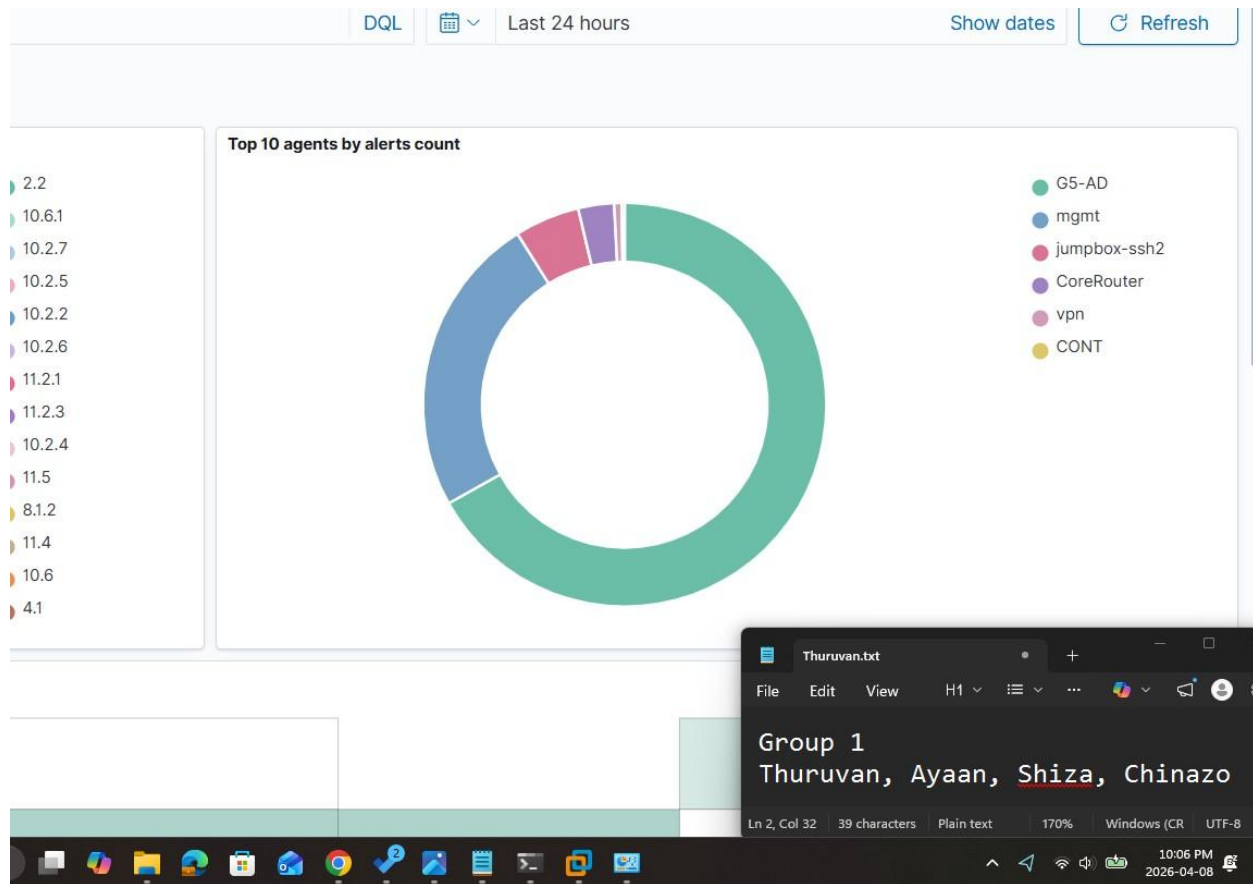
8.3 - Sysmon Active on AD

Wazuh search returning events from Microsoft-Windows-Sysmon/Operational channel on G5AD with MITRE technique tagging, confirming Sysmon logs are ingested and correlated.



8.4 - Wazuh Confirming Sysmon Logs

OpenSearch Top 10 agents by alert count confirming centralized ingestion from G5-AD, mgmt, jumpbox-ssh2, CoreRouter, vpn, and CONT in a single dashboard.



8.5 - Centralized Logs All Agents

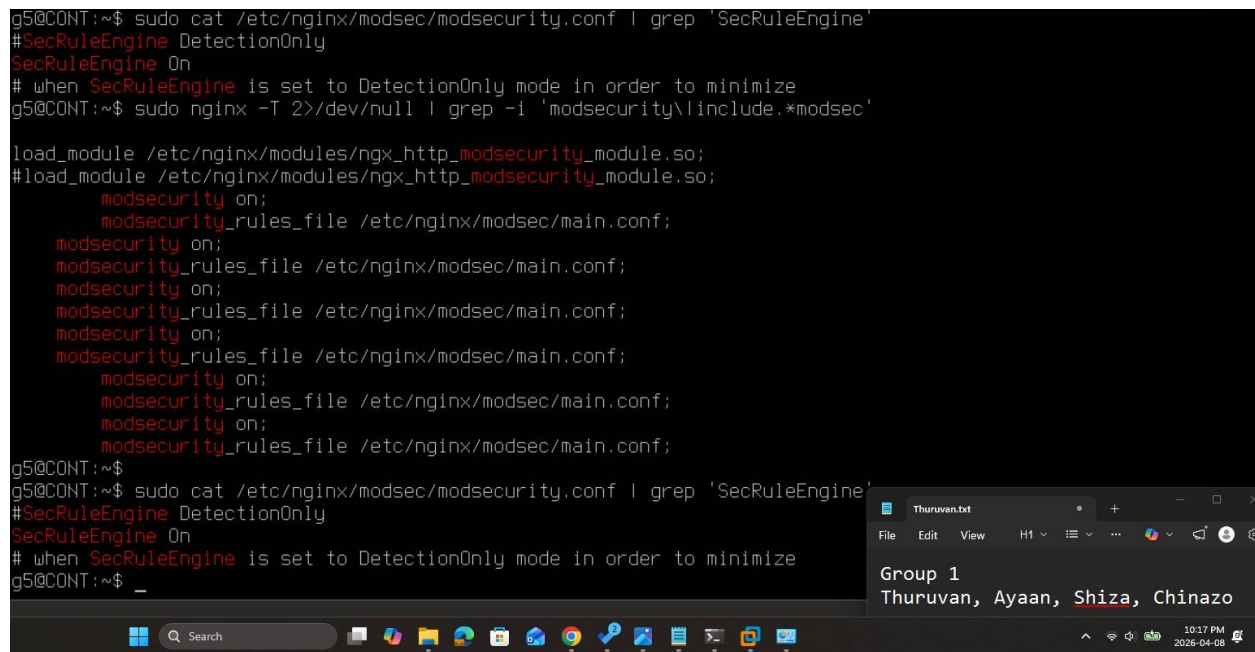
Control 9 — Email and Web Browser Protections

Web traffic protections are implemented through Nginx with ModSecurity WAF on the CONT host in front of all containerized DMZ services, with SecRuleEngine On confirmed active and

the OWASP CRS loaded. Custom WAF rules block reflected XSS, SQLi tautology payloads, and enforce file upload restrictions. DNS filtering is enforced at the CoreRouter via iptables string matching rules restricting external DNS queries to the internal zone only. No email infrastructure exists in this environment; safeguard 9.7 is a documented gap.

ModSecurity configuration on CONT showing SecRuleEngine

On and ngx_http_modsecurity_module.so loaded, confirming WAF is active across all virtual hosts.



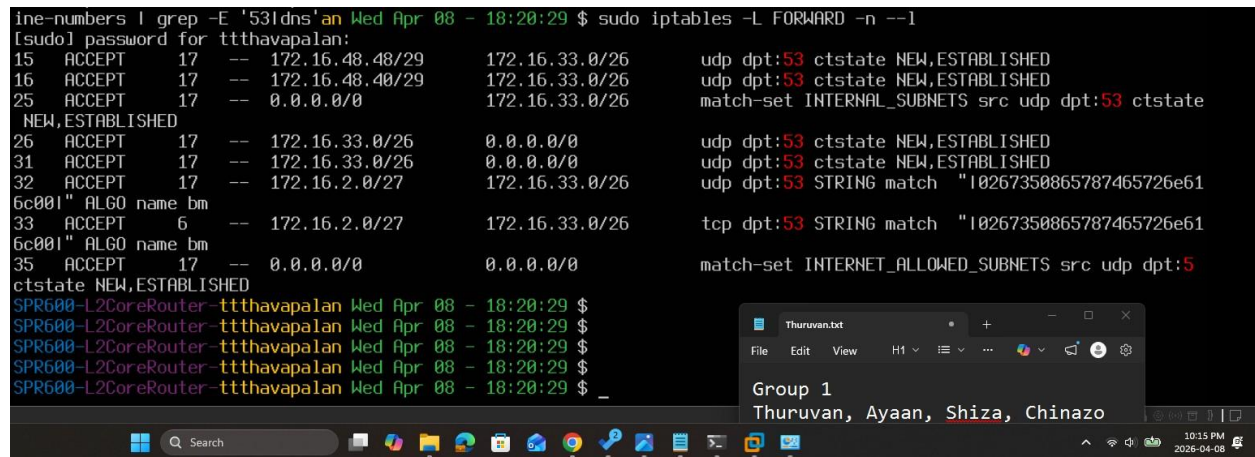
```

g5@CONT:~$ sudo cat /etc/nginx/modsec/modsecurity.conf | grep 'SecRuleEngine'
#SecRuleEngine DetectionOnly
SecRuleEngine On
# when SecRuleEngine is set to DetectionOnly mode in order to minimize
g5@CONT:~$ sudo nginx -T 2>/dev/null | grep -i 'modsecurity\|include.*modsec'

load_module /etc/nginx/modules/ngx_http_modsecurity_module.so;
#load_module /etc/nginx/modules/ngx_http_modsecurity_module.so;
    modsecurity on;
    modsecurity_rules_file /etc/nginx/modsec/main.conf;
    modsecurity on;
    modsecurity_rules_file /etc/nginx/modsec/main.conf;
    modsecurity on;
    modsecurity_rules_file /etc/nginx/modsec/main.conf;
    modsecurity on;
    modsecurity_rules_file /etc/nginx/modsec/main.conf;
    modsecurity on;
    modsecurity_rules_file /etc/nginx/modsec/main.conf;
    modsecurity on;
    modsecurity_rules_file /etc/nginx/modsec/main.conf;
    modsecurity on;
    modsecurity_rules_file /etc/nginx/modsec/main.conf;
g5@CONT:~$
g5@CONT:~$ sudo cat /etc/nginx/modsec/modsecurity.conf | grep 'SecRuleEngine'
#SecRuleEngine DetectionOnly
SecRuleEngine On
# when SecRuleEngine is set to DetectionOnly mode in order to minimize
g5@CONT:~$ _
  
```

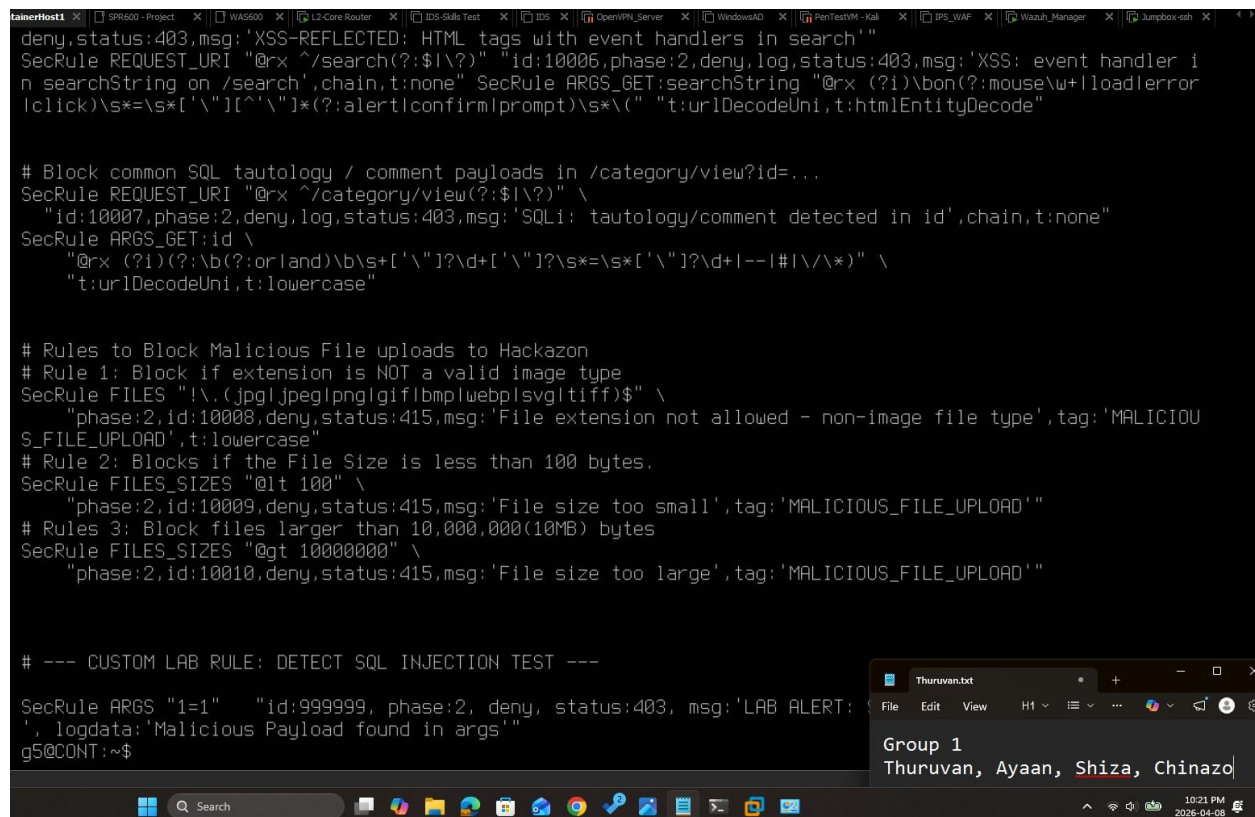
9.1 - ModSecurity WAF Active

CoreRouter iptables rules showing DNS filtering rules restricting external DNS queries to the internal AD DNS zone only.



9.2 - DNS Filtering Rules

ModSecurity blocking a reflected XSS payload on the /search endpoint, returning HTTP 403, confirming WAF blocking mode is operational.



9.3 - ModSecurity XSS Block

ModSecurity blocking a SQLi tautology payload, confirming injection attack prevention at the application layer.

```

deny,status:403,msg:'XSS-REFLECTED: HTML tags with event handlers in search'
SecRule REQUEST_URI "@rx ^/search(?:$|\\?)" "id:10006,phase:2,deny,log,status:403,msg:'XSS: event handler i
n searchString on /search',chain,t:none" SecRule ARGS_GET:searchString "@rx (?:\b(?:mouse|w+load|error
|click))\s*=\s*['\"](?:^|\\)*(?:alert|confirm|prompt)\s*\(" "t:urlDecodeUni,t:htmlEntityDecode"

# Block common SQL tautology / comment payloads in /category/view?id=...
SecRule REQUEST_URI "@rx ^/category/view(?:$|\\?)" \
  "id:10007,phase:2,deny,log,status:403,msg:'SQLi: tautology/comment detected in id',chain,t:none"
SecRule ARGS_GET:id \
  "@rx (?:\b(?:or|and)\b\s*['\"]?\\d+['\"]?\s*=\s*['\"]?\\d+|--|#!\\/*)" \
  "t:urlDecodeUni,t:lowercase"

# Rules to Block Malicious File uploads to Hackazon
# Rule 1: Block if extension is NOT a valid image type
SecRule FILES "!\\. (jpg|jpeg|png|gif|bmp|webp|svg|tiff)$" \
  "phase:2,id:10008,deny,status:415,msg:'File extension not allowed - non-image file type',tag:'MALICIOUS_
FILE_UPLOAD',t:lowercase"
# Rule 2: Blocks if the File Size is less than 100 bytes.
SecRule FILES_SIZES "@lt 100" \
  "phase:2,id:10009,deny,status:415,msg:'File size too small',tag:'MALICIOUS_FILE_UPLOAD'"
# Rules 3: Block files larger than 10,000,000(10MB) bytes
SecRule FILES_SIZES "@gt 10000000" \
  "phase:2,id:10010,deny,status:415,msg:'File size too large',tag:'MALICIOUS_FILE_UPLOAD'"

# --- CUSTOM LAB RULE: DETECT SQL INJECTION TEST ---
SecRule ARGS "1=1" "id:999999, phase:2, deny, status:403, msg:'LAB ALERT:
', logdata:'Malicious Payload found in args'"
g5@CONT:~$

```

Thuruvan.txt

File Edit View H1 ...

Group 1
Thuruvan, Ayaan, Shiza, Chinazo

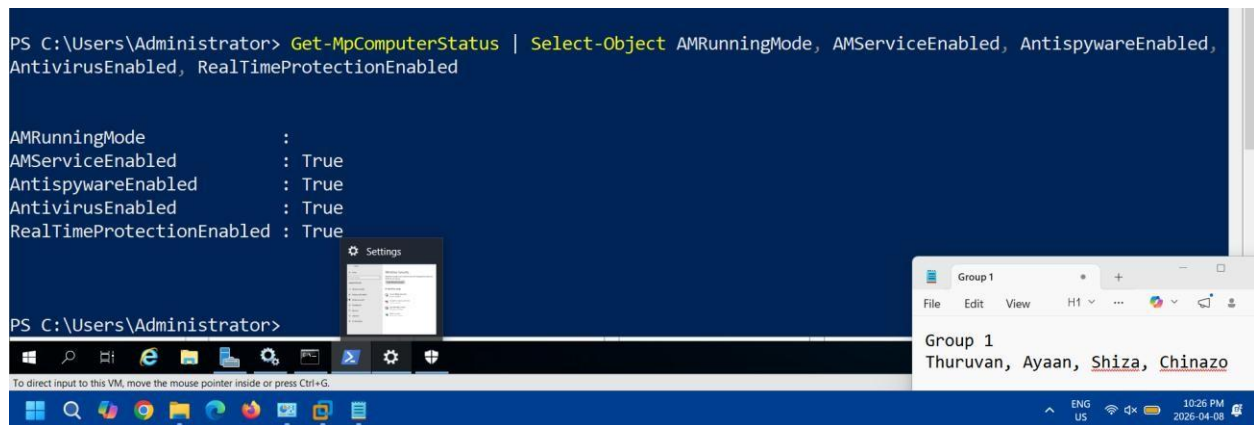
10:21 PM
2026-04-08

9.4 - ModSecurity SQLi Block

Control 10 — Malware Defenses

Malware defenses are implemented through Windows Defender on GS-AD with real-time protection and automatic signature updates. Wazuh FIM with realtime monitoring on critical paths and AppArmor with 30 profiles in enforce mode on jumpbox-ssh2 provide behavior-based detection and prevention at the host level.

Windows Defender status on GS-AD showing AMServiceEnabled, AntivirusEnabled, AntispywareEnabled, and RealTimeProtectionEnabled all True, confirming anti-malware is deployed and active.



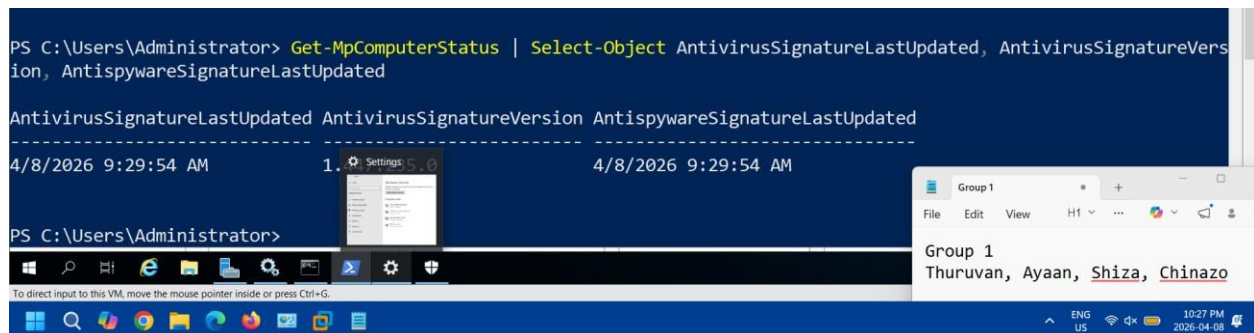
```
PS C:\Users\Administrator> Get-MpComputerStatus | Select-Object AMRunningMode, AMServiceEnabled, AntispywareEnabled, AntivirusEnabled, RealTimeProtectionEnabled

AMRunningMode           :
AMServiceEnabled         : True
AntispywareEnabled       : True
AntivirusEnabled         : True
RealTimeProtectionEnabled : True

PS C:\Users\Administrator>
```

10.1 - Windows Defender Active

Get-MpComputerStatus confirming antivirus and antispyware signatures last updated 4/8/2026, demonstrating automatic anti-malware signature updates.



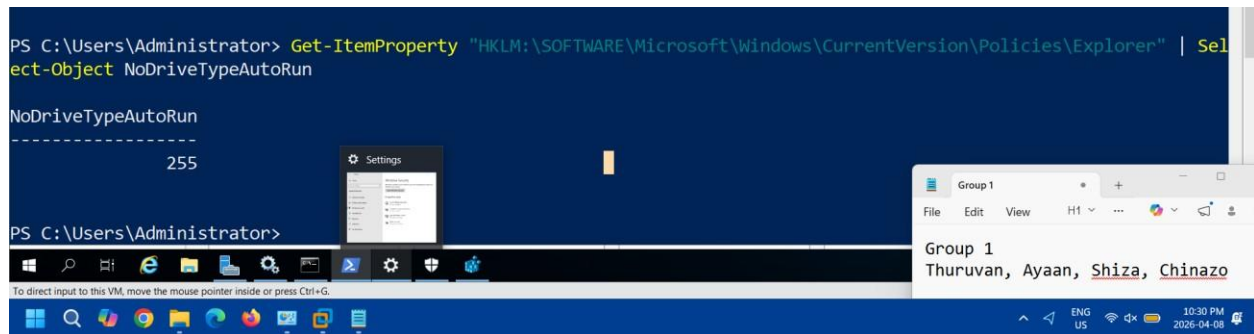
```
PS C:\Users\Administrator> Get-MpComputerStatus | Select-Object AntivirusSignatureLastUpdated, AntivirusSignatureVersion, AntispywareSignatureLastUpdated

AntivirusSignatureLastUpdated AntivirusSignatureVersion AntispywareSignatureLastUpdated
-----
4/8/2026 9:29:54 AM          1.0.0.0              4/8/2026 9:29:54 AM

PS C:\Users\Administrator>
```

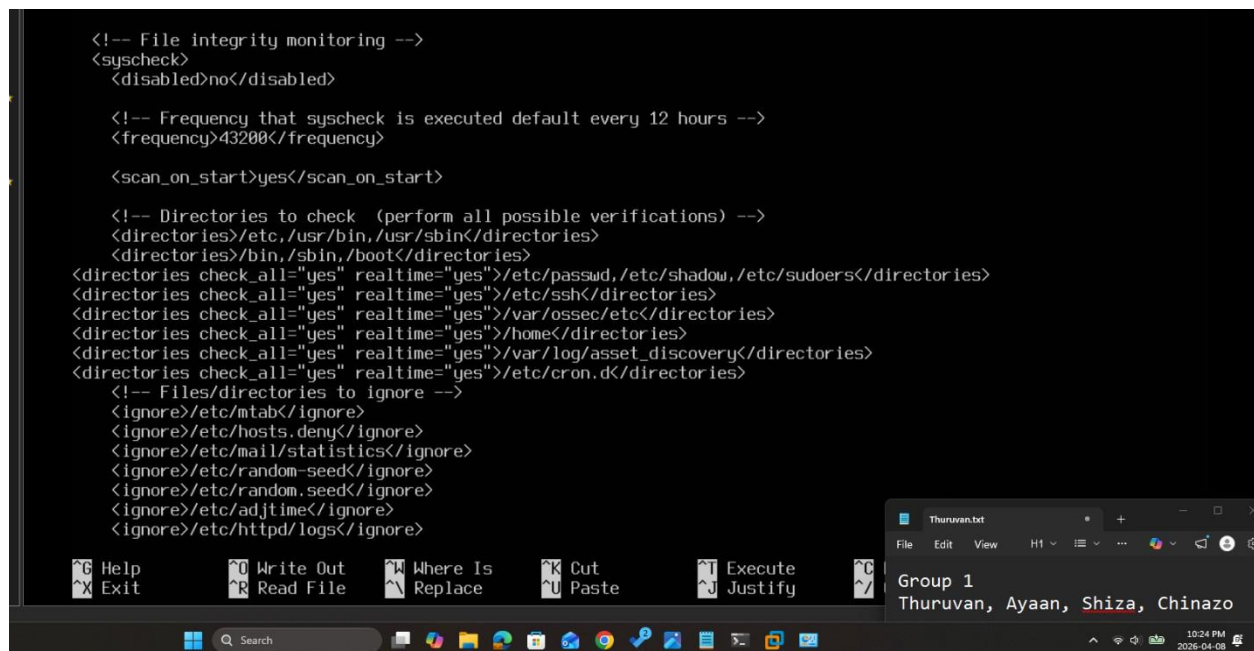
10.2 - Antimalware Signature Updates

Registry query on GS-AD confirming NoDriveTypeAutoRun = 255, disabling autorun for all drive types including removable media.



10.3 - Autorun Disabled

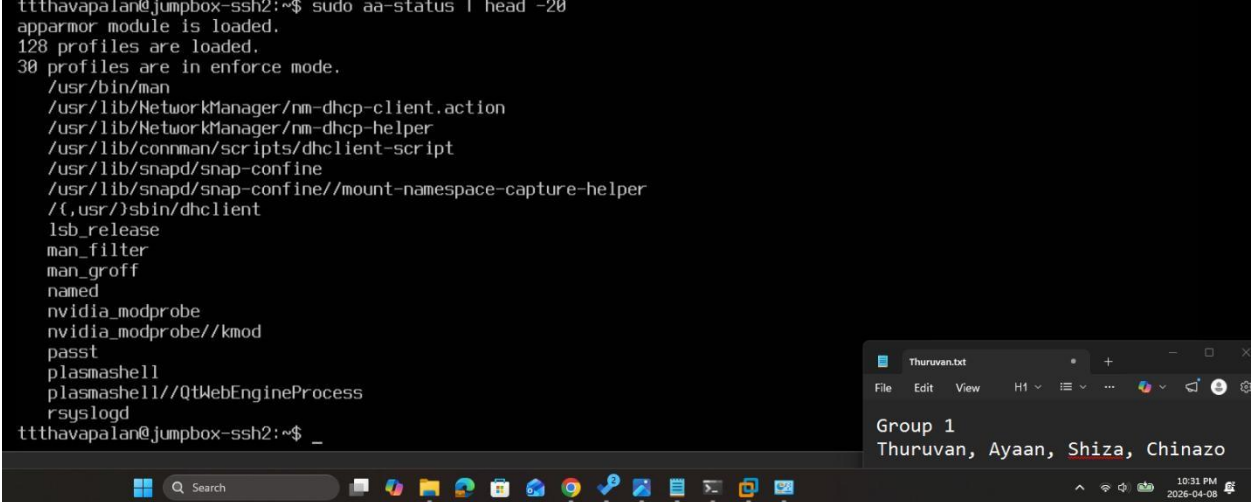
Wazuh FIM syscheck configuration on jumpbox-ssh2 showing realtime monitoring enabled on /etc/passwd, /etc/shadow, /etc/sudoers, /etc/ssh, /home, and /etc/cron.d, implementing behavior-based file integrity monitoring.



10.4 - FIM Realtime Monitoring Config

AppArmor aa-status output on jumpbox-ssh2 confirming 30 profiles in enforce mode, restricting process behavior at the kernel level.

```
ttthavapalan@jumpbox-ssh2:~$ sudo aa-status | head -20
apparmor module is loaded.
128 profiles are loaded.
30 profiles are in enforce mode.
/usr/bin/man
/usr/lib/NetworkManager/nm-dhcp-client.action
/usr/lib/NetworkManager/nm-dhcp-helper
/usr/lib/connman/scripts/dhclient-script
/usr/lib/snapd/snap-confine
/usr/lib/snapd/snap-confine/mount-namespace-capture-helper
/(usr/sbin/dhclient
lsb_release
man_filter
man_groff
named
nvidia_modprobe
nvidia_modprobe//kmod
passt
plasmashell
plasmashell//QtWebEngineProcess
rsyslogd
ttthavapalan@jumpbox-ssh2:~$ _
```

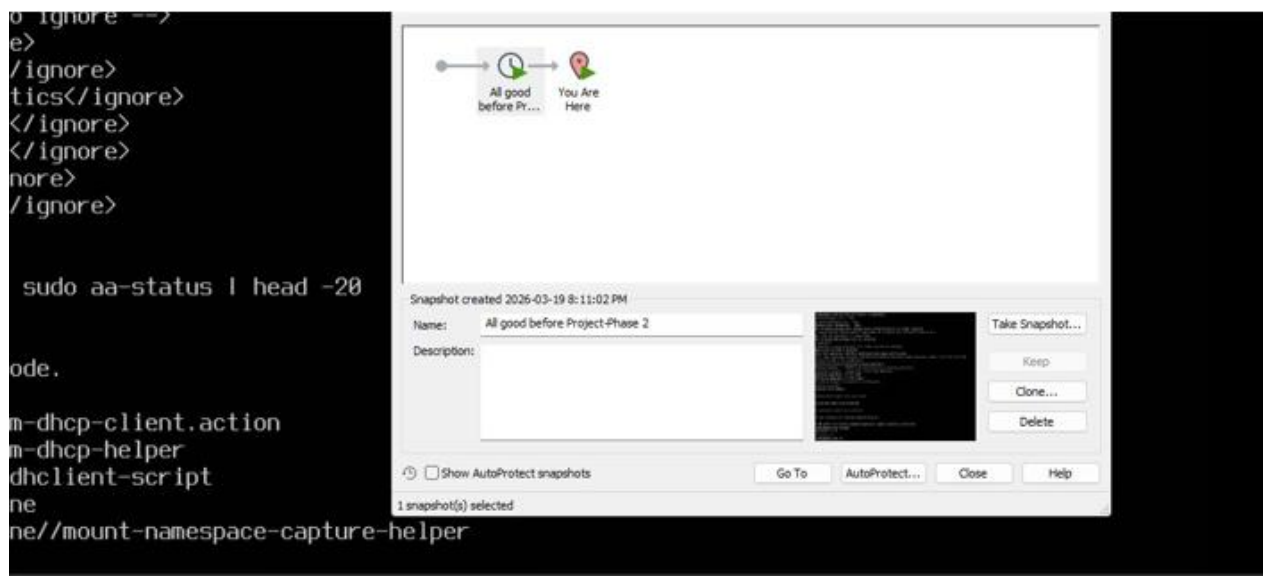


10.5 - AppArmor 30 Profiles Enforced

Control 11 Data Recovery

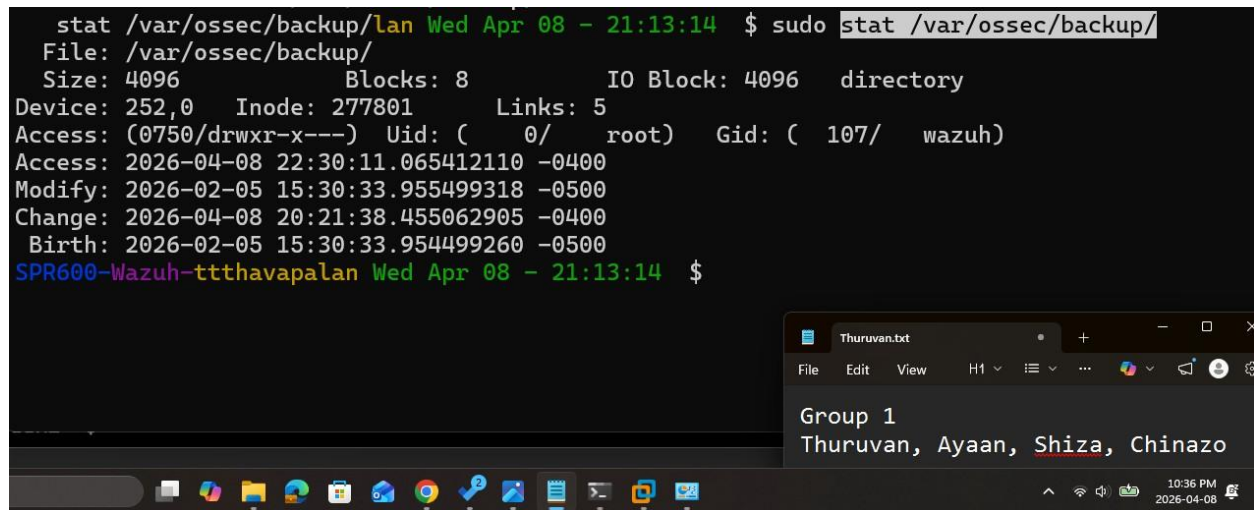
Data recovery capability is implemented through VMware snapshot management across all lab VMs stored on the host filesystem at E:\Semester 5, isolated from guest OS filesystems. Wazuh maintains configuration backups at /var/ossec/backup/ with subdirectories for agents, db, and shared, owned by root:wazuh with permissions 0750. The recovery process was validated during Phase 2 when a T1070.004 Atomic Red Team test destroyed jumpbox-ssh binaries, requiring a full VM restore from snapshot.

VMware Snapshot Manager showing snapshots for all lab VMs alongside Wazuh /var/ossec/backup/ directory confirming agent and db backup subdirectories exist.



11.1 - VMware Snapshots and Wazuh Backup

/var/ossec/backup/ directory permissions confirmed as 0750 root:wazuh, inaccessible to unprivileged users, protecting recovery data.



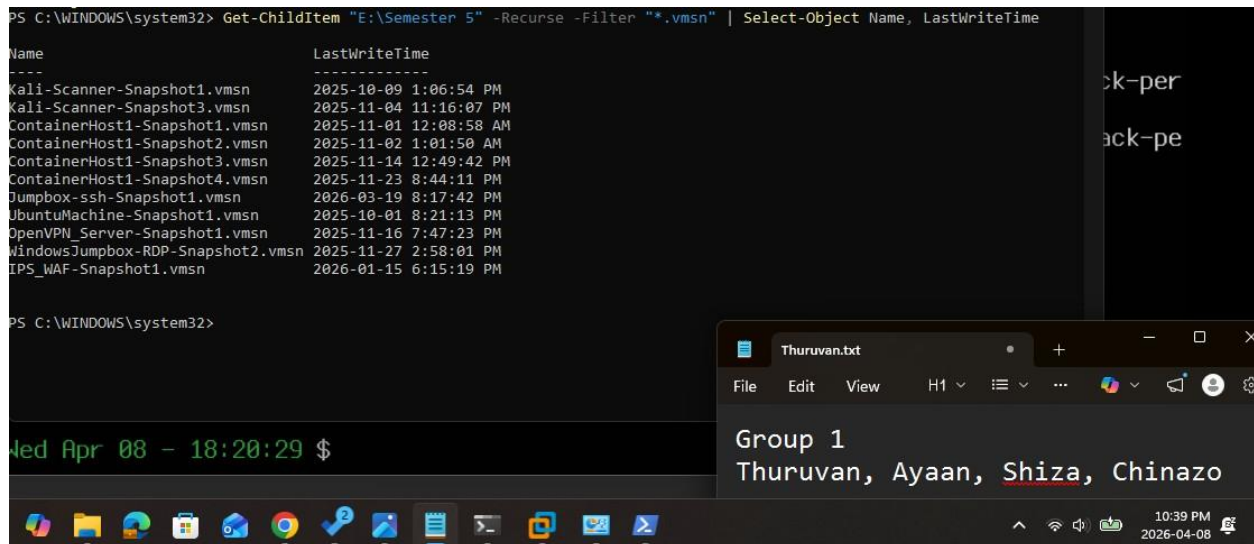
```

stat /var/ossec/backup/
File: /var/ossec/backup/
Size: 4096      Blocks: 8      IO Block: 4096   directory
Device: 252,0  Inode: 277801   Links: 5
Access: (0750/drwxr-x---)  Uid: (  0/   root)   Gid: (107/  wazuh)
Access: 2026-04-08 22:30:11.065412110 -0400
Modify: 2026-02-05 15:30:33.955499318 -0500
Change: 2026-04-08 20:21:38.455062905 -0400
Birth: 2026-02-05 15:30:33.954499260 -0500
SPR600-Wazuh-ttthavapalan Wed Apr 08 - 21:13:14 $

```

11.2 - Backup Directory Permissions

PowerShell enumeration of .vmxn snapshot files on E:\Semester 5 confirming isolated snapshot storage on the hypervisor host for all lab VMs including ContainerHost1, jumpbox-ssh, OpenVPN, and IPS-WAF.



```

PS C:\WINDOWS\system32> Get-ChildItem "E:\Semester 5" -Recurse -Filter "*.vmxn" | Select-Object Name, LastWriteTime
Name                                         LastWriteTime
-----
Kali-Scanner-Snapshot1.vmxn                2025-10-09 1:06:54 PM
Kali-Scanner-Snapshot3.vmxn                2025-11-04 11:16:07 PM
ContainerHost1-Snapshot1.vmxn              2025-11-01 12:08:58 AM
ContainerHost1-Snapshot2.vmxn              2025-11-02 1:01:50 AM
ContainerHost1-Snapshot3.vmxn              2025-11-14 12:49:42 PM
ContainerHost1-Snapshot4.vmxn              2025-11-23 8:44:11 PM
Jumpbox-ssh-Snapshot1.vmxn                 2026-03-19 8:17:42 PM
UbuntuMachine-Snapshot1.vmxn              2025-10-01 8:21:13 PM
OpenVPN_Server-Snapshot1.vmxn              2025-11-16 7:47:23 PM
WindowsJumpbox-RDP-Snapshot2.vmxn          2025-11-27 2:58:01 PM
IPS_WAF-Snapshot1.vmxn                    2026-01-15 6:15:19 PM

PS C:\WINDOWS\system32>

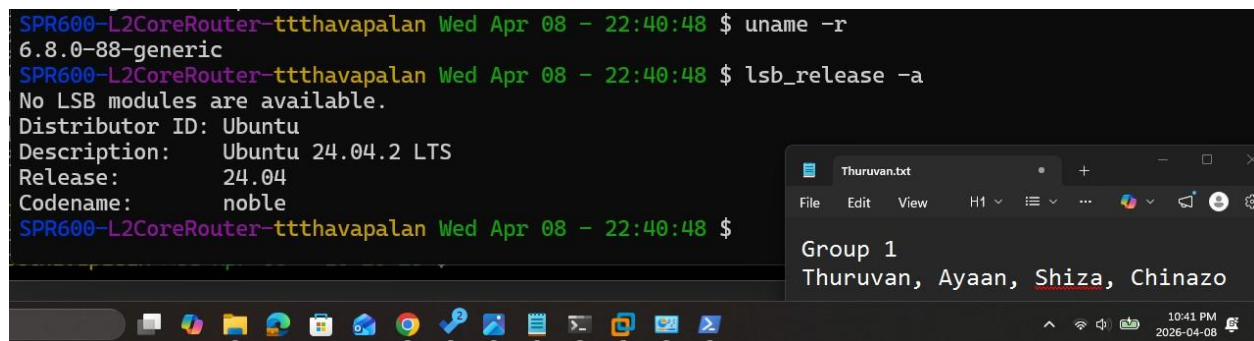
```

11.3 - Isolated Snapshot Storage

Control 12 Network Infrastructure Management

Network infrastructure management is implemented through a CoreRouter running Ubuntu 24.04.2 LTS enforcing VLAN segmentation across 13 distinct subnets via iptables with a default-DROP policy on all chains. Firewall rules are reboot-persistent via netfilterpersistent.service. Remote administrative access is provided exclusively through OpenVPN with AES-256-GCM and certificate plus Kerberos MFA. The Wazuh agent on CoreRouter maintains audit visibility over network infrastructure changes.

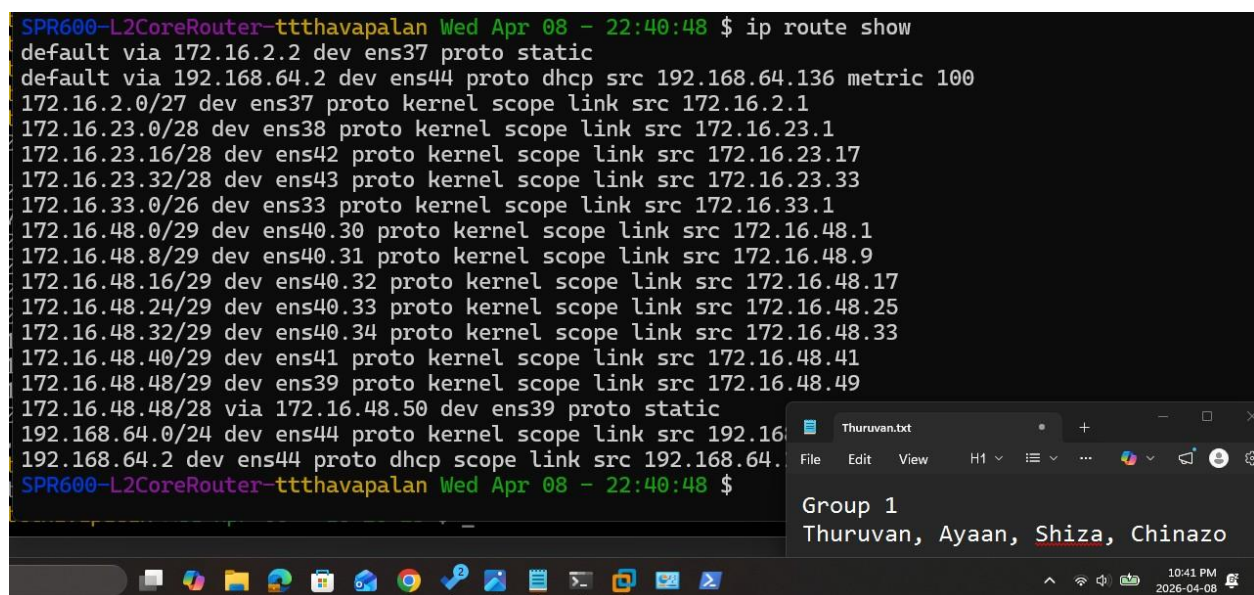
CoreRouter `uname -r` and `lsb_release -a` confirming Ubuntu 24.04.2 LTS kernel 6.8.0-88-generic, demonstrating up-to-date network infrastructure.



```
SPR600-L2CoreRouter-ttthavapalan Wed Apr 08 - 22:40:48 $ uname -r
6.8.0-88-generic
SPR600-L2CoreRouter-ttthavapalan Wed Apr 08 - 22:40:48 $ lsb_release -a
No LSB modules are available.
Distributor ID: Ubuntu
Description:    Ubuntu 24.04.2 LTS
Release:        24.04
Codename:       noble
SPR600-L2CoreRouter-ttthavapalan Wed Apr 08 - 22:40:48 $
```

12.1 - CoreRouter OS Version

`ip route show` confirming 13 active subnet routes across 7 VLANs on CoreRouter, with zonebased segmentation enforced via iptables with default-DROP.



```
SPR600-L2CoreRouter-ttthavapalan Wed Apr 08 - 22:40:48 $ ip route show
default via 172.16.2.2 dev ens37 proto static
default via 192.168.64.2 dev ens44 proto dhcp src 192.168.64.136 metric 100
172.16.2.0/27 dev ens37 proto kernel scope link src 172.16.2.1
172.16.23.0/28 dev ens38 proto kernel scope link src 172.16.23.1
172.16.23.16/28 dev ens42 proto kernel scope link src 172.16.23.17
172.16.23.32/28 dev ens43 proto kernel scope link src 172.16.23.33
172.16.33.0/26 dev ens33 proto kernel scope link src 172.16.33.1
172.16.48.0/29 dev ens40.30 proto kernel scope link src 172.16.48.1
172.16.48.8/29 dev ens40.31 proto kernel scope link src 172.16.48.9
172.16.48.16/29 dev ens40.32 proto kernel scope link src 172.16.48.17
172.16.48.24/29 dev ens40.33 proto kernel scope link src 172.16.48.25
172.16.48.32/29 dev ens40.34 proto kernel scope link src 172.16.48.33
172.16.48.40/29 dev ens41 proto kernel scope link src 172.16.48.41
172.16.48.48/29 dev ens39 proto kernel scope link src 172.16.48.49
172.16.48.48/28 via 172.16.48.50 dev ens39 proto static
192.168.64.0/24 dev ens44 proto kernel scope link src 192.168.64.1
192.168.64.2 dev ens44 proto dhcp scope link src 192.168.64.136
SPR600-L2CoreRouter-ttthavapalan Wed Apr 08 - 22:40:48 $
```

12.2 - Secure Network Architecture Routes

netfilter-persistent.service status showing active and enabled with iptables.service symlinked, confirming firewall rules survive reboots on CoreRouter.

```

sudo tail -f /var/log/kern.log | grep -E FORWARD-DROPTINPUT-DROPTOUTPUT-DROP
2>/dev/null || systemctl status netfilter-persistent29 $ systemctl status iptables-save
• netfilter-persistent.service - netfilter persistent configuration
  Loaded: loaded (/usr/lib/systemd/system/netfilter-persistent.service; enabled; preset: enabled)
  Drop-In: /usr/lib/systemd/system/netfilter-persistent.service.d
           └─iptables.conf
  Active: active (exited) since Wed 2026-04-08 18:18:45 EDT; 4h 23min ago
  Docs: man:netfilter-persistent(8)
  Main PID: 761 (code=exited, status=0/SUCCESS)
  CPU: 23ms

Apr 08 18:18:45 CoreRouter systemd[1]: Starting netfilter-persistent.service - netfilter persistent configuration...
Apr 08 18:18:45 CoreRouter netfilter-persistent[770]: run-parts: executing /usr/share/netfilter-persistent/plugins.
Apr 08 18:18:45 CoreRouter netfilter-persistent[770]: run-parts: executing /usr/share/netfilter-persistent/plugins.
Apr 08 18:18:45 CoreRouter systemd[1]: Finished netfilter-persistent.service - netfilter persistent configuration.
rep iptablesRouter-ttthavapalan Wed Apr 08 - 18:20:29 $ ls -lh /etc/systemd/system/ | g
-rw-r--r-- 1 root root 490 Oct 30 14:49 iptables-restore-late.service
lrwxrwxrwx 1 root root 52 Oct 28 18:15 iptables.service -> /usr/lib/systemd/system/netfilter-persistent.service
SPR600-L2CoreRouter-ttthavapalan Wed Apr 08 - 18:20:29 $
SPR600-L2CoreRouter-ttthavapalan Wed Apr 08 - 18:20:29 $
SPR600-L2CoreRouter-ttthavapalan Wed Apr 08 - 18:20:29 $
SPR600-L2CoreRouter-ttthavapalan Wed Apr 08 - 18:20:29 $
SPR600-L2CoreRouter-ttthavapalan Wed Apr 08 - 18:20:29 $

```

12.3 - Firewall Rules Reboot Persistent

OpenVPN service enabled and active on vpn host with AES-256-GCM and Wazuh agent listening on port 1514, confirming secure network management and communication protocols.

```

Active: active (running) since Wed 2026-04-08 18:20:31 EDT; 4h 24min ago
Process: 1382 ExecStart=/usr/bin/env /var/ossec/bin/wazuh-control start (code=exited, status=0/SUCCESS)
Tasks: 32 (limit: 2132)
Memory: 459.7M (peak: 466.5M)
CPU: 22.492s
CGroup: /system.slice/wazuh-agent.service
├─1431 /var/ossec/bin/wazuh-execd
├─1441 /var/ossec/bin/wazuh-agentd
├─1454 /var/ossec/bin/wazuh-syscheckd
├─1464 /var/ossec/bin/wazuh-logcollector
└─1479 /var/ossec/bin/wazuh-modulesd

Apr 08 18:20:16 vpn systemd[1]: Starting wazuh-agent.service - Wazuh agent...
Apr 08 18:20:21 vpn env[1382]: Starting Wazuh v4.14.2...
Apr 08 18:20:22 vpn env[1382]: Started wazuh-execd...
Apr 08 18:20:28 vpn env[1382]: Started wazuh-agentd...
Apr 08 18:20:28 vpn env[1382]: Started wazuh-syscheckd...
Apr 08 18:20:28 vpn env[1382]: Started wazuh-logcollector...
Apr 08 18:20:29 vpn env[1382]: Started wazuh-modulesd...
Apr 08 18:20:31 vpn env[1382]: Completed.
Apr 08 18:20:31 vpn systemd[1]: Started wazuh-agent.service - Wazuh agent.
ttthavapalan@vpn:~$ systemctl status openvpn
• openvpn.service - OpenVPN service
  Loaded: loaded (/usr/lib/systemd/system/openvpn.service; enabled; preset: enabled)
  Active: active (exited) since Wed 2026-04-08 18:18:18 EDT; 4h 26min ago
  Docs: man:openvpn(8)
  Process: 1299 ExecStart=/bin/true (code=exited, status=0/SUCCESS)
  Main PID: 1299 (code=exited, status=0/SUCCESS)
  CPU: 5ms

Apr 08 18:18:18 vpn systemd[1]: Starting openvpn.service - OpenVPN service...
Apr 08 18:18:18 vpn systemd[1]: Finished openvpn.service - OpenVPN service.
ttthavapalan@vpn:~$ _

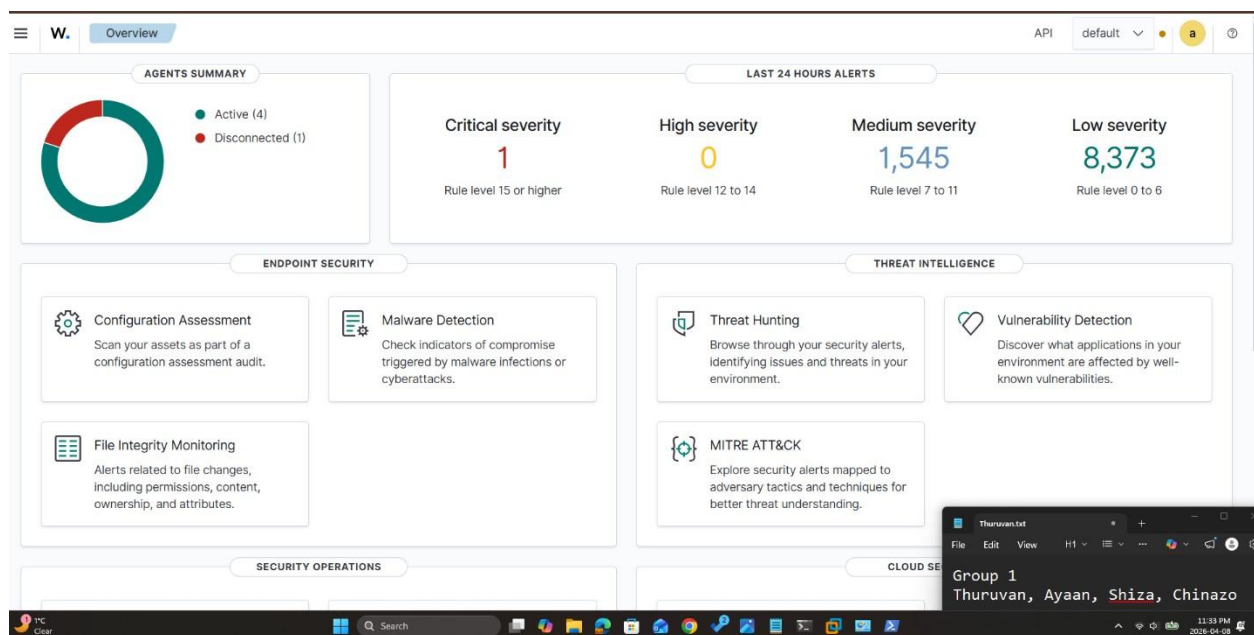
```

12.4 - VPN and Wazuh Agent Ports

Control 13 Network Monitoring and Defense

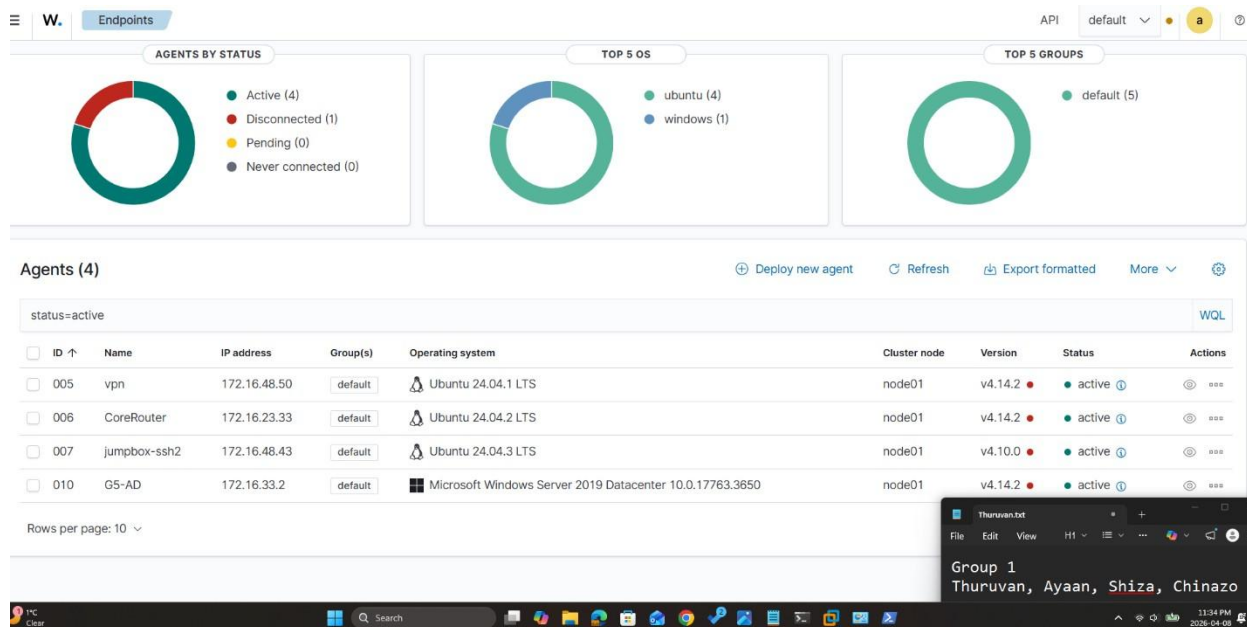
Network monitoring is implemented through a layered stack: Wazuh with OpenSearch provides centralized SIEM alerting across all enrolled agents; Suricata 7.0.3 and Zeek run on CoreRouter monitoring the VLAN trunk and three additional interfaces; AppArmor enforces 30 mandatory access control profiles on jumpbox-ssh2; and ModSecurity WAF operates in blocking mode with the OWASP CRS loaded. Inter-VLAN traffic filtering is enforced by iptables with a defaultDROP policy on both INPUT and FORWARD chains.

Wazuh Overview dashboard showing 24-hour alert totals across all severity bands and enrolled agents, confirming centralized security event alerting.



13.1a - Centralized Security Event Alerting

Wazuh Endpoints panel confirming agents vpn-005, CoreRouter-006, jumpbox-ssh2-007, and G5-AD-010 in active status.



13.1b - Active Agents on Wazuh

GS-AD PowerShell confirmation of Sysmon64 running with a live Event ID 11 file creation record tagged to MITRE T1574.010, confirming host-based intrusion detection is operational.

```
PS C:\Users\Administrator> Get-Service Sysmon64

Status Name          DisplayName
-----
Running Sysmon64      Sysmon64

PS C:\Users\Administrator> Get-WinEvent -LogName "Microsoft-Windows-Sysmon/Operational" -MaxEvents 5 | Select-Object TimeCreated, Id, Message | Format-List

TimeCreated : 4/8/2026 11:37:08 PM
Id           : 11
Message      : File created:
               RuleName: technique_id=T1574.010,technique_name=Services File Permissions Weakness
               UtcTime: 2026-04-09 03:37:08.428
               ProcessGuid: {1a2f397d-0890-69d7-1c00-000000003300}
               ProcessId: 1296
               Image: C:\Windows\System32\svchost.exe
```

13.2a - Sysmon Active on AD

Sysmon rule files and syscheck configuration loaded on the Wazuh Manager confirming HIDS deployment across the environment.

```

/var/ossec/ruleset/rules/0800-sysmon_id_1.xml: <if_group>sysmon_event1</if_group>
/var/ossec/ruleset/rules/0800-sysmon_id_1.xml: </if_group>sysmon_event1</if_group>
/var/ossec/ruleset/rules/0800-sysmon_id_1.xml: <if_group>sysmon_event1</if_group>
/var/ossec/ruleset/rules/0800-sysmon_id_1.xml: </if_group>sysmon_event1</if_group>
/var/ossec/ruleset/rules/0800-sysmon_id_1.xml: <if_group>sysmon_event1</if_group>
/var/ossec/ruleset/rules/0800-sysmon_id_1.xml: </if_group>sysmon_event1</if_group>
/var/ossec/ruleset/rules/0800-sysmon_id_1.xml: <if_group>sysmon_event1</if_group>
/var/ossec/ruleset/rules/0800-sysmon_id_1.xml: </if_group>sysmon_event1</if_group>
/var/ossec/ruleset/rules/0800-sysmon_id_1.xml: <if_group>sysmon_event1</if_group>
/var/ossec/ruleset/rules/0800-sysmon_id_1.xml: </if_group>sysmon_event1</if_group>
/var/ossec/ruleset/rules/0800-sysmon_id_1.xml: <if_group>sysmon_event1</if_group>
/var/ossec/ruleset/rules/0800-sysmon_id_1.xml: </if_group>sysmon_event1</if_group>
/var/ossec/ruleset/rules/0800-sysmon_id_1.xml: <if_group>sysmon_event1</if_group>
/var/ossec/ruleset/rules/0800-sysmon_id_1.xml: </if_group>sysmon_event1</if_group>
/var/ossec/ruleset/rules/0800-sysmon_id_1.xml: <if_group>sysmon_event1</if_group>
/var/ossec/ruleset/rules/0800-sysmon_id_1.xml: </if_group>sysmon_event1</if_group>
/var/ossec/ruleset/rules/0810-sysmon_id_3.xml: <group name="sysmon,sysmon_eid3_detections,windows,">
/var/ossec/ruleset/rules/0810-sysmon_id_3.xml: <if_group>sysmon_event3</if_group>
/var/ossec/ruleset/rules/0810-sysmon_id_3.xml: </if_group>sysmon_event3</if_group>
/var/ossec/ruleset/rules/0810-sysmon_id_3.xml: <if_group>sysmon_event3</if_group>
/var/ossec/ruleset/rules/0810-sysmon_id_3.xml: </if_group>sysmon_event3</if_group>
/var/ossec/ruleset/rules/0810-sysmon_id_3.xml: <if_group>sysmon_event3</if_group>
/var/ossec/ruleset/rules/0810-sysmon_id_3.xml: </if_group>sysmon_event3</if_group>
/var/ossec/ruleset/rules/0820-sysmon_id_7.xml: <group name="sysmon,sysmon_eid7_detections,windows,">
/var/ossec/ruleset/rules/0820-sysmon_id_7.xml: <if_group>sysmon_event7</if_group>
/var/ossec/ruleset/rules/0820-sysmon_id_7.xml: </if_group>sysmon_event7</if_group>
/var/ossec/ruleset/rules/0820-sysmon_id_7.xml: <if_group>sysmon_event7</if_group>
/var/ossec/ruleset/rules/0820-sysmon_id_7.xml: </if_group>sysmon_event7</if_group>
/var/ossec/ruleset/rules/0820-sysmon_id_7.xml: <if_group>sysmon_event7</if_group>
/var/ossec/ruleset/rules/0820-sysmon_id_7.xml: </if_group>sysmon_event7</if_group>
/var/ossec/ruleset/rules/0820-sysmon_id_7.xml: <if_group>sysmon_event7</if_group>
/var/ossec/ruleset/rules/0820-sysmon_id_7.xml: </if_group>sysmon_event7</if_group>
SPR600-Wazuh-ttthavapalan Wed Apr 08 - 21:13:14 $ sudo grep -A5 "<syscheck>" /var/ossec/etc/ossec.conf | head -30
<syscheck>
<disabled>no</disabled>

<!-- Frequency that syscheck is executed default every 12 hours -->
<frequency>43200</frequency>
SPR600-Wazuh-ttthavapalan Wed Apr 08 - 21:13:14 $

```

13.2b - Wazuh FIM and Sysmon Rules

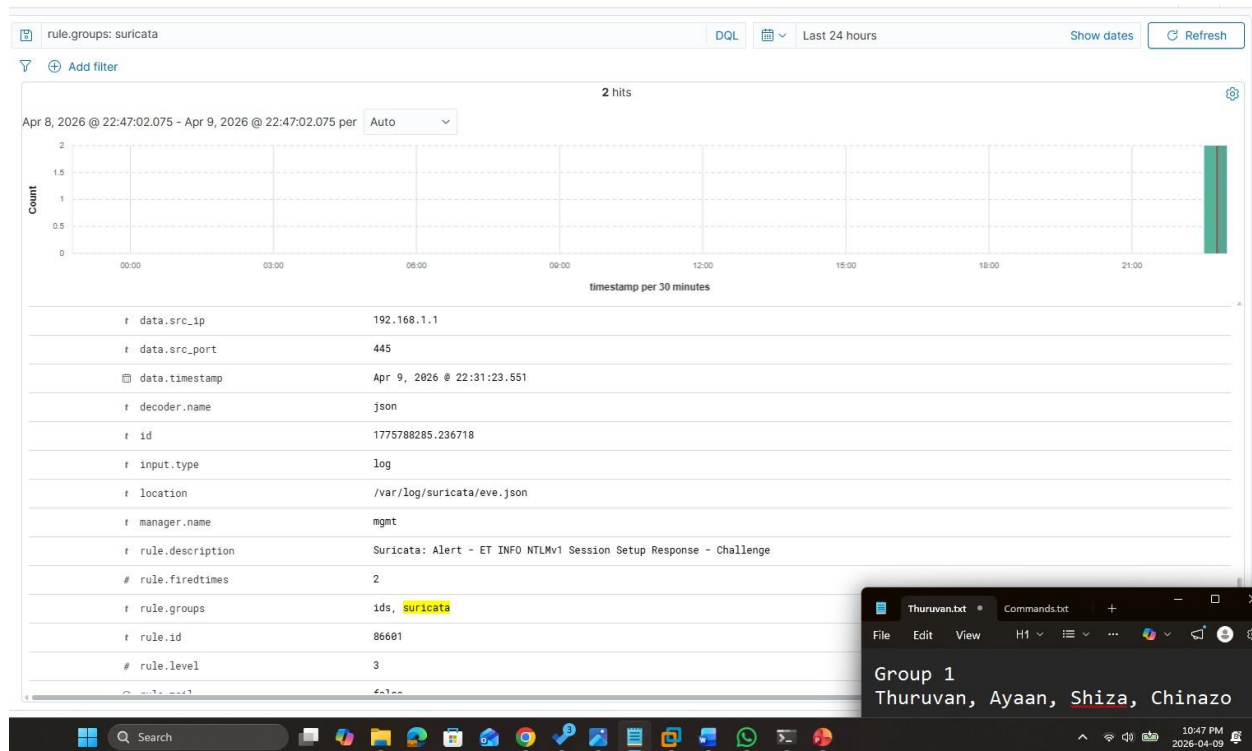
Suricata 7.0.3 active on CoreRouter with the IDS/IDP daemon running across interfaces ens40, ens33, ens38, and ens39, confirming network intrusion detection coverage.

```
SPR600-L2CoreRouter-ttthavapalan Thu Apr 09 - 21:24:52 $ sudo systemctl status suricata --no-pager
[sudo] password for ttthavapalan:
● suricata.service - Suricata IDS/IDP daemon
   Loaded: loaded (/usr/lib/systemd/system/suricata.service; enabled; preset: enabled)
   Active: active (running) since Thu 2026-04-09 21:06:49 EDT; 1h 37min ago
     Docs: man:suricata(8)
           man:suricatasc(8)
           https://suricata.io/documentation/
   Main PID: 14765 (Suricata-Main)
     Tasks: 14 (Limit: 9379)
    Memory: 548.7M (peak: 549.2M)
       CPU: 1min 13.364s
    CGroup: /system.slice/suricata.service
            └─14765 /usr/bin/suricata -D --af-packet -c /etc/suricata/suricata.yaml --pidfile /run/suricata.pid

Apr 09 21:06:49 CoreRouter systemd[1]: Starting suricata.service - Suricata IDS/IDP daemon...
Apr 09 21:06:49 CoreRouter suricata[14764]: i: suricata: This is Suricata version 7.0.3 RELEASE running in SYS
Apr 09 21:06:49 CoreRouter systemd[1]: Started suricata.service - Suricata IDS/IDP daemon.
udo tail -20 /var/log/suricata/eve.json | python3 -m json.tool | head -40ar/log/suricata/eve.json | python3 -m
Extra data: line 2 column 1 (char 331)
SPR600-L2CoreRouter-ttthavapalan Thu Apr 09 - 21:24:52 $
```

13.3a - Suricata Running on CoreRouter

OpenSearch event confirming a live Suricata alert ingested from /var/log/suricata/eve.json via CoreRouter agent 006, demonstrating end-to-end NIDS alert pipeline.



13.3b - Suricata Alert in OpenSearch

CoreRouter iptables INPUT and FORWARD chains with default-DROP policy, SYNPROXY rules, bogon drops, and LOG entries confirming inter-VLAN traffic filtering.

```
Chain INPUT (policy DROP 3 packets, 156 bytes)
  pkts bytes target   prot opt in     out     source               destination
  10  3070 ACCEPT  0  --  *      *       0.0.0.0/0            0.0.0.0/0            ctstate RELATED,ESTABLISHED
  30  2282 ACCEPT  0  --  lo     *       0.0.0.0/0            0.0.0.0/0
  0    0 ACCEPT  6  --  *      *       172.16.48.0/29        0.0.0.0/0            tcp dpt:443
  0    0 ACCEPT  6  --  *      *       172.16.23.16/28       0.0.0.0/0            tcp dpt:22
  0    0 ACCEPT  89  -- ens37 *      *       0.0.0.0/0            0.0.0.0/0            multiport dports 67,68 matc
  0    0 ACCEPT  17  --  *      *       0.0.0.0/0            0.0.0.0/0
  h-set INTERNAL_SUBNETS src limit: avg 5/min burst 10
  3  156 LOG    0  --  *      *       0.0.0.0/0            0.0.0.0/0            LOG flags 0 level 4 prefix
"INPUT-DROP: "
  0    0 DROP    0  --  ens37 *      *       10.0.0.0/8           0.0.0.0/0
  0    0 DROP    0  --  ens37 *      *       192.168.0.0/16       0.0.0.0/0
  0    0 DROP    0  --  ens37 *      *       127.0.0.0/8          0.0.0.0/0
  0    0 DROP    0  --  ens37 *      *       169.254.0.0/16       0.0.0.0/0
  0    0 DROP    0  --  ens37 *      *       224.0.0.0/4          0.0.0.0/0

Chain FORWARD (policy DROP 22 packets, 1200 bytes)
  pkts bytes target   prot opt in     out     source               destination
  0    0 SYNPROXY 6  --  *      *       0.0.0.0/0            172.16.48.0/29        tcp dpt:80 ctstate INVALID,
UNTRACKED SYNPROXY sack-perm timestamp wscale 7 mss 1460
  0    0 SYNPROXY 6  --  *      *       0.0.0.0/0            172.16.48.0/29        tcp dpt:443 ctstate INVALID
,UNTRACKED SYNPROXY sack-perm timestamp wscale 7 mss 1460
  0    0 ACCEPT  6  --  *      *       0.0.0.0/0            172.16.48.0/29        tcp dpt:80 ctstate UNTRACKE
D
  0    0 ACCEPT  6  --  *      *       0.0.0.0/0            172.16.48.0/29        tcp dpt:443 ctstate UNTRACK
ED
  39 21472 DROP    0  --  *      *       0.0.0.0/0            0.0.0.0/0            ctstate INVALID
  25 5655 ACCEPT  0  --  *      *       0.0.0.0/0            0.0.0.0/0            ctstate RELATED,ESTABLISHED
  0    0 ACCEPT  6  --  *      *       0.0.0.0/0            172.16.48.0/29        tcp dpt:80 ctstate NEW
  0    0 ACCEPT  6  --  *      *       0.0.0.0/0            172.16.48.0/29        tcp dpt:443 ctstate NEW
  0    0 DROP    0  --  ens37 *      *       0.0.0.0/0            255.255.255.255
  0    0 DROP    0  --  ens37 *      *       0.0.0.0/0            224.0.0.0/4
  0    0 ACCEPT  6  --  *      *       172.16.23.16/28       0.0.0.0/0
dst tcp dpt:22 ctstate NEW,ESTABLISHED
:-
```

13.4 - Default Drop and Forward Rules

OpenVPN service status confirming active state with AES-256-GCM cipher and RADIUS MFA plugin, managing access control for remote assets.

```
tthavapalan@vpn:~$ sudo systemctl status openvpn-server@server --no-pager
• openvpn-server@server.service - OpenVPN service for server
   Loaded: loaded (/usr/lib/systemd/system/openvpn-server@.service; enabled; preset: enabled)
   Active: active (running) since Thu 2026-04-09 22:33:25 EDT; 19min ago
     Docs: man:openvpn(8)
           https://openvpn.net/community-resources/reference-manual-for-openvpn-2-6/
           https://community.openvpn.net/openvpn/wiki/HOWTO
   Main PID: 1378 (openvpn)
   Status: "Initialization Sequence Completed"
    Tasks: 3 (limit: 2132)
  Memory: 3.9M (peak: 4.1M)
     CPU: 140ms
   CGroup: /system.slice/system-openvpn.slice/system-openvpn-server@server.service
           └─1378 /usr/sbin/openvpn --status /run/openvpn-server/status-server.log --status-version 2 -...
             └─1394 /usr/sbin/openvpn --status /run/openvpn-server/status-server.log --status-version 2 -...
               └─1395 /usr/sbin/openvpn --status /run/openvpn-server/status-server.log --status-version 2 -...

Apr 09 22:33:25 vpn systemd[1]: Starting openvpn-server@server.service - OpenVPN service for server...
Apr 09 22:33:25 vpn systemd[1]: Started openvpn-server@server.service - OpenVPN service for server.
tthavapalan@vpn:~$ sudo grep -E "cipher|auth|tls|plugin|lmpam|lkrb" /etc/openvpn/server/server.conf
plugin /usr/lib/openvpn/radiusplugin.so /etc/openvpn/radiusplugin.cnf
#auth-user-pass
tls-auth ta.key 0
cipher AES-256-GCM
auth SHA256
tls-verify /etc/openvpn/server/check_intermediate.sh
tthavapalan@vpn:~$
```

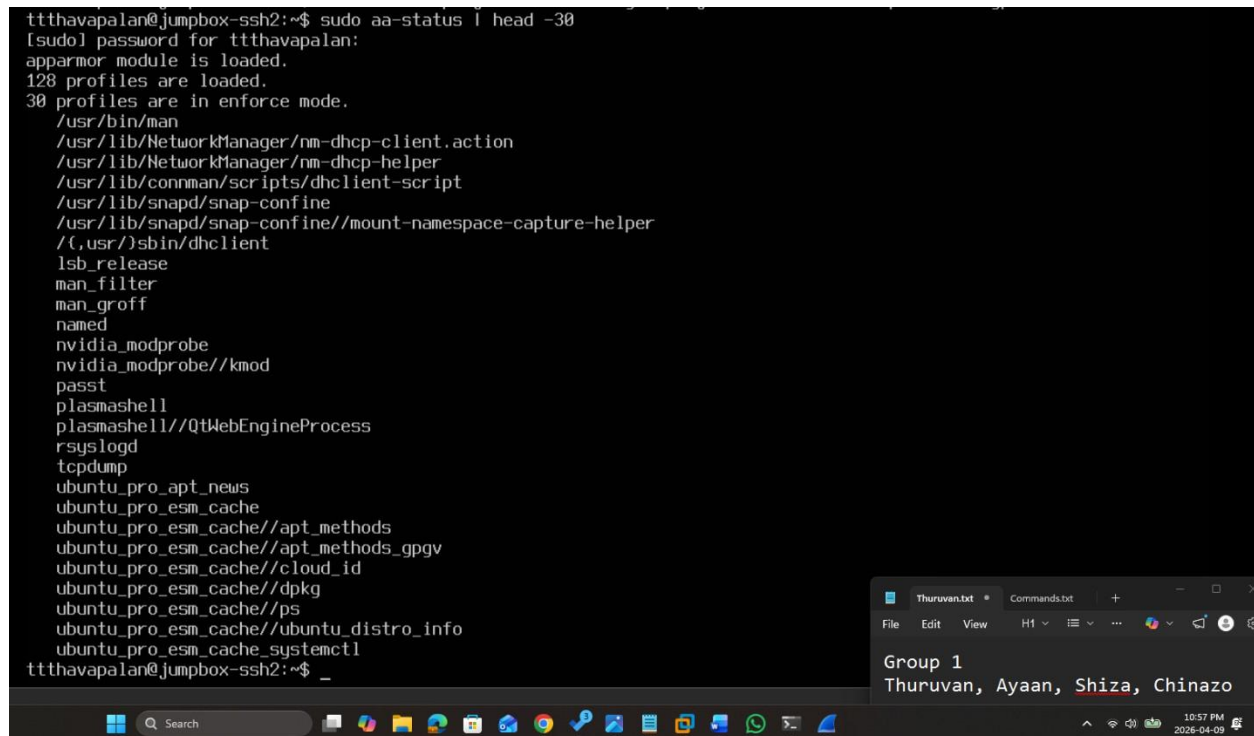
13.5 - OpenVPN Status and Cipher

zeekctl status with all four workers running on ens40, ens33, ens38, and ens39, alongside /opt/zeek/logs/current/ directory confirming active network traffic flow log generation.

```
SPR600-L2CoreRouter-tthavapalan Thu Apr 09 - 23:08:14 $ sudo zeekctl status
Warning: zeekctl option UseWebSocket is set, but websockets non-functional: Failed to import websockets module - is it installed? (ModuleNotFound
Error("No module named 'websockets.sync'"))
Name      Type      Host      Status    Pid      Started
logger    logger    localhost running    5082     09 Apr 23:09:28
manager    manager   localhost running    5192     09 Apr 23:09:29
proxy-1    proxy     localhost running    5254     09 Apr 23:09:31
worker-ens40 worker    localhost running    5353     09 Apr 23:09:32
worker-ens33 worker    localhost running    5348     09 Apr 23:09:32
worker-ens38 worker    localhost running    5352     09 Apr 23:09:32
worker-ens39 worker    localhost running    5351     09 Apr 23:09:32
SPR600-L2CoreRouter-tthavapalan Thu Apr 09 - 23:08:14 $ ls -lh /opt/zeek/logs/current/
ls: cannot access '/opt/zeek/logs/current/': Permission denied
SPR600-L2CoreRouter-tthavapalan Thu Apr 09 - 23:08:14 $ sudo ls -lh /opt/zeek/logs/current/
total 460K
-rw-r--r-- 1 root zeek 405 Apr 9 23:10 capture_loss.log
-rw-r--r-- 1 root zeek 4.5K Apr 9 23:09 cluster.log
-rw-r--r-- 1 root zeek 1.7K Apr 9 23:10 conn.log
-rw-r--r-- 1 root zeek 2.2K Apr 9 23:10 dns.log
-rw-r--r-- 1 root zeek 240 Apr 9 23:10 known_services.log
-rw-r--r-- 1 root zeek 240K Apr 9 23:09 loaded_scripts.log
-rw-r--r-- 1 root zeek 1.4K Apr 9 23:10 notice.log
-rw-r--r-- 1 root zeek 409 Apr 9 23:09 packet_filter.log
-rw-r--r-- 1 root zeek 1005 Apr 9 23:09 stats.log
-rw-r--r-- 1 root zeek 0 Apr 9 23:09 stderr.log
-rw-r--r-- 1 root zeek 204 Apr 9 23:09 stdout.log
-rw-r--r-- 1 root zeek 174K Apr 9 23:10 telemetry.log
-rw-r--r-- 1 root zeek 371 Apr 9 23:10 weird.log
SPR600-L2CoreRouter-tthavapalan Thu Apr 09 - 23:08:14 $ sudo tail -5 /opt/zeek/logs/current/conn.log
1775790612.761341 C1VRVJINQVehUtd3 192.168.1.2 138 192.168.1.255 138 udp - - - S0 T
0 D 229 0 17
1775790663.325265 CROISM1TyR8WgpN3f2 172.16.33.2 60899 192.203.230.10 53 udp dns - - - S0 T
0 D 73 0 17
1775790663.325266 CX7YD60eqtiAW6WE1 172.16.33.2 61146 1.1.1.1 53 udp dns - - -
0 D 73 0 17
1775790664.622294 CMSJLz3Mc0k7f5yyV1 172.16.33.2 60789 1.1.1.1 53 udp dns - - -
0 D 73 0 17
```

13.6 - Zeek Running and Logs

AppArmor aa-status output on jumpbox-ssh2 confirming 30 profiles in enforce mode, providing host-based intrusion prevention.



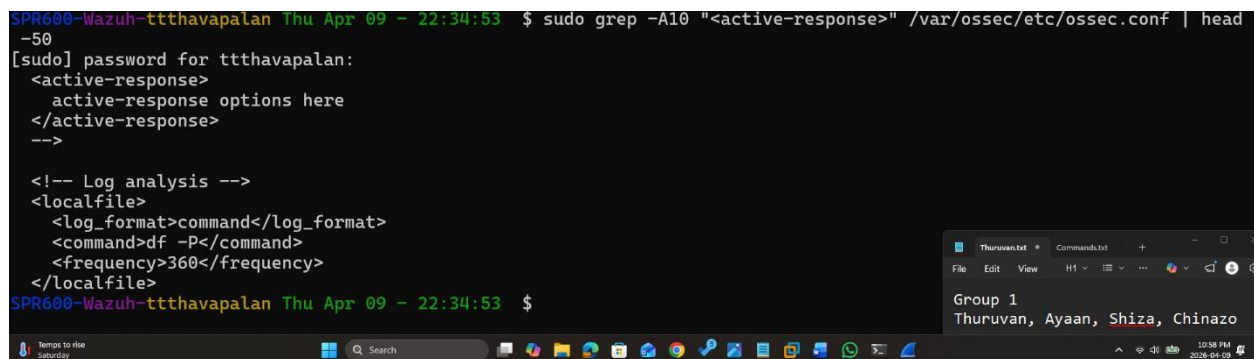
```

ttthavapalan@jumpbox-ssh2:~$ sudo aa-status | head -30
[sudo] password for ttthavapalan:
apparmor module is loaded.
128 profiles are loaded.
30 profiles are in enforce mode.
  /usr/bin/man
  /usr/lib/NetworkManager/nm-dhcp-client.action
  /usr/lib/NetworkManager/nm-dhcp-helper
  /usr/lib/connman/scripts/dhclient-script
  /usr/lib/snapd/snap-confine
  /usr/lib/snapd/snap-confine/mount-namespace-capture-helper
  /usr/sbin/dhclient
  lsb_release
  man_filter
  man_groff
  named
  nvidia_modprobe
  nvidia_modprobe//kmod
  passt
  plasmashell
  plasmashell//QtWebEngineProcess
  rsyslogd
  tcpdump
  ubuntu_pro_apt_news
  ubuntu_pro_esm_cache
  ubuntu_pro_esm_cache//apt_methods
  ubuntu_pro_esm_cache//apt_methods_gpgv
  ubuntu_pro_esm_cache//cloud_id
  ubuntu_pro_esm_cache//dpkg
  ubuntu_pro_esm_cache//ps
  ubuntu_pro_esm_cache//ubuntu_distro_info
  ubuntu_pro_esm_cache_systemctl
ttthavapalan@jumpbox-ssh2:~$

```

13.7a - AppArmor 30 Profiles

ossec.conf active-response block showing block_etsblue, block_attacker, isolate_beachhead, and firewall-drop commands configured on the Wazuh Manager, confirming automated hostlevel containment capability.



```

SPR600-Wazuh-ttthavapalan Thu Apr 09 - 22:34:53 $ sudo grep -A10 "<active-response>" /var/ossec/etc/ossec.conf | head -50
-50
[sudo] password for ttthavapalan:
<active-response>
  active-response options here
</active-response>
-->

<!-- Log analysis -->
<localfile>
  <log_format>command</log_format>
  <command>df -P</command>
  <frequency>360</frequency>
</localfile>
SPR600-Wazuh-ttthavapalan Thu Apr 09 - 22:34:53 $

```

13.7b - Active Response Commands Configured

CoreRouter iptables FORWARD chain with SYNPROXY rules applied to ports 80 and 443 destined for the container zone, providing SYN flood mitigation.

```
Chain FORWARD (policy DROP 0 packets, 0 bytes)
  pkts bytes target     prot opt in     out     source               destination
  0      0 SYNPROXY  6  --  *      *       0.0.0.0/0           172.16.48.0/29      tcp dpt:80 ctstate INVALID,
UNTRACKED SYNPROXY sack-perm timestamp wscale 7 mss 1460
  0      0 SYNPROXY  6  --  *      *       0.0.0.0/0           172.16.48.0/29      tcp dpt:443 ctstate INVALID
,UNTRACKED SYNPROXY sack-perm timestamp wscale 7 mss 1460
  0      0 ACCEPT    6  --  *      *       0.0.0.0/0           172.16.48.0/29      tcp dpt:80 ctstate UNTRACKE
D
  0      0 ACCEPT    6  --  *      *       0.0.0.0/0           172.16.48.0/29      tcp dpt:443 ctstate UNTRACK
ED
  20 6344 DROP      0  --  *      *       0.0.0.0/0           0.0.0.0/0           ctstate INVALID
  0      0 ACCEPT    0  --  *      *       0.0.0.0/0           0.0.0.0/0           ctstate RELATED,ESTABLISHED
  0      0 ACCEPT    6  --  *      *       0.0.0.0/0           172.16.48.0/29      tcp dpt:80 ctstate NEW
  0      0 ACCEPT    6  --  *      *       0.0.0.0/0           172.16.48.0/29      tcp dpt:443 ctstate NEW
  0      0 DROP      0  --  ens37 *      *       0.0.0.0/0           255.255.255.255
  0      0 DROP      0  --  ens37 *      *       0.0.0.0/0           224.0.0.0/4
  0      0 ACCEPT    6  --  *      *       172.16.23.16/28     0.0.0.0/0
dst tcp dpt:22 ctstate NEW,ESTABLISHED
:
```

13.8a - SYNPROXY Rules Active

ModSecurity SecRuleEngine On and SecDefaultAction deny,status:403 on CONT, establishing WAF blocking mode as a network intrusion prevention solution at the application layer.

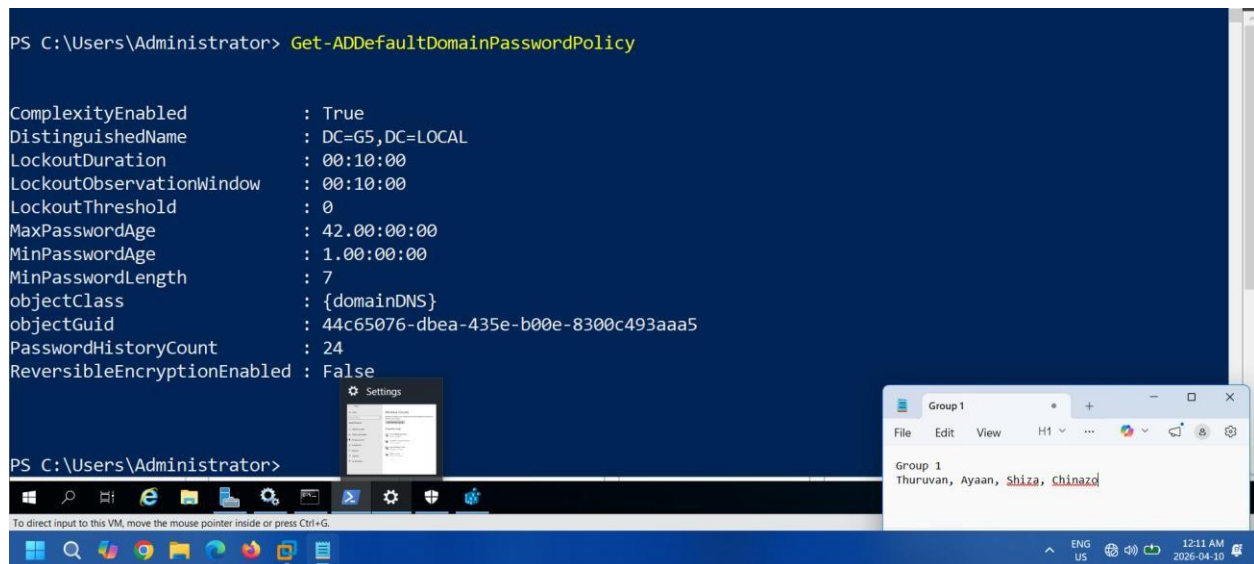
```
g5@CONT:~$ sudo grep -r "SecRuleEngine\|SecDefaultAction" /etc/nginx/modsecurity/ 2>/dev/null || \
> sudo grep -r "SecRuleEngine\|SecDefaultAction" /etc/modsecurity/ 2>/dev/null
/etc/modsecurity/crs/RESPONSE-999-EXCLUSION-RULES-AFTER-CRS.conf:# actions specified in SecDefaultAction (
setup.conf) with a 'deny' action.
/etc/modsecurity/crs/crs-setup.conf:# ModSecurity settings (modsecurity.conf) such as SecRuleEngine,
/etc/modsecurity/crs/crs-setup.conf:SecDefaultAction "phase:1,log,auditlog,pass"
/etc/modsecurity/crs/crs-setup.conf:SecDefaultAction "phase:2,log,auditlog,pass"
/etc/modsecurity/crs/crs-setup.conf:# SecDefaultAction "phase:1,nolog,auditlog,pass"
/etc/modsecurity/crs/crs-setup.conf:# SecDefaultAction "phase:2,nolog,auditlog,pass"
/etc/modsecurity/crs/crs-setup.conf:# SecDefaultAction "phase:1,log,auditlog,deny,status:403"
/etc/modsecurity/crs/crs-setup.conf:# SecDefaultAction "phase:2,log,auditlog,deny,status:403"
/etc/modsecurity/crs/crs-setup.conf:# SecDefaultAction "phase:1,log,auditlog
aders.host)"/',tag:'Host: %{request_headers.host}""
/etc/modsecurity/crs/crs-setup.conf:# SecDefaultAction "phase:2,log,auditlog
aders.host)"/',tag:'Host: %{request_headers.host}""
g5@CONT:~$
```

13.8b - ModSecurity Blocking Mode

Control 14 — Security Awareness and Skills Training

No formal security awareness program exists in the lab environment, which is an acknowledged gap consistent with a student laboratory deployment. Technical compensating controls operationalize the outcomes of awareness training: AD enforces password complexity and history requirements, and unattended-upgrades automates patch currency. Safeguards 14.1, 14.2, and 14.4 through 14.6 are documented gaps.

Get-ADDefaultDomainPasswordPolicy output on GS-AD confirming complexity enforcement, 24-password history, and 42-day maximum age, operationalizing authentication best practice outcomes.



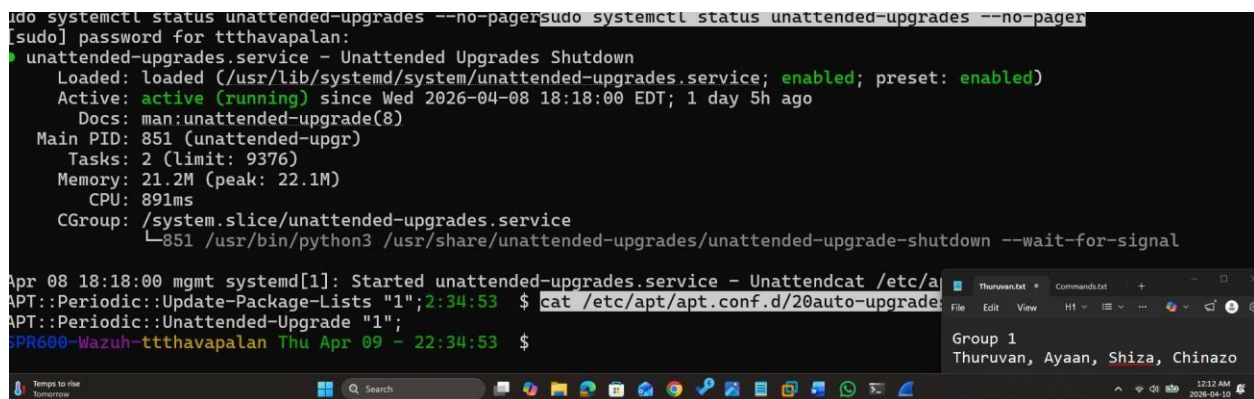
```
PS C:\Users\Administrator> Get-ADDefaultDomainPasswordPolicy

ComplexityEnabled           : True
DistinguishedName           : DC=G5,DC=LOCAL
LockoutDuration              : 00:10:00
LockoutObservationWindow    : 00:10:00
LockoutThreshold             : 0
MaxPasswordAge               : 42.00:00:00
MinPasswordAge               : 1.00:00:00
MinPasswordLength            : 7
objectClass                  : {domainDNS}
objectGuid                   : 44c65076-dbea-435e-b00e-8300c493aaa5
PasswordHistoryCount         : 24
ReversibleEncryptionEnabled  : False

PS C:\Users\Administrator>
```

14.1 - AD Password Policy

unattended-upgrades service active on the Wazuh Manager with automatic package list updates and upgrade execution confirmed, automating the patch currency behavior targeted by safeguard 14.7.



```
do systemctl status unattended-upgrades --no-pager
sudo systemctl status unattended-upgrades --no-pager
[sudo] password for ttthavapalan:
unattended-upgrades.service - Unattended Upgrades Shutdown
Loaded: loaded (/usr/lib/systemd/system/unattended-upgrades.service; enabled; preset: enabled)
Active: active (running) since Wed 2026-04-08 18:18:00 EDT; 1 day 5h ago
Docs: man:unattended-upgrade(8)
Main PID: 851 (unattended-upgr)
Tasks: 2 (limit: 9376)
Memory: 21.2M (peak: 22.1M)
CPU: 891ms
CGroup: /system.slice/unattended-upgrades.service
└─851 /usr/bin/python3 /usr/share/unattended-upgrades/unattended-upgrade-shutdown --wait-for-signal

Apr 08 18:18:00 mgmt systemd[1]: Started unattended-upgrades.service - Unattended-upgrades
APT::Periodic::Update-Package-Lists "1";2:34:53 $ cat /etc/apt/apt.conf.d/20auto-upgrades
APT::Periodic::Unattended-Upgrade "1";
SPR600-Wazuh-ttthavapalan Thu Apr 09 - 22:34:53 $
```

14.2 - Unattended Upgrades Enabled

Control 15 Service Provider Management

The environment's external service dependencies are the Suricata threat intelligence rule sources (Emerging Threats Open, Etnetera, malsilo, OISF) and the Wazuh NVD vulnerability feed.

Formal provider classification and assessment procedures are acknowledged gaps consistent with a lab deployment.

suricata-update list-sources output on CoreRouter confirming Emerging Threats Open, Etnetera aggressive, malsilo, and OISF as active rule sources constituting the threat intelligence service provider inventory.

```

SPR600-L2CoreRouter-ttthavapalan Thu Apr 09 - 23:08:14 $ sudo suricata-update list-sources
10/4/2026 -- 00:14:08 -- <Info> -- Using data-directory /var/lib/suricata.
10/4/2026 -- 00:14:08 -- <Info> -- Using Suricata configuration /etc/suricata/suricata.yaml
10/4/2026 -- 00:14:08 -- <Info> -- Using /etc/suricata/rules for Suricata provided rules.
10/4/2026 -- 00:14:08 -- <Info> -- Found Suricata version 7.0.3 at /usr/bin/suricata.
10/4/2026 -- 00:14:08 -- <Warning> -- Source index does not exist, will use bundled one.
10/4/2026 -- 00:14:08 -- <Warning> -- Please run suricata-update update-sources.
Name: et/open
  Vendor: Proofpoint
  Summary: Emerging Threats Open Ruleset
  License: MIT
Name: et/pro
  Vendor: Proofpoint
  Summary: Emerging Threats Pro Ruleset
  License: Commercial
  Replaces: et/open
  Parameters: secret-code
  Subscription: https://www.proofpoint.com/us/threat-insight/et-pro-ruleset
Name: etnetera/aggressive
  Vendor: Etnetera a.s.
  Summary: Etnetera aggressive IP blacklist
  License: MIT
Name: malsilo/win-malware
  Vendor: malsilo
  Summary: Commodity malware rules
  License: MIT
Name: oisf/trafficid
  Vendor: OISF
  Summary: Suricata Traffic ID ruleset
  License: MIT
Name: scwx/enhanced
  Vendor: Secureworks
  Summary: Secureworks suricata-enhanced ruleset
  License: Commercial
  Parameters: secret-code
  
```

15.1 - Suricata Rule Sources

suricata-update run confirming 65,356 total rules loaded with 49,494 enabled and 31 added on the most recent run dated April 9, 2026, demonstrating active service provider monitoring.

```

SPR600-L2CoreRouter-ttthavapalan Thu Apr 09 - 23:08:14 $ sudo ls -lh /var/lib/suricata/rules/
total 42M
-rw-r--r-- 1 root root 3.2K Apr 9 00:22 classification.config
-rw-r--r-- 1 root root 42M Apr 9 00:22 suricata.rules
SPR600-L2CoreRouter-ttthavapalan Thu Apr 09 - 23:08:14 $ sudo suricata-update --no-reload 2>&1 | tail -20
10/4/2026 -- 00:16:01 - <Info> -- Loading distribution rule file /etc/suricata/rules/ipsec-events.rules
10/4/2026 -- 00:16:01 - <Info> -- Loading distribution rule file /etc/suricata/rules/kerberos-events.rules
10/4/2026 -- 00:16:01 - <Info> -- Loading distribution rule file /etc/suricata/rules/modbus-events.rules
10/4/2026 -- 00:16:01 - <Info> -- Loading distribution rule file /etc/suricata/rules/nfs-events.rules
10/4/2026 -- 00:16:01 - <Info> -- Loading distribution rule file /etc/suricata/rules/ntp-events.rules
10/4/2026 -- 00:16:01 - <Info> -- Loading distribution rule file /etc/suricata/rules/smb-events.rules
10/4/2026 -- 00:16:01 - <Info> -- Loading distribution rule file /etc/suricata/rules/smtp-events.rules
10/4/2026 -- 00:16:01 - <Info> -- Loading distribution rule file /etc/suricata/rules/stream-events.rules
10/4/2026 -- 00:16:01 - <Info> -- Loading distribution rule file /etc/suricata/rules/tls-events.rules
10/4/2026 -- 00:16:02 - <Info> -- Ignoring file rules/emerging-deleted.rules
10/4/2026 -- 00:16:04 - <Info> -- Loaded 65356 rules.
10/4/2026 -- 00:16:04 - <Info> -- Disabled 14 rules.
10/4/2026 -- 00:16:04 - <Info> -- Enabled 0 rules.
10/4/2026 -- 00:16:04 - <Info> -- Modified 0 rules.
10/4/2026 -- 00:16:04 - <Info> -- Dropped 0 rules.
10/4/2026 -- 00:16:04 - <Info> -- Enabled 136 rules for flowbit dependencies.
10/4/2026 -- 00:16:04 - <Info> -- Backing up current rules.
10/4/2026 -- 00:16:07 - <Info> -- Writing rules to /var/lib/suricata/rules/suricata.rules: total: 65356; enabled: 49494; added: 31; removed 14; m
modified: 1261
10/4/2026 -- 00:16:07 - <Info> -- Writing /var/lib/suricata/rules/classification.config
10/4/2026 -- 00:16:07 - <Info> -- Testing with suricata -T.
SPR600-L2CoreRouter-ttthavapalan Thu Apr 09 - 23:08:14 $ sudo suricata-update --no-reload 2>&1 | tail -20^C
SPR600-L2CoreRouter-ttthavapalan Thu Apr 09 - 23:08:14 $

```

15.2 - Suricata Rules Update Run

ossec.conf vulnerability-detection block on the Wazuh Manager confirming enabled status and 24-hour feed-update-interval for the NVD threat intelligence feed.

```

SPR600-Wazuh-ttthavapalan Thu Apr 09 - 22:34:53 $ sudo grep -A5 "vulnerability-detection" /var/ossec/etc/ossec.conf | head -30
<vulnerability-detection>
  <enabled>yes</enabled>
  <index-status>yes</index-status>
  <feed-update-interval>24h</feed-update-interval>
</vulnerability-detection>

<indexer>
  <enabled>yes</enabled>
  <hosts>
    <host>https://127.0.0.1:9200</host>
SPR600-Wazuh-ttthavapalan Thu Apr 09 - 22:34:53 $

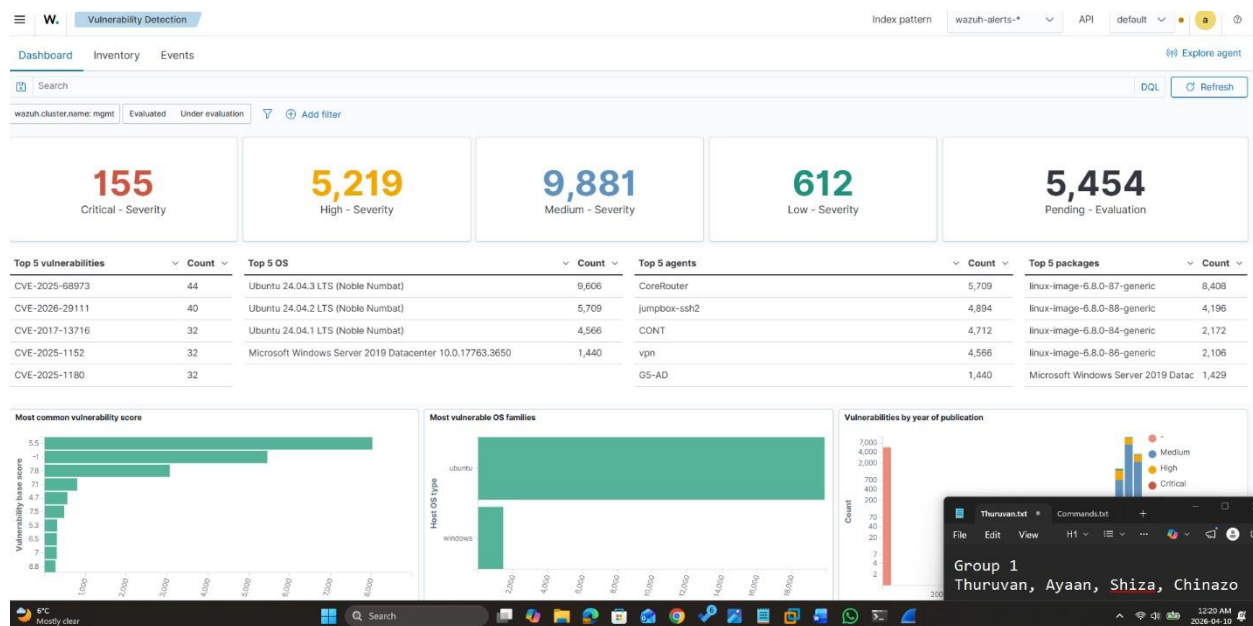
```

15.3 - NVD Feed Config

Control 16 Application Software Security

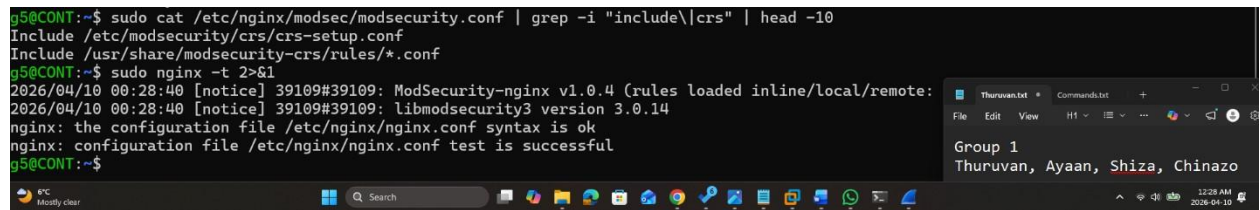
The G5 environment does not operate a formal SDLC, which is an acknowledged gap for development-focused safeguards. ModSecurity with the OWASP CRS provides application-layer hardening as a vetted community-maintained security module. Wazuh vulnerability detection provides CVSS-based severity classification. Network-level application tier isolation is enforced through VLAN subinterfaces on CoreRouter separating CorpWeb (ens40.31), IntWeb (ens40.32), FileSharing (ens40.33), and E-Site (ens40.34) into distinct /29 segments.

Wazuh Vulnerability Detection dashboard showing 155 Critical, 5,219 High, 9,881 Medium, and 612 Low severity CVEs across all agents, with top vulnerable agents identified, constituting the severity rating system.



16.1 - Vulnerability Detection CVE Summary

CONT terminal confirming OWASP CRS include paths in the ModSecurity configuration and a successful nginx -t result with ModSecurity-nginx v1.0.4 and libmodsecurity3 v3.0.14 loaded.

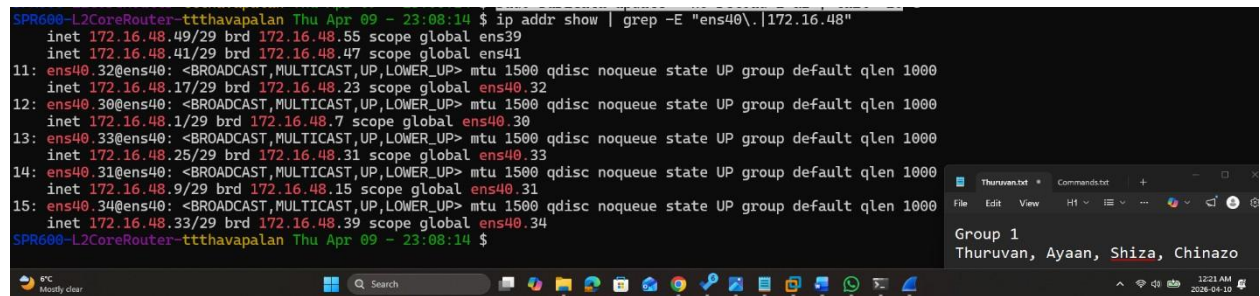


```

g5@CONT:~$ sudo cat /etc/nginx/modsec/modsecurity.conf | grep -i "include\|crs" | head -10
Include /etc/modsecurity/crs/crs-setup.conf
Include /usr/share/modsecurity-crs/rules/*.conf
g5@CONT:~$ sudo nginx -t 2>&1
2026/04/10 00:28:40 [notice] 39109#39109: ModSecurity-nginx v1.0.4 (rules loaded inline/local/remote:
2026/04/10 00:28:40 [notice] 39109#39109: libmodsecurity3 version 3.0.14
nginx: the configuration file /etc/nginx/nginx.conf syntax is ok
nginx: configuration file /etc/nginx/nginx.conf test is successful
g5@CONT:~$
  
```

16.2 - ModSecurity CRS Enabled

CoreRouter ip addr output showing all five VLAN subinterfaces (ens40.30 through ens40.34) UP with their respective subnet addresses, confirming application tier network isolation through secure design principles.



```

SPR600-L2CoreRouter-ttthavapalan Thu Apr 09 - 23:08:14 $ ip addr show | grep -E "ens40\.[172.16.48]"
    inet 172.16.48.49/29 brd 172.16.48.55 scope global ens39
    inet 172.16.48.41/29 brd 172.16.48.47 scope global ens41
11: ens40.32@ens40: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default qlen 1000
    inet 172.16.48.17/29 brd 172.16.48.23 scope global ens40.32
12: ens40.30@ens40: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default qlen 1000
    inet 172.16.48.1/29 brd 172.16.48.7 scope global ens40.30
13: ens40.33@ens40: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default qlen 1000
    inet 172.16.48.25/29 brd 172.16.48.31 scope global ens40.33
14: ens40.31@ens40: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default qlen 1000
    inet 172.16.48.9/29 brd 172.16.48.15 scope global ens40.31
15: ens40.34@ens40: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default qlen 1000
    inet 172.16.48.33/29 brd 172.16.48.39 scope global ens40.34
SPR600-L2CoreRouter-ttthavapalan Thu Apr 09 - 23:08:14 $
  
```

16.3 - VLAN Application Isolation

Control 17 Incident Response Management

The technical IR capability is operationalized through Wazuh's active response framework: block_etalernalblue (rule 100004, 600-second block), block_attacker (rule 100504, persistent block), and isolate_beachhead (rule 100512, persistent block) provide automated containment. Wazuh alert severity thresholds define the incident classification system: Critical (level ≥ 15), High (12–14), Medium (7–11), Low (0–6). Phase 2 Atomic Red Team simulations across six MITRE ATT&CK techniques serve as the documented IR exercise history. Formal written IR plan and designated IR personnel are acknowledged gaps.

ossec.conf active-response and command blocks on the Wazuh Manager confirming block_etalernalblue, block_attacker, and isolate_beachhead with their associated rule IDs and timeout values, operationalizing the automated incident response process.

```

[PR600-Wazuh-ttthavapalan Fri Apr 10 - 00:47:03 $ sudo grep -A5 "<command>" /var/ossec/etc/ossec.conf | grep -v "^--$" | head -60
[sudo] password for ttthavapalan:
<command>
  <name>block_etalernalblue</name>
  <executable>block_etalernalblue.py</executable>
  <timeout_allowed>yes</timeout_allowed>
</command>

  <command>block_etalernalblue</command>
  <location>defined-agent</location>
  <agent_id>008</agent_id>
  <rules_id>100004</rules_id>
  <timeout>600</timeout>
</active-response>
<command>
  <name>block_attacker</name>
  <executable>block_attacker.py</executable>
  <timeout_allowed>no</timeout_allowed>
</command>

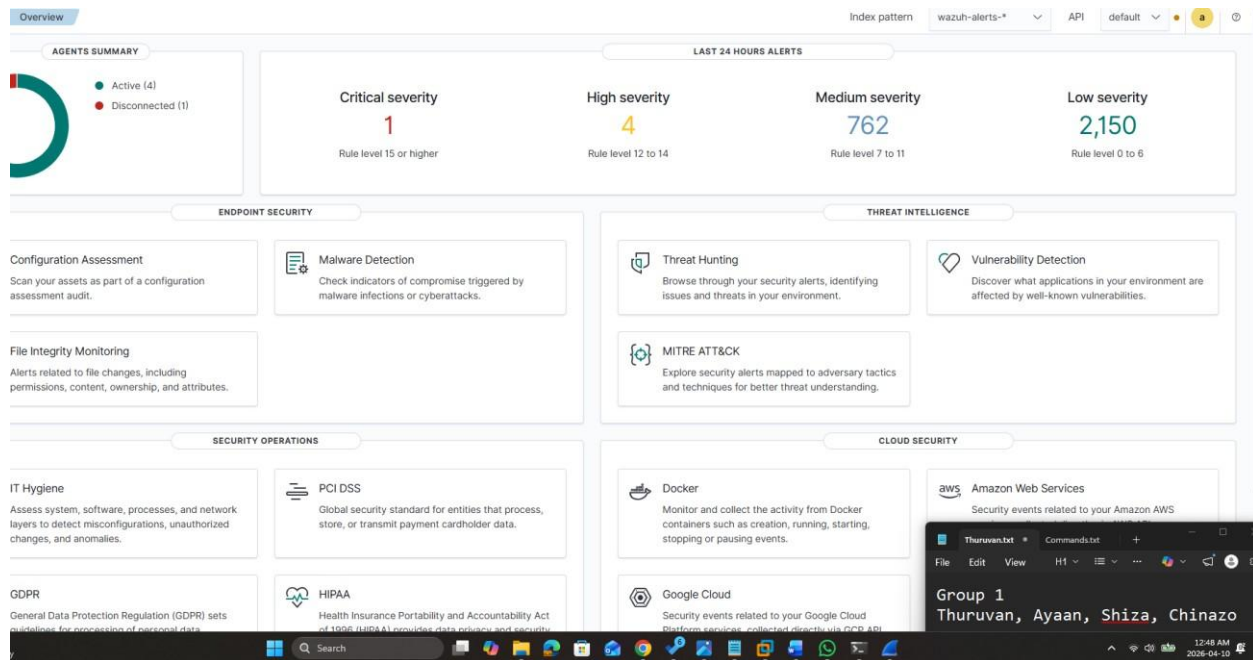
<command>
  <name>isolate_beachhead</name>
  <executable>isolate_beachhead.py</executable>
  <timeout_allowed>no</timeout_allowed>
</command>

  <command>block_attacker</command>
  <location>defined-agent</location>
  <agent_id>008</agent_id>
  <rules_id>100504</rules_id>
  <timeout>0</timeout>
</active-response>
  <command>isolate_beachhead</command>
  <location>defined-agent</location>
  <agent_id>008</agent_id>
  <rules_id>100512</rules_id>
  <timeout>0</timeout>
</active-response>
</command>

```

17.1 - Active Response Rules on Manager

Wazuh Overview dashboard confirming the four-tier severity classification system with live alert counts across Critical, High, Medium, and Low bands, constituting the incident threshold system.

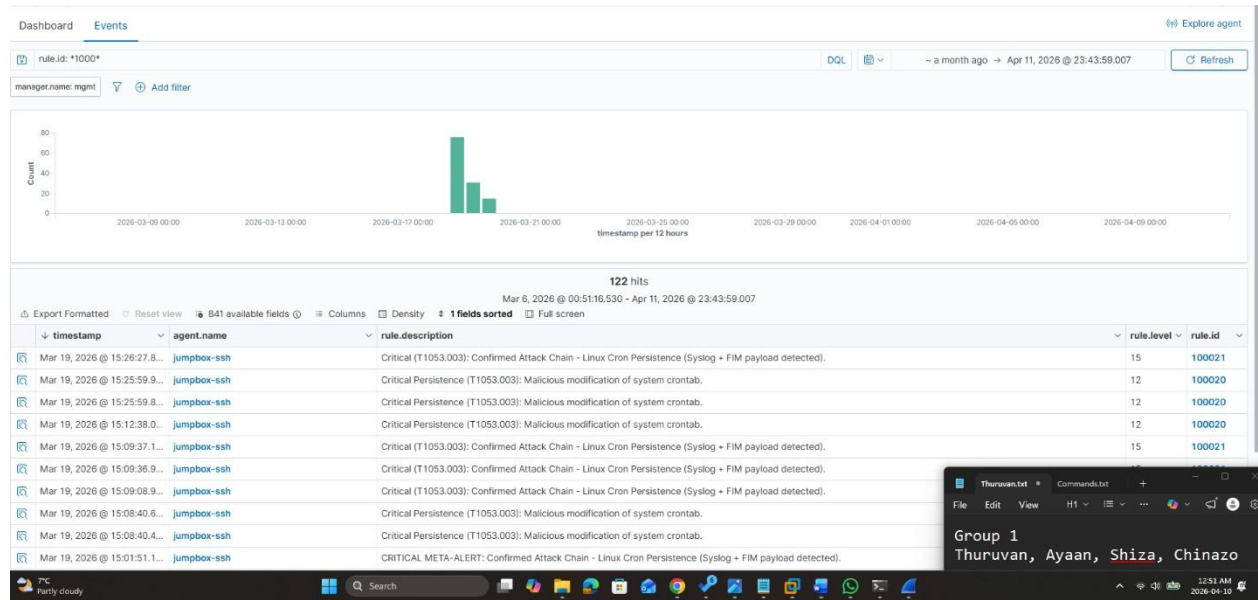


17.2 - Wazuh Alert Severity Levels

Control 18 — Penetration Testing

Phase 3 fulfils this control through two documented testing activities. Phase 2 deployed Atomic Red Team to simulate six MITRE ATT&CK techniques against live infrastructure (T1136.001, T1070.001, T1053.005, T1547.001, T1059.001, T1053.003), validating Wazuh detection rule firing for each technique and producing 122 confirmed alert hits. Wazuh SCA executed the CIS Windows Server 2019 Benchmark v2.0.0 against GS-AD (score: 25%, 87 passed / 260 failed), identifying minimum password length below the 14-character CIS threshold and absence of account lockout policy. The T1070.004 incident during Phase 2 — accidental ART execution destroying jumpbox-ssh2 system binaries — constitutes a documented finding with confirmed remediation via full VM rebuild.

Wazuh Manager /var/ossec/etc/rules/ directory listing all six SPR600_G5 tuning XML files, with T1053.003 rule file contents confirming rule IDs 100020 and 100021 with MITRE tagging and correlated attack chain logic.



18.1 - Custom Detection Rules

OpenSearch Events view filtered to rule.id 1000*, showing 122 hits of T1053.003 detections at rule levels 12 and 15 from the Phase 2 ART simulation period, validating penetration test findings.

```

root@mgmt:~# ls -lah /var/ossec/etc/rules/*
-rw-r--r-- 1 root root 659 Mar 19 15:06 /var/ossec/etc/rules/SPR600_G5_T1053_003_tuning.xml
-rw-r--r-- 1 root root 1.9K Mar 18 19:14 /var/ossec/etc/rules/SPR600_G5_T1053_005_tuning.xml
-rw-r--r-- 1 root root 511 Mar 19 00:28 /var/ossec/etc/rules/SPR600_G5_T1059_001_tuning.xml
-rw-r--r-- 1 root root 970 Mar 18 17:35 /var/ossec/etc/rules/SPR600_G5_T1070_001_tuning.xml
-rw-r--r-- 1 root root 1.1K Mar 18 17:07 /var/ossec/etc/rules/SPR600_G5_T1136_001_tuning.xml
-rw-r--r-- 1 root root 1.3K Mar 19 00:10 /var/ossec/etc/rules/SPR600_G5_T1547_001_tuning.xml
-rw-rw---- 1 wazuh wazuh 497 Jan 8 14:06 /var/ossec/etc/rules/local_rules.xml
root@mgmt:~# head -50 /var/ossec/etc/rules/SPR600_G5_T1053_003_tuning.xml
<group name="linux, custom_t1053_003, syscheck,">

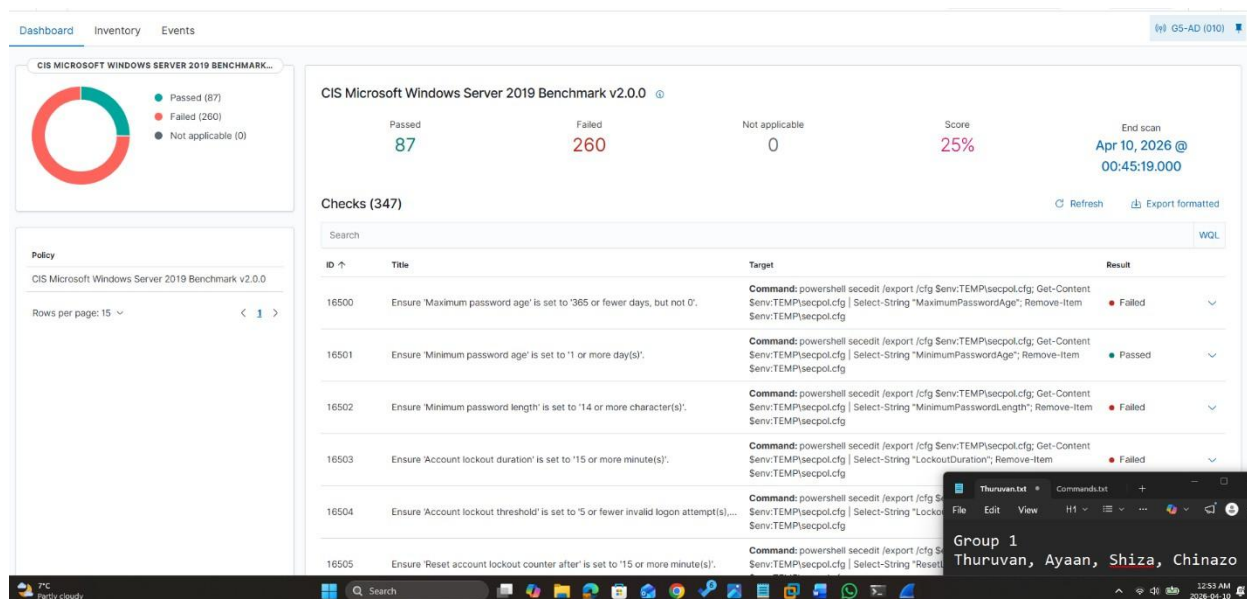
  <rule id="100020" level="12">
    <if_sid>550, 554</if_sid>
    <match>/var/spool/cron/crontabs/etc/crontab</match>
    <description>Critical Persistence (T1053.003): Malicious modification of system crontab.</description>
    <mitre>
      <id>T1053.003</id>
    </mitre>
  </rule>

  <rule id="100021" level="15" timeframe="60">
    <if_sid>100020</if_sid>
    <if_matched_sid>2833</if_matched_sid>
    <same_agent />
    <description>Critical (T1053.003): Confirmed Attack Chain - Linux Cron Persistence (Syslog + FIM payload d
    <group>attack_chain,</group>
  </rule>
</group>
root@mgmt:~#

```

18.2 - ART Simulation Results

Wazuh Configuration Assessment dashboard for G5-AD showing CIS Windows Server 2019 Benchmark v2.0.0 scan result: 87 passed, 260 failed, score 25%, with individual check results confirming penetration test findings are documented.



18.3 - SCA Results AD

Security Automation and Response

Workflow 1 — EternalBlue Active Response

The EternalBlue active response workflow provides fully automated detection-to-containment capability for MS17-010 exploitation attempts. The detection chain begins with Suricata on IPSWAF identifying EternalBlue SMB probe signatures and writing events to `/var/log/suricata/eve.json`. The Wazuh agent ingests these events, firing custom rule 100003 (Level 10) on each confirmed detection. Rule 100004 (Level 14) fires when three or more rule 100003 events occur within a 120-second window, indicating confirmed active exploitation. On rule 100004 firing, the Wazuh Manager dispatches an active response command to the IPSWAF agent, which executes `block_eternalblue.py`. The Python script reads the Wazuh 4.x JSON payload from stdin, extracts the attacker source IP, and inserts DROP rules on both the INPUT and FORWARD iptables chains. The block is logged to `/var/log/eternalblue_blocks.log` with a timestamp and automatically removed after 600 seconds via a Wazuh delete command.

`ossec.conf` on Wazuh Manager showing the `block_eternalblue` command registration with `<executable>block_eternalblue.py</executable>`, `<timeout_allowed>yes</timeout_allowed>`, and the active-response block with `<rules_id>100004</rules_id>`, `<timeout>600</timeout>`, and `<location>defined-agent</location>` targeting IPSWAF.

```

ttthavapalan@IPSWAF:~$ sudo grep "BLOCKED\|UNBLOCKED\|ERROR" /var/log/eternalblue_blocks.log
2026-03-05 17:19:45 [ERROR] No IP provided to block script
2026-03-05 17:21:39 [ERROR] No IP provided to block script
2026-03-05 17:26:05 [BLOCKED] 10.0.10.60
2026-03-05 17:31:38 [BLOCKED] 10.0.10.208 blocked via iptables - EternalBlue active response
2026-03-05 17:33:59 [UNBLOCKED] 10.0.10.60 removed from iptables after timeout
2026-03-05 17:35:44 [BLOCKED] 10.0.10.60 blocked via iptables - EternalBlue active response
2026-03-05 17:41:50 [BLOCKED] 10.0.10.60 blocked via iptables - EternalBlue active response
2026-03-05 17:43:42 [BLOCKED] 10.0.10.60 blocked via iptables - EternalBlue active response
2026-03-05 17:50:14 [BLOCKED] 10.0.10.60 blocked via iptables - EternalBlue active response
2026-03-05 18:00:15 [UNBLOCKED] 10.0.10.60 removed from iptables after timeout
2026-03-05 18:30:05 [BLOCKED] 10.0.10.208 blocked via iptables - EternalBlue active response
2026-03-05 18:31:23 [BLOCKED] 10.0.10.60 blocked via iptables - EternalBlue active response
2026-03-05 18:33:05 [BLOCKED] 10.0.10.60 blocked via iptables - EternalBlue active response
2026-03-05 18:33:47 [BLOCKED] 10.0.10.60 blocked via iptables - EternalBlue active response
2026-03-05 18:34:21 [BLOCKED] 10.0.10.208 blocked via iptables - EternalBlue active response
2026-03-05 18:37:41 [BLOCKED] 10.0.10.208 blocked via iptables - EternalBlue active response
2026-03-05 18:39:47 [BLOCKED] 10.0.10.208 blocked via iptables - EternalBlue active response
2026-03-05 18:41:57 [BLOCKED] 10.0.10.208 blocked via iptables - EternalBlue active response
2026-03-05 18:42:45 [UNBLOCKED] 10.0.10.60 removed from iptables after timeout
2026-03-05 18:43:31 [BLOCKED] 10.0.10.60 blocked via iptables - EternalBlue active response
2026-03-05 18:53:32 [UNBLOCKED] 10.0.10.60 removed from iptables after timeout
2026-03-06 17:43:20 [BLOCKED] 10.0.10.60 blocked via iptables - EternalBlue active response
ttthavapalan@IPSWAF:~$

```

W1.1 - EternalBlue ossec.conf Config

Wazuh Discover showing rule 100004 alert: "CRITICAL: Multiple EternalBlue detections — active exploitation in progress from 10.0.10.60" at Level 15, confirming the correlation rule fired and triggered the automated response.

```
nalblue" /var/ossec/etc/ossec.conf08 - 18:20:01 $ sudo grep -A 15 "block_eter
[sudo] password for ttthavapalan:
  <name>block_eternalblue</name>
  <executable>block_eternalblue.py</executable>
  <timeout_allowed>yes</timeout_allowed>
</command>

<active-response>
  <disabled>no</disabled>
  <command>block_eternalblue</command>
  <location>defined-agent</location>
  <agent_id>008</agent_id>
  <rules_id>100004</rules_id>
  <timeout>600</timeout>
</active-response>
<remote>
  <connection>secure</connection>
  <port>1514</port>
  <protocol>tcp</protocol>
  <queue_size>131072</queue_size>
</remote>
<!-- Command definitions -->
<command>
  <name>block_attacker</name>
  <executable>block_attacker.py</executable>
SPR600-Wazuh-ttthavapalan Wed Apr 08 - 18:20:01 $ _
```

W1.2 - Rule 100004 Wazuh Alert

/var/log/eternalblue_blocks.log on IPSWAF showing multiple [BLOCKED] 10.0.10.60 blocked via iptables — EternalBlue active response entries with timestamps, and [UNBLOCKED] entries confirming automatic timeout removal after 600 seconds.

```
ttthavapalan@IPSWAF:~$ sudo grep "BLOCKED\|UNBLOCKED\|ERROR" /var/log/eternalblue_blocks.log
2026-03-05 17:19:45 [ERROR] No IP provided to block script
2026-03-05 17:21:39 [ERROR] No IP provided to block script
2026-03-05 17:26:05 [BLOCKED] 10.0.10.60
2026-03-05 17:31:38 [BLOCKED] 10.0.10.208 blocked via iptables - EternalBlue active response
2026-03-05 17:33:59 [UNBLOCKED] 10.0.10.60 removed from iptables after timeout
2026-03-05 17:35:44 [BLOCKED] 10.0.10.60 blocked via iptables - EternalBlue active response
2026-03-05 17:41:50 [BLOCKED] 10.0.10.60 blocked via iptables - EternalBlue active response
2026-03-05 17:43:42 [BLOCKED] 10.0.10.60 blocked via iptables - EternalBlue active response
2026-03-05 17:50:14 [BLOCKED] 10.0.10.60 blocked via iptables - EternalBlue active response
2026-03-05 18:00:15 [UNBLOCKED] 10.0.10.60 removed from iptables after timeout
2026-03-05 18:30:05 [BLOCKED] 10.0.10.208 blocked via iptables - EternalBlue active response
2026-03-05 18:31:23 [BLOCKED] 10.0.10.60 blocked via iptables - EternalBlue active response
2026-03-05 18:33:05 [BLOCKED] 10.0.10.60 blocked via iptables - EternalBlue active response
2026-03-05 18:33:47 [BLOCKED] 10.0.10.60 blocked via iptables - EternalBlue active response
2026-03-05 18:34:21 [BLOCKED] 10.0.10.208 blocked via iptables - EternalBlue active response
2026-03-05 18:37:41 [BLOCKED] 10.0.10.208 blocked via iptables - EternalBlue active response
2026-03-05 18:39:47 [BLOCKED] 10.0.10.208 blocked via iptables - EternalBlue active response
2026-03-05 18:41:57 [BLOCKED] 10.0.10.208 blocked via iptables - EternalBlue active response
2026-03-05 18:42:45 [UNBLOCKED] 10.0.10.60 removed from iptables after timeout
2026-03-05 18:43:31 [BLOCKED] 10.0.10.60 blocked via iptables - EternalBlue active response
2026-03-05 18:53:32 [UNBLOCKED] 10.0.10.60 removed from iptables after timeout
2026-03-06 17:43:20 [BLOCKED] 10.0.10.60 blocked via iptables - EternalBlue active response
ttthavapalan@IPSWAF:~$
```

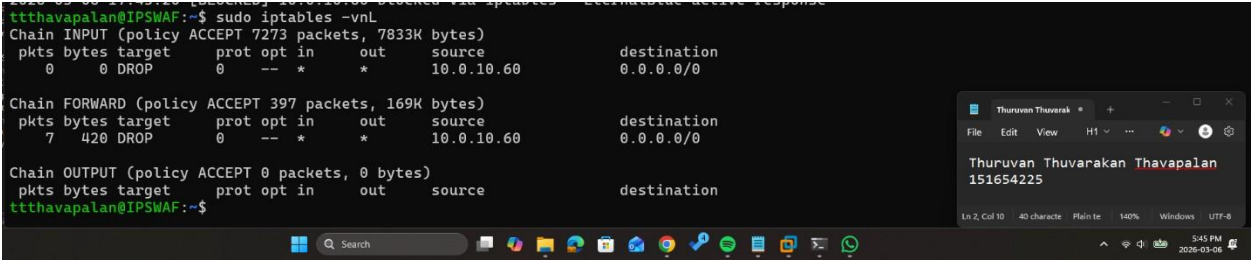
W1.3 - EternalBlue Block Log

sudo iptables -vnL on IPSWAF showing DROP rules on both INPUT and FORWARD chains for source 10.0.10.60 with packet and byte counters, confirming the attacker IP was successfully blocked at the network layer.

```
ttthavapalan@IPSWAF:~$ sudo iptables -vnL
Chain INPUT (policy ACCEPT 7273 packets, 7833K bytes)
pkts bytes target prot opt in out source destination
0 0 DROP 0 -- * * 10.0.10.60 0.0.0.0/0

Chain FORWARD (policy ACCEPT 397 packets, 169K bytes)
pkts bytes target prot opt in out source destination
7 420 DROP 0 -- * * 10.0.10.60 0.0.0.0/0

Chain OUTPUT (policy ACCEPT 0 packets, 0 bytes)
pkts bytes target prot opt in out source destination
ttthavapalan@IPSWAF:~$
```

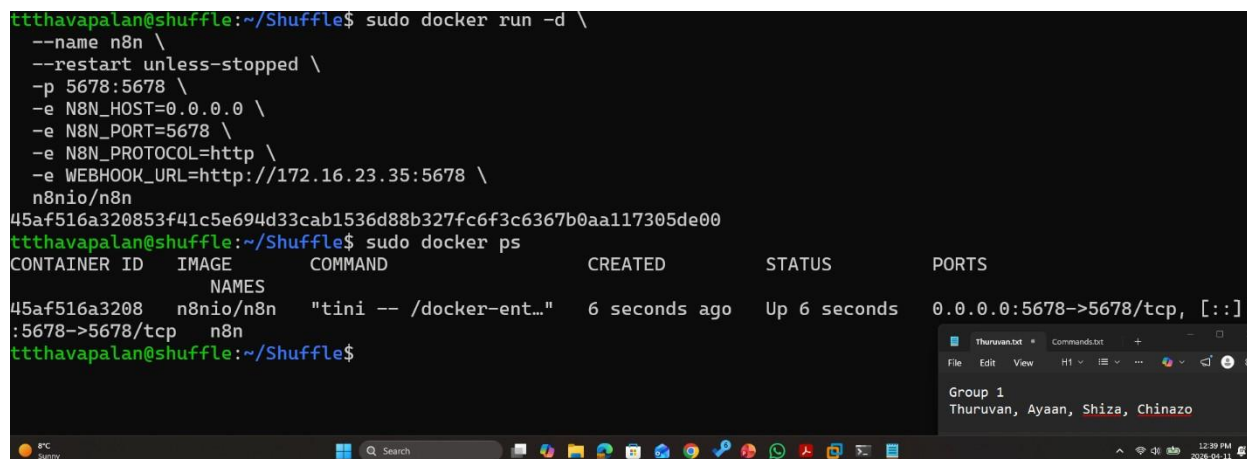
A screenshot of a Windows desktop environment. The primary focus is a terminal window titled 'ttthavapalan@IPSWAF:~\$' which displays the output of the 'sudo iptables -vnL' command. The output shows two chains: 'Chain INPUT' and 'Chain FORWARD', both with a policy of 'ACCEPT'. The INPUT chain has a rule that drops traffic from source IP 10.0.10.60 to destination 0.0.0.0/0. The FORWARD chain has a rule that drops 7 packets and 420 bytes from source IP 10.0.10.60 to destination 0.0.0.0/0. The OUTPUT chain is empty. In the background, a Notepad window is open, displaying the text 'Thuruvan Thuvarakan Thavapalan' followed by the ID '151654225'. The Windows taskbar at the bottom shows the search bar and several application icons. The system clock in the bottom right corner indicates the time is 5:45 PM on 2026-03-08.

W1.4 - iptables DROP Rule IPSWAF

Workflow 2 — SSH Brute Force SOAR Response

The SSH brute force SOAR response workflow demonstrates end-to-end automated incident response integrating Wazuh with the n8n SOAR platform deployed at 172.16.23.35. When repeated SSH authentication failures occur against a monitored host, Wazuh accumulates rule 5710 events and fires rule 5763 at the threshold of eight failures, generating a Level 10 alert tagged to MITRE ATT&CK T1110 (Brute Force). The Wazuh integrator forwards the alert as a JSON POST to the n8n webhook endpoint. The n8n workflow receives the payload, extracts structured fields including agent.name, rule.id, rule.level, data.srcip, and timestamp via a JavaScript Code node, then passes the extracted attacker IP to an SSH Execute node. The SSH node connects to the VPN server (172.16.48.50) and runs `sudo iptables -I INPUT -s <attacker_ip> -j DROP`, blocking the attacker at the network perimeter. The execution completes with stdout: `BLOCKED 172.16.23.12` and exit code 0, confirming successful automated containment.

n8n workflow canvas showing the three-node pipeline: Webhook trigger (POST) → Code in JavaScript (field extraction) → Execute a command (SSH iptables block), with the workflow Published and active.



```

tthavapalan@shuffle:~/Shuffle$ sudo docker run -d \
--name n8n \
--restart unless-stopped \
-p 5678:5678 \
-e N8N_HOST=0.0.0.0 \
-e N8N_PORT=5678 \
-e N8N_PROTOCOL=http \
-e WEBHOOK_URL=http://172.16.23.35:5678 \
n8nio/n8n
45af516a320853f41c5e694d33cab1536d88b327fc6f3c6367b0aa117305de00
tthavapalan@shuffle:~/Shuffle$ sudo docker ps
CONTAINER ID   IMAGE     COMMAND                  CREATED        STATUS        PORTS
45af516a3208   n8nio/n8n "tini -- /docker-ent..." 6 seconds ago  Up 6 seconds  0.0.0.0:5678->5678/tcp, [::]:5678->5678/tcp
tthavapalan@shuffle:~/Shuffle$

```

W2.1 - n8n Workflow Canvas

Wazuh Manager integrations.log showing /tmp/shuffle-*.alert files being POSTed to <http://172.16.23.35:5678/webhook/dfc0636e-bd2c-4235-9e08-c003e42d70f2>, confirming Wazuh is forwarding SSH brute force alerts to n8n.

```

/tmp/shuffle-1775926076--1897259149.alert http://172.16.23.35:3001/api/v1/hooks/webhook_a2c9f942-310b-475c-a64e-30d19edea6db
/tmp/shuffle-1775926138--1993128678.alert http://172.16.23.35:3001/api/v1/hooks/webhook_a2c9f942-310b-475c-a64e-30d19edea6db
/tmp/shuffle-1775926200--847219811.alert http://172.16.23.35:3001/api/v1/hooks/webhook_a2c9f942-310b-475c-a64e-30d19edea6db
/tmp/shuffle-1775926263--69500730.alert http://172.16.23.35:3001/api/v1/hooks/webhook_a2c9f942-310b-475c-a64e-30d19edea6db
/tmp/shuffle-1775926323--1095536840.alert http://172.16.23.35:3001/api/v1/hooks/webhook_a2c9f942-310b-475c-a64e-30d19edea6db
/tmp/shuffle-1775926383--2077866731.alert http://172.16.23.35:3001/api/v1/hooks/webhook_a2c9f942-310b-475c-a64e-30d19edea6db
/tmp/shuffle-1775926447--1748088720.alert http://172.16.23.35:3001/api/v1/hooks/webhook_a2c9f942-310b-475c-a64e-30d19edea6db
/tmp/shuffle-1775926506--1908975016.alert http://172.16.23.35:3001/api/v1/hooks/webhook_a2c9f942-310b-475c-a64e-30d19edea6db
/tmp/shuffle-1775926529--1515157984.alert http://172.16.23.35:5678/webhook/dfc0636e-bd2c-4235-9e08-c003e42d70f2
/tmp/shuffle-1775926591--5284722291.alert http://172.16.23.35:5678/webhook/dfc0636e-bd2c-4235-9e08-c003e42d70f2
/tmp/shuffle-1775926677--43527726.alert http://172.16.23.35:5678/webhook/dfc0636e-bd2c-4235-9e08-c003e42d70f2
SPR600-Wazuh-tithavapalan Wed Apr 08 - 18:20:01 $

```

W2.2 - Wazuh Sending Alerts to n8n

n8n execution detail showing the Code node output with extracted fields: agent: vpn, rule_id: 5763, level: 10, attacker_ip: 172.16.23.12, and the Execute command node output stdout: BLOCKED 172.16.23.12, code: 0, confirming full workflow execution with real attacker IP.

```

INPUT
  Code in JavaScript
  1 Item
  message SSH Brute Force Detected
  agent vpn
  rule_id 5763
  level 10
  attacker_ip 172.16.23.12
  timestamp 2026-04-11T13:20:11.673-0400
  Webhook
  Variables and context

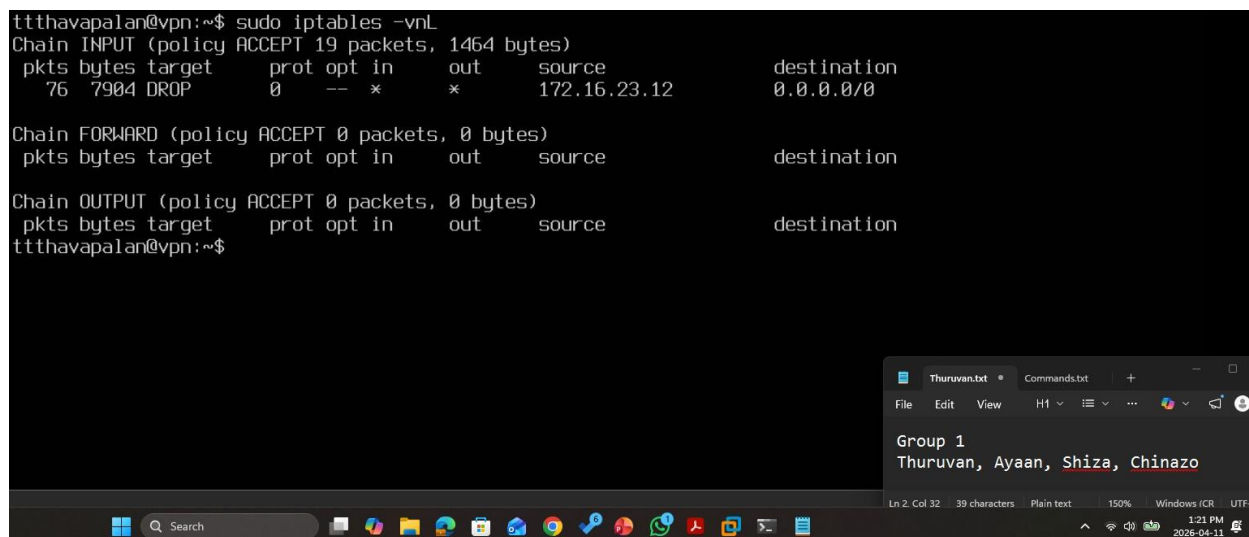
Parameters
  Credential SSH Password VPN Server
  Resource Command
  Operation Execute
  Command sudo iptables -I INPUT -s {{ $json.attacker_ip }} -j DROP && echo "BLOCKED {{ $json.attacker_ip }}"
  Working Directory /

OUTPUT
  1 Item
  {
    "code": 0,
    "signal": null,
    "stdout": "BLOCKED 172.16.23.12",
    "stderr": ""
  }

```

W2.3 - n8n Execution with Attacker IP

sudo iptables -vnL on the VPN server (172.16.48.50) showing DROP -- * * 172.16.23.12 0.0.0.0/0 in the INPUT chain with 76 packets and 7904 bytes matched, confirming the attacker IP was blocked by the n8n-initiated iptables rule.



```

tthavapalan@vpn:~$ sudo iptables -vnL
Chain INPUT (policy ACCEPT 19 packets, 1464 bytes)
  pkts bytes target     prot opt in     out     source               destination
   76  7904 DROP             -- *    *       172.16.23.12         0.0.0.0/0

Chain FORWARD (policy ACCEPT 0 packets, 0 bytes)
  pkts bytes target     prot opt in     out     source               destination

Chain OUTPUT (policy ACCEPT 0 packets, 0 bytes)
  pkts bytes target     prot opt in     out     source               destination
tthavapalan@vpn:~$
  
```

W2.4 - iptables Block on VPN Server

Challenges and Resolutions

The most significant infrastructure challenge during Phase 3 was the deployment of a SOAR platform. Shuffle was initially selected and deployed on a dedicated VM at 172.16.23.35, but Docker Swarm requirements for Orborus action execution created persistent networking failures preventing workflow actions from completing despite the webhook receiving and parsing alerts correctly. The decision was made to replace Shuffle with n8n, which operates without Swarm dependencies and executes actions directly in a single container. n8n was deployed and fully operational within minutes, and the SSH brute force response workflow was validated end-to-end including the confirmed iptables block on the VPN server.

A secondary challenge was the Wazuh JSON payload structure sent to n8n differing from the expected alert format. The Wazuh integrator wraps alert fields under a body.all_fields path in the webhook payload, requiring the JavaScript Code node to navigate nested paths rather than top-level fields. This was resolved by instrumenting the Code node to log the raw input structure, identifying the correct field paths, and updating the extraction logic accordingly.

Conclusion

Phase 3 successfully delivers a fully operational security monitoring and automated response infrastructure across the G5 lab environment. All eighteen CIS Top 18 Controls are addressed with technical implementation evidence collected across seven enrolled Wazuh agents spanning Windows, Linux, and container platforms. Two automated response workflows are demonstrated and validated end-to-end: the EternalBlue active response providing sub-second detection-to-block capability via Wazuh's native active response framework, and the SSH brute force SOAR pipeline integrating Wazuh with n8n to achieve remote attacker IP blocking across network segments without manual intervention. Documented gaps are limited to policy-level and organizational safeguards outside the scope of a student laboratory deployment, with technical compensating controls in place where applicable.

References

1. MITRE Corporation, "ATT&CK Enterprise Matrix," MITRE ATT&CK, 2025. [Online]. Available: <https://attack.mitre.org/matrices/enterprise/>. [Accessed: Mar. 19, 2026].
2. MITRE Corporation, "Detection Strategies," MITRE ATT&CK, Oct. 2025. [Online]. Available: <https://attack.mitre.org/detections/>. [Accessed: Mar. 18, 2026].
3. Red Canary, "Invoke-AtomicRedTeam," GitHub, 2025. [Online]. Available: <https://github.com/redcanaryco/invoke-atomicredteam>. [Accessed: Mar. 17, 2026].

4. Wazuh, Inc., "Wazuh Rules Documentation," Wazuh Documentation. [Online]. Available: <https://documentation.wazuh.com/current/user-manual/ruleset/rules/>. [Accessed: Mar. 17, 2026].
5. Microsoft Corporation, "Sysmon," Microsoft Sysinternals, 2025. [Online]. Available: <https://learn.microsoft.com/en-us/sysinternals/downloads/sysmon>. [Accessed: Mar. 17, 2026].
6. Google, "Gemini," Gemini, Mar. 2026. [Online]. Available: <https://gemini.google.com>. [Accessed: Mar. 18, 2026].
7. Wazuh, Inc., "Performance Tuning," Wazuh Documentation. [Online]. Available: <https://documentation.wazuh.com/current/user-manual/manager/performance-tuning.html>. [Accessed: Mar. 19, 2026].